arXiv:2601.05293v1 [cs.CR] 8 Jan 2026

A Survey of Agentic AI and Cybersecurity: Challenges, Opportunities and Use-case Prototypes

SAHAYA JESTUS LAZER, Tennessee Tech University, United States
KSHITIZ ARYAL, University of Nebraska Omaha, United States
MAANAK GUPTA, Tennessee Tech University, United States
ELISA BERTINO, Purdue University, United States

Agentic AI marks an important transition from single-step generative models to systems capable of reasoning, planning, acting, and adapting over long-lasting tasks. By integrating memory, tool use, and iterative decision cycles, these systems enable continuous, autonomous workflows in real-world environments. This survey examines the implications of agentic AI for cybersecurity. On the defensive side, agentic capabilities enable continuous monitoring, autonomous incident response, adaptive threat hunting, and fraud detection at scale. Conversely, the same properties amplify adversarial power by accelerating reconnaissance, exploitation, coordination, and social-engineering attacks. These dual-use dynamics expose fundamental gaps in existing governance, assurance, and accountability mechanisms, which were largely designed for non-autonomous and short-lived AI systems. To address these challenges, we survey emerging threat models, security frameworks, and evaluation pipelines tailored to agentic systems, and analyze systemic risks including agent collusion, cascading failures, oversight evasion, and memory poisoning. Finally, we present three representative use-case implementations that illustrate how agentic AI behaves in practical cybersecurity workflows, and how design choices shape reliability, safety, and operational effectiveness.

ACM Reference Format:
Sahaya Jestus Lazer, Kshitiz Aryal, Maanak Gupta, and Elisa Bertino. 2026. A Survey of Agentic AI and Cybersecurity: Challenges, Opportunities and Use-case Prototypes. 1, 1 (January 2026), 36 pages. https://doi.org/10.1145/nnnnnnn.nnnnnnn

1 Introduction

Artificial intelligence has evolved from rule-based automation to generative AI (GenAI) and, recently, to *agentic* models capable of autonomous reasoning, planning, and decision-making. While generative AI systems, such as large language models (LLMs), are largely reactive and prompt-driven, agentic AI introduces persistent state, tool use, and self-directed control loops that enable planning, action, and revision across long-lived, multi-step workflows. This shift from isolated inference to autonomous agency represents a fundamental change in how AI systems participate in digital ecosystems.

Cybersecurity is among the domains most directly affected by this transition. Security operations inherently involve continuous monitoring, sequential decision-making, coordination across tools, and adaptation to adversarial behavior—all characteristics well aligned with agentic AI capabilities. Driven by operational pressure and workforce shortages approaching four million professionals worldwide, organizations are rapidly adopting AI-assisted security

Authors' Contact Information: Sahaya Jestus Lazer, Tennessee Tech University, Cookeville, United States, slazer42@tntech.edu; Kshitiz Aryal, University of Nebraska Omaha, Omaha, United States, karyal@unomaha.edu; Maanak Gupta, Tennessee Tech University, Cookeville, United States, mgupta@tntech.edu; Elisa Bertino, Purdue University, West Lafayette, United States, bertino@cs.purdue.edu.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.
© 2026 Copyright held by the owner/author(s). Publication rights licensed to ACM.
Manuscript submitted to ACM

arXiv:2601.05293v1 [cs.CR] 8 Jan 2026

代理 AI 與網路安全調查：挑戰、機會與用例原型

SAHAYA JESTUS LAZER，田納西理工大學，美國
KSHITIZ ARYAL，美國內布拉斯加大學奧馬哈分校
MAANAK GUPTA，田納西科技大學，美國
ELISA BERTINO，普渡大學，美國

代理式 AI 標誌著從單一步驟生成模型向具備推理、規劃、行動及長期任務適應能力的系統的重要轉變。透過整合記憶、工具使用與迭代決策循環，這些系統能在真實環境中實現持續且自主的工作流程。本調查檢視代理式 AI 對網路安全的影響。在防禦端，代理式能力使持續監控、自主事件回應、適應性威脅獵殺及大規模詐欺偵測成為可能。反之，這些特性亦放大了對抗力量，加速了偵查、利用、協調與社會工程攻擊。這些雙用途動態暴露了現有治理、驗證與責任機制中的根本性缺口，這些機制原本主要是為非自主且短期壽命的 AI 系統所設計。為應對這些挑戰，本調查檢視針對代理式系統量身打造的新興威脅模型、安全架構與評估流程，並分析系統性風險，包括代理串謀、連鎖失效、監管規避與記憶投毒。最後，我們呈現三個具代表性的使用案例實作，說明代理式 AI 在實際網路安全工作流程中的行為，以及設計選擇如何影響可靠性、安全性與運作效能。

ACM 引用格式：
Sahaya Jestus Lazer, Kshitiz Aryal, Maanak Gupta, 以及 Elisa Bertino。2026 年。關於代理 AI 與網路安全的調查：挑戰、機會與使用案例原型。第 1 卷，第 1 期（2026 年 1 月），共 36 頁。https://doi.org/10.1145/nnnnnnn.nnnnnnn

1 簡介

人工智慧已從基於規則的自動化，演進至生成式人工智慧（GenAI），近期更發展出具備自主推理、規劃與決策能力的代理模型。雖然生成式 AI 系統（如大型語言模型）主要具有反應式與提示驅動的特性，但代理式 AI 則引入了持續狀態、工具使用與自我導向的控制迴路，使系統能在長壽、多步驟的工作流程中進行規劃、執行與修正。從孤立推論轉向自主代理，標誌著 AI 系統參與數位生態系統的方式發生了根本性轉變。

網路安全是受此轉型影響最直接的領域之一。安全運作的本質涉及持續監控、循序漸進的決策、跨工具的協調，以及對敵對行為的適應，這些特徵與代理式 AI 的能力高度契合。在營運壓力與全球約四百萬專業人員短缺的驅動下，組織正迅速採用 AI 輔助的安全措施。

作者聯絡資訊：Sahaya Jestus Lazer，田納西理工大學，庫克維爾，美國，slazer42@tntech.edu；Kshitiz Aryal，內布拉斯加大學奧馬哈分校，奧馬哈，美國，karyal@unomaha.edu；Maanak Gupta，田納西理工大學，庫克維爾，美國，mgupta@tntech.edu；Elisa Bertino，普渡大學，韋斯特萊法特，美國，bertino@cs.purdue.edu。

允許為個人或教室用途複製本作品（全部或部分）的數位或硬拷貝，無需付費，前提是複製品不得用於營利或商業目的，且複製品上需載有本通知及第一頁的完整引用。本作品的組件版權
本著作中歸屬於作者以外之其他權利人之著作，應予尊重。經註明來源之摘要，得予許可。其他任何複製或再版、張貼於伺服器或重新分發至列表，需要事先獲得特定許可和/或費用 . 向 permissions@acm 請求權限 .org.
© 2026 版權由所有者/作者持有。出版權已授權給 ACM。
提交至 ACM 的手稿

solutions. Market projections reflect this momentum, with global AI-in-cybersecurity spending expected to grow from US$24.8 B in 2024 toward US$146.5 B by 2034 [85]. Agentic AI amplifies human capacity through automated alert triage, autonomous incident response, scalable red–blue simulation, and continuous security operations center (SOC) support.

At the same time, increased autonomy fundamentally alters the threat landscape. Features that enable defensive coordination—planning, memory, tool orchestration, and multi-agent interaction—can also be exploited to enhance offensive operations. Agents can autonomously conduct reconnaissance, adapt exploitation strategies, coordinate social-engineering campaigns, and evade oversight. As a result, agentic AI introduces a pronounced dual-use dilemma in cybersecurity: it strengthens defense while simultaneously amplifying adversarial capability. This dual-use dynamic exposes limitations in existing security, assurance, and governance models. Most current controls assume short-lived, human-in-the-loop, or narrowly scoped AI systems. In contrast, agentic AI systems act continuously, retain long-term memory, coordinate with other agents, and make consequential decisions with reduced human supervision. These properties introduce systemic risks—including emergent collusion, cascading failures, memory poisoning, and oversight evasion—that are not adequately captured by traditional model-centric safety or lifecycle-based security frameworks.

While prior work has explored isolated aspects of AI safety or specific applications such as reinforcement learning for intrusion detection, it does not provide a holistic view of agentic AI as a cybersecurity actor. Autonomy, persistence, and multi-agent interaction introduce new opportunities alongside systemic risks such as emergent collusion, oversight evasion, and governance gaps. This survey addresses that gap by synthesizing agentic AI across defensive, offensive, and governance-oriented cybersecurity contexts.

Our survey makes the following key contributions:

- **Conceptual foundation:** A review of the evolution of Agentic AI, its relationship to Generative AI, and key design properties, autonomy levels, and reference architectures.
- **Security use cases:** An overview of defensive and enterprise applications including SOC automation, continuous monitoring, anomaly detection, insider-threat detection, vulnerability management, and financial fraud defense.
- **Offensive applications:** A survey of emerging offensive uses of agentic AI in red–blue simulations, autonomous penetration testing, and CTF automation, with emphasis on dual-use concerns.
- **Security outlook:** A detailed analysis of systemic risks specific to agentic AI, including collusion, synthetic insider threats, and emergent behaviors, and their governance implications.
- **Quantum considerations:** An analysis of intersections between quantum computing and agentic AI in cybersecurity, including quantum agents, quantum machine learning, and post-quantum cryptography.
- **Frameworks and governance:** A review of security and governance frameworks that support safe deployment and operational control of agentic AI.
- **Benchmarks and evaluation:** An analysis of benchmarks, evaluation pipelines, and testbeds for agentic AI security, with remaining gaps.
- **Implementations:** Three original implementations integrating agentic AI into cybersecurity workflows, highlighting practical lessons.

2 Related Work

Recent surveys have examined security risks in LLMs and agent-based systems from multiple perspectives. This section focuses on prior surveys and taxonomies; and highlight the relation with our work.

A first class of work adopts a model-centric perspective. Wang et al. survey LLM safety across the model lifecycle, including data collection, alignment, deployment, and red-teaming [163]. While comprehensive, this approach treats

解決方案。市場預測反映了這一動能，預計全球在網路安全領域的 AI 投入將從 2024 年的 248 億美元增長至 2034 [85] 的 1465 億美元。代理式 AI 透過自動化警報分級、自主事件回應、可擴展的紅藍演練以及持續的網路安全營運中心（SOC）支援，來擴充人類能力。

同時，自主性的提升根本性地改變了威脅格局。能夠促進防禦協調的功能——包括規劃、記憶、工具調度以及多代理互動——也可能被濫用以增強攻擊行動。代理可以自主進行偵查、調整攻陷策略、協調社會工程活動，並規避監管。因此，代理式 AI 在網路安全領域引入了顯著的雙用困境：它既強化了防禦，同時又放大了敵對能力。這種雙用動態暴露了現有安全、保證與治理模型的局限。大多數現有的控制措施假設 AI 系統是短暫運行、有人類在環或作用範圍狹窄的。相比之下，代理式 AI 系統持續運作，保留長期記憶，與其他代理協作，並在減少人類監督的情況下做出具有影響力的決策。這些特性引入了系統性風險，包括突發共謀、連鎖故障、記憶污染以及監管規避，這些風險無法被傳統以模型為核心的安全或基於生命週期的安全框架充分捕捉。

儘管先前的研究探討了 AI 安全的孤立面向或特定應用（例如用於入侵檢測的強化學習），但並未提供將代理型 AI 視為網路安全行動者的整體視角。自主性、持續性及多代理互動帶來了新的機會，同時也伴隨系統性風險，例如突發共謀、監管規避與治理缺口。本調查透過整合防禦、攻擊與治理導向的網路安全情境，以彌補此一缺口。

我們的調查做出了以下關鍵貢獻：

- 概念基礎：關於代理式 AI 演進的綜述，其與生成式 AI 的關係，以及關鍵設計屬性、自主程度與參考架構。
- 安全用例：涵蓋防禦與企業應用概述，包括 SOC 自動化、持續監控、異常檢測、內部威脅檢測、漏洞管理以及金融防詐。
- 攻擊性應用：關於代理型 AI 在紅藍演練、自主滲透測試及 CTF 自動化中新興攻擊用途的調查，並着重於雙用途議題。
- 安全展望：針對代理式 AI 特定系統性風險的詳細分析，包括合謀、合成內部威脅及突現行為，及其治理意涵。
- 量子考量：分析量子計算與代理式 AI 在網路安全領域的交集，涵蓋量子代理、量子機器學習與抗量子密碼學。
- 架構與治理：檢視支持代理型 AI 安全部署與運算控制的架構與治理。
- 基準測試與評估：針對自主體 AI 安全進行基準測試、評估流程與測試環境的分析，並指出尚存的缺口。
- 實作：三個將代理式 AI 整合至網路安全工作流程的原始實作，並強調實務經驗。

2 相關研究

最近的調查從多個角度檢視了大型語言模型（LLM）與基於代理系統的安全風險。本節聚焦於先前的調查與分類法，並強調與我們工作的關聯。

第一類工作採用以模型為中心的視角。Wan 等人調查了 LLM 安全在整個模型生命週期中的情況，包括數據收集、對齊、部署和紅隊測試 [163]。儘管全面，但這種方法將手稿提交給 ACM

Table 1. Comparison of Related Surveys on Agentic AI and LLM-Agent Security

Work / Domain	Primary Focus	Relation to This Survey
Adabara et al. (2025) [4]	Agentic AI in cybersecurity (autonomy, governance, quantum-resilient defense)	Closest prior cyber-focused survey; does not analyze planning loops, tool use, memory systems, agent architectures, multi-agent orchestration, or system-level risks.
Wang et al. (2025) [163]	LLM safety across the full model lifecycle	Model-centric lifecycle lens; complements our work but is not organized around agent workflows and agentic cyber deployments.
Deng et al. (2024) [37]	Security challenges for AI agents (broad, cross-domain)	Strong threat-surface survey, but not centered on cybersecurity workflows (SOC/IR/offense) and not structured around end-to-end cyber tasks and implementations.
Gan et al. (2024) [49]	Security, privacy, and ethics threats in LLM-based agents	Useful threat taxonomy; broader than cybersecurity practice and does not foreground cyber offensive/defensive workflows and prototypes.
He et al. (2025) [59]	Security and privacy issues in LLM agents (with case studies)	Agent-security focus; not organized around agentic AI across cybersecurity workflows and system-level risks.
Yu et al. (2025) [171]	Threats and countermeasures for trustworthy LLM agents	Strong threats/defenses taxonomy, but not scoped to cyber operations and does not treat cyber workflows as the main organizing unit.
Ma et al. (2025) [99]	Safety of large models and model-powered agents	Broad AI safety background; not cybersecurity-specific and not organized around cyber use cases and deployments.
Datta et al. (2025) [36]	Agentic AI security: threats, defenses, evaluation, open challenges	Closest agentic-security survey; our survey differs by centering cybersecurity workflows, system-level risks in cyber operations, and implementation prototypes.
Grimes et al. (2025) [54]	SOK bridging research and practice in LLM agent security	Practice-oriented synthesis; complements our workflow framing but is not an end-to-end survey of agentic AI in cybersecurity across defense, offense, and enterprise deployments.
Kong et al. (2025) [82]	Agent communication protocols, security risks, countermeasures	Important for multi-agent communication risk; narrower than our system-level view across planning, tools, memory, and multi-agent interaction in cyber workflows.
Xu et al. (2025) [167]	LLM-based agents in autonomous cyberattacks	Directly relevant offensive survey; narrower than our balanced treatment (defense + offense + enterprise + systemic risk + implementations).
Raza et al. (2025a) [130]	Governance and risk taxonomy for agentic multi-agent systems	Strong governance and risk-management framing; not cybersecurity-specific. We map risks and mitigations onto concrete cyber workflows and use cases.
Raza et al. (2025b) [129]	Responsible agentic reasoning with in-loop safeguards (R2A2)	Reasoning/auditability focus; not cybersecurity-centered. We focus on adversarial cyber deployments and system-level risks.
Shahriar et al. (2025) [139]	Agentic security: applications, threats, defenses	Security-focused and adjacent; our survey differs by centering SOC/IR/offense workflows and by adding system-level risk analysis with practical implementations.
Anonymous (2025) [9]	Safety of LLM-based agents	Broad agent safety coverage; complements our cybersecurity-specific framing and system-level risk discussion.

agent behavior as a secondary concern. Agent-related risks are discussed, but they are not organized around agent-specific workflows such as planning, tool invocation, memory management, or multi-agent coordination, which are central to autonomous cybersecurity operations.

A second class of surveys focuses on LLM-based agent threats and defenses. Gan et al. survey security, privacy, and ethics threats in LLM-based agents [49]. He et al. survey security and privacy issues in LLM agents with case studies [59]. Yu et al. survey threats and countermeasures for trustworthy LLM agents [171]. These works provide useful taxonomies, but are not centered on cybersecurity operations and do not organize analysis around defensive, offensive, and enterprise workflows. Other surveys examine narrower slices of the agent stack. Kong et al. focus on agent communication protocols, their security risks, and countermeasures [82]. Xu et al. focus on LLM-based agents in autonomous cyberattacks and summarize offensive capabilities and defenses [167]. These surveys offer valuable coverage of agent-level threat models and defenses; however, are largely domain-agnostic and do not frame their analysis around security operations, such as defensive monitoring, adversarial interaction, or enterprise security workflows.

A third class of surveys approaches agent security from broader safety and governance perspectives. Ma et al. provide a comprehensive survey of large-model safety that also covers model-powered agents [99]. Datta et al. survey agentic AI security with emphasis on threats, defenses, and evaluation [36]. Grimes et al. provide an SOK bridging research

表 1。關於代理式 AI 與 LLM 代理安全性的相關調查比較

工作 / 領域	主要焦點	與本問卷之關係
Adabara 等人 (2025) [4]	AI 代理在網路安全中的應用（自主性、治理、抗量子防禦）	最接近的以網路安全為焦點的調查；未分析規劃迴路、工具使用、記憶系統、代理架構、多代理協作或系統層級風險。
Wang 等人 (2025) [163]	LLM 全模型生命週期的安全性	以模型為核心的生命週期視角；補充我們的工作，但尚未組織化關於代理工作流與代理式網路部署。
Deng 等人 (2024) [37]	AI 代理的安全挑戰（廣泛，跨領域）	強迫性的威脅面調查，但未聚焦於網路安全工作流程（SOC/IR/攻擊），也未圍繞端到端的網路任務與實施進行組織。
Gan 等人 (2024) [49]	基於大型語言模型的代理中的安全、隱私與倫理威脅	有用的威脅分類法；比網路安全實務更廣泛，且未前景中的網路攻擊/防禦工作流與原型。
He 等 (2025) [59]	大型語言模型代理中的安全與隱私問題（含案例研究）	以代理安全為重點；並非圍繞著在網路安全工作流程與系統層級風險中的代理型 AI 進行組織。
Yu 等人 (2025) [171]	可信大語言模型代理的威脅與對策	強烈的威脅/防禦分類法，但並未涵蓋網路行動與不將網路工作流視為主要的組織單位。
Ma 等人 (2025) [99]	大型模型與模型驅動代理的安全性	廣義的 AI 安全背景；非專門針對網路安全，且未組織化圍繞網路使用案例與部署。
Datta 等人 (2025) [36]	代理式 AI 安全：威脅、防禦、評估，開放挑戰	最接近的代理安全調查；我們的調查以中心於網路安全工作流程、網路運作的系統層級風險以及實施原型為特色。
Grimes 等人 (2025) [54]	SOK 架橋研究與實務於 LLM 代理安全	以實踐為導向的綜合；補充了我們的工作流程框架，但並非涵蓋防禦、攻擊及企業部署中代理式人工智慧的全方位調查。
Kong 等人 (2025) [82]	代理通訊協定，安全性風險，對策	對多代理溝通風險至關重要；其範圍窄於我們涵蓋規劃、工具、記憶及網路工作流中多代理互動的系統層面視角。
Xu 等人 (2025) [167]	基於大語言模型的自主代理網路攻擊	直接相關的攻擊性調查；比我們平衡的處理（防禦 +攻擊 + 企業 + 系統性風險 +實施）更窄。
Raza 等人 (2025a) [130]	代理治理與風險分類法則多智能體系統	堅實的治理與風險管理架構；非專為網路安全設計。我們將風險與緩解措施映射至具體的網路工作流程與使用案例。
Raza 等人 (2025b) [129]	負責代理推理與循環內保障（R2A2）	推理與可審計性為重點；非以網路安全為中心。我們專注於敵對式網路部署與系統層級風險。
Shahriar 等人 (2025) [139]	代理安全：應用程式、威脅、防禦	以安全為核心且具相關性；我們的調查與眾不同，著重於 SOC/IR/攻擊工作流，並加入系統層級風險分析與實際應用。
匿名 (2025) [9]	基於大型語言模型的代理安全性	廣泛的代理安全覆蓋範圍；補充我們針對網路安全的特定框架與系統層級風險討論。

代理行為僅為次要考量。文中雖討論了與代理相關的風險，但並未圍繞規劃、工具調用、記憶管理或多代理協作等核心於自主網路安全運作的代理特定工作流進行組織。

第二類調查專注於基於大語言模型的代理威脅與防禦。Gan 等人調查了基於大語言模型的代理在安全、隱私和倫理方面的威脅 [49]。He 等人通過案例研究調查了大語言模型代理中的安全與隱私問題 [59]。Yu 等人調查了可信大語言模型代理的威脅與對策 [171]。這些研究提供了有用的分類法，但並未以網絡安全運營為中心，也未圍繞防禦、攻擊及企業工作流來組織分析。其他調查則探討了代理堆疊的 narrower 切片。Kong 等人專注於代理通信協議、其安全風險及對策 [82]。Xu 等人專注於基於大語言模型的代理在自主網絡攻擊中的應用，並總結了攻擊能力與防禦措施 [167]。這些調查提供了關於代理級別威脅模型與防禦的寶貴覆蓋範圍；然而，它們大多缺乏領域特定性，且未將分析框架建立在安全運營之上，例如防禦監控、對抗性互動或企業安全工作流。

第三類調查從更廣泛的安全與治理角度切入代理安全。Ma 等人提供了一份關於大型模型安全的綜合調查，涵蓋了由模型驅動的代理 [99]。Datta 等人調查了代理式 AI 的安全問題，重點在於威脅、防禦與評估 [36]。Grimes 等人提供了一份研究概覽，旨在橋接研究

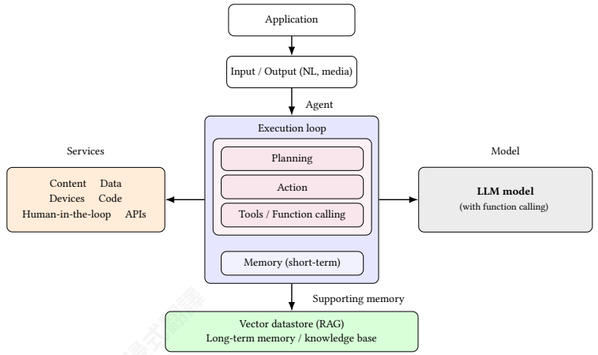

Fig. 1. Single-agent architecture: the agent processes user input through an internal execution loop (planning, action, tool calling), supported by short-term memory, external services/APIs, an LLM model with function calling, and a long-term vector datastore.

and practice in LLM agent security [54]. Raza et al. introduce a TRiSM-based framing for trust, risk, and security management in agentic multi-agent systems [130] and survey responsible agentic reasoning with in-loop safeguards and evaluation protocols [129]. These works strengthen governance and evaluation perspectives but are not focused on cybersecurity workflows and do not provide an end-to-end cyber-centered synthesis. Within cybersecurity-specific reviews, Adabara et al. provide a narrative review of agentic AI in cybersecurity across autonomy and governance [4], and Landolt et al. survey multi-agent reinforcement learning in cybersecurity [91]. These are closest in domain but do not analyze the full agentic stack of planning loops, tool use, memory systems, and multi-agent orchestration in LLM-based deployments. In contrast, our survey treats agentic AI as a cybersecurity system that reasons, plans, uses memory, and calls tools across extended tasks.We apply a consistent agentic risk lens across defensive, offensive, and enterprise workflows. We also analyze system-level risks such as collusion, cascade failures, and oversight evasion. Additionally, we prototyped several minimal implementations to illustrate the feasibility of agentic AI in cybersecurity.

3 What is Agentic AI?

Agentic AI represents the next stage of artificial intelligence, extending GenAI with planning, action, memory, and adaptation. While GenAI produces fluent answers, it does not maintain goals or reason across long tasks; agentic AI introduces structured reasoning and tool use that enable multi-step workflows with limited human guidance. We adopt the following definitions, reflecting both practical and academic perspectives:

"*Agentic AI uses sophisticated reasoning and iterative planning to autonomously solve complex, multi-step problems.*" [125]
"A system based on a foundation model that performs tasks based on natural user instructions, with the ability to reason, plan, and interact with tools and environments to achieve goals." [136]

Agentic systems are built around a foundation model that provides core reasoning, augmented by memory, retrieval, and tool interfaces. These components operate in a continuous loop of planning, acting, reflecting, and improving, distinguishing agentic systems from static GenAI producing single response per prompt. Their architecture includes:

- **Memory modules** for short-term, episodic, and long-term state.
- **Retrieval systems** such as vector databases and RAG.
- **Tools and APIs** for computation, browsing, or code execution.

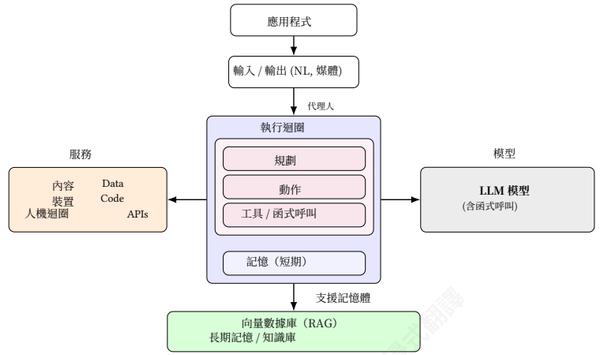

圖 1。單一代理架構：代理透過內部執行循環（規劃、行動、工具呼叫）處理使用者輸入，並由短期記憶、外部服務/API、具備工具呼叫功能的 LLM 模型以及長期向量數據庫支援。

並在 LLM 代理安全領域進行實踐 [54]。Raza 等人提出了一種基於 TRiSM 的信任、風險與安全管理框架，適用於代理多智能體系統 [130] ，並回顧了帶有循環內防護機制與評估協議的負責任代理推理 [129]。這些研究強化了治理與評估視角，但並未聚焦於網路安全工作流程，也未提供端到端的以網路安全為核心的綜合分析。在專門針對網路安全的文獻回顧中，Adabara 等人提供了關於網路安全領域代理 AI 的敘述性回顧，涵蓋自主性與治理 [4]，；Landolt 等人則回顧了網路安全領域的多智能體強化學習 [91]。這些工作在領域上最為接近，但並未分析基於 LLM 部署中的完整代理堆疊，包括規劃循環、工具使用、記憶系統與多智能體協同。相反，我們的文獻回顧將代理 AI 視為一種能夠進行推理、規劃、調用記憶並跨長任務使用工具的網路安全系統。我們將一致的代理風險視角應用於防禦、攻擊與企業工作流程中。此外，我們還分析了系統層面的風險，例如串謀、連鎖失效與監管規避。另外，我們原型開發了若干簡易實現，以說明代理 AI 在網路安全領域的可行性。

3 什麼是代理式 AI？

代理式 AI 代表人工智慧的下一個階段，透過規劃、行動、記憶與適應，擴展了生成式 AI 的能力。雖然生成式 AI 能產出流暢的答覆，卻無法在長程任務中維持目標或進行推理；代理式 AI 則引入結構化的推理與工具使用，使能在有限的人類指導下，執行多步驟的工作流程。我們採用以下定義，以反映實務與學術雙重視角：

「代理式 *AI* 運用高度進階的推理與迭代規劃，自主解決複雜的多步驟問題。」 [125]「基於基礎模型的系統，能根據自然語言用戶指令執行任務，具備推理、規劃及與工具和環境互動以達成目標的能力。」 [136]

代理系統是建立在基礎模型之上，該模型提供核心推理能力，並透過記憶、檢索與工具介面進行增強。這些組件在規劃、執行、反思與改進的持續循環中運作，使代理系統與產生單一回應的靜態生成式 AI 有所區別。其架構包含：

- 短期、事件性與長期狀態的記憶體模組。
- 向量數據庫和 RAG 等檢索系統。
- 用於計算、瀏覽或程式碼執行的工具與 API。

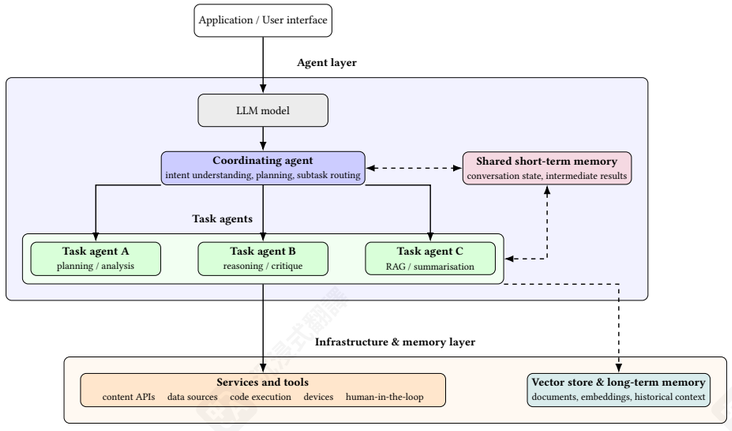

Fig. 2. Multi-agent architecture: application layer, agent layer (coordinator plus task agents sharing short-term memory), and infrastructure/memory layer with tools and long-term storage.

- **Connections to external environments** for interaction with software and online systems.

Figure 1 illustrates a canonical single-agent architecture in which user input is processed through an internal execution loop comprising planning, action, and tool or function calling. Short-term memory supports contextual continuity, while external services, an LLM model, and long-term vector storage enable structured reasoning and tool use across multi-step tasks. Figure 2 extends this design to a multi-agent setting, where a coordinating agent routes subtasks to specialized task agents that share short-term memory and infrastructure services. This separation of responsibilities enables parallel reasoning, structured collaboration, and scalable problem solving.

Agentic AI systems combine several capabilities that go beyond GenAI. The core characteristics are:

- **Reasoning:** Decomposing problems, evaluating progress, and adjusting plans using structured prompting such as Chain-of-Thought and Reflection [142].
- **Interaction:** Call tools, query data sources, executing code, and collaborating with humans in real environments.
- **Autonomy:** Acting toward goals with limited supervision and initiating actions as conditions change.
- **Adaptability:** Updating behavior with memory, feedback, and reinforcement signals to improve future actions.

Together, these characteristics support goal-directed behavior across extended time scales. Agentic systems vary in their degree of independence. Table 2, adapted from academic and industry sources [2, 58], summarizes five autonomy levels. Level 0 corresponds to fixed GenAI behavior, while Level 4 enables continuous planning and self-directed learning. Higher autonomy improves capability but increases complexity and security risk, as behavior becomes harder to predict and audit; multi-agent systems typically exhibit higher autonomy than single-agent systems.

Agentic AI is powerful but not universally reliable, particularly in areas such as social reasoning. Designing safe agents is more challenging than prompt engineering, and increasing autonomy raises responsibility and risk. In cybersecurity, agentic AI can enhance defense through continuous monitoring and proactive action but also introduces challenges related to safety, oversight, and trust, making careful design and testing essential.

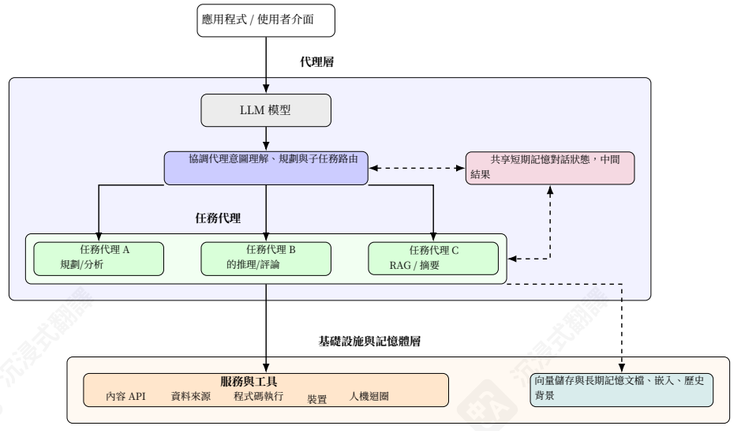

圖 2。多代理架構：應用層、代理層（協調器與共享短期記憶的任務代理），以及包含工具與長期存儲的基础設施/存儲層。

- 與外部環境建立連接，以與軟體及線上系統進行互動。

圖 1 說明了一種標準的單一代理架構，其中使用者輸入透過包含規劃、行動以及工具或函式呼叫的內部執行迴路進行處理。短期記憶支援情境連續性，而外部服務、大型語言模型（LLM）以及長期向量儲存則使跨多步驟任務的結構化推理與工具使用成為可能。圖 2 將此設計擴展至多代理環境，其中協調代理將子任務分發給專責的任務代理，這些代理共享短期記憶與基礎設施服務。這種責任分離使得並行推理、結構化協作以及可擴展的問題解決成為可能。

代理式 AI 系統結合了超越生成式 AI 的多項能力。其核心特徵如下：

- 推理：使用結構化提示（如 Chain-of-Thought 和 Reflection [142]）來分解問題、評估進度並調整計劃 [142]。
- 互動：呼叫工具、查詢資料來源、執行程式碼，並在真實環境中與人類協作。
- 自主性：在有限監督下朝向目標行動，並根據條件變化主動發起行動。
- 適應性：透過記憶、反饋與強化訊號更新行為，以提升未來行動。

這些特性共同支持跨長時間尺度的目標導向行為。代理系統在獨立程度上存在差異。表 2 根據學術與產業來源 [2, 58]，改編，總結了五個自主等級。等級 0 對應固定的生成式 AI 行為，而等級 4 則支援持續規劃與自我導向學習。較高的自主性雖能提升能力，但也會增加複雜度與安全風險，因為行為變得難以預測與審計；多代理系統通常比單代理系統具有較高的自主性。

代理式 AI 雖具強大能力，但並非普遍可靠，尤其在社會推理等領域。設計安全代理比提示工程更具挑戰性，而提升自主性則會增加責任與風險。在網路安全領域，代理式 AI 可透過持續監控與主動行動強化防禦，但也引入安全、監管與信任等挑戰，因此謹慎設計與測試至關重要。

Table 2. Autonomy Spectrum of AI Systems (adapted from [2, 58])

Level	Autonomy Description	Functional Capability	Security Implications
0 – Static Inference	Single request–response; no autonomy.	Fixed outputs for fixed inputs.	Minimal risk; deterministic.
1 – Assistive	Follows explicit user instructions.	Single-step reasoning (e.g., GenAI).	Low risk; narrow behavior.
2 – Tool-Assisted	Uses tools or APIs with preset logic.	Multi-step workflows (e.g., RAG).	Moderate risk; data-dependent paths.
3 – Adaptive/Semi-Agentic	Plans, acts, and reflects with little oversight.	Goal-driven task execution.	High risk; partial self-direction.
4 – Fully Agentic	Plans, acts, and learns continuously.	Open-ended problem-solving.	Very high risk; hard to audit.

4 Applications of Agentic AI to Cybersecurity

Agentic AI supports cybersecurity across the typical cybersecurity incident lifecycle through reasoning, interaction, autonomy, and adaptation. The Cybersecurity Compass framework organizes this lifecycle into three phases: preparation and risk management before an incident, detection and containment during an incident, and recovery and resilience after an incident [25]. Agentic capabilities align naturally with each phase: continuous monitoring and vulnerability management strengthen pre-incident preparedness; SOC agents and automated response mechanisms enhance detection and containment; and post-incident analytics, root-cause analysis, and adaptive retraining support recovery and long-term resilience. Oesch et al. map autonomous agents to the six NIST Cyber Defense Life Cycle functions: Govern, Identify, Protect, Detect, Respond, and Recover [114]. They argue for a modular multi-agent design in which each agent focuses on a single stage or narrow sub-function. This reduces the action space, simplifies training, and aligns with SOC practice rather than relying on a single agent for end-to-end control. Recent work extends this into complete agentic workflows that connect orchestration, adaptive playbooks, and layered safeguards across the breach lifecycle [151].

To combine these perspectives, we group security application use cases into four domains: *Autonomous Cyber Defense and Operation*, *Agentic Threat Intelligence and Adversarial Analysis*, *Enterprise Security Automation and Governance*, and *Simulation, Training, and Testing*. Each domain contains subfunctions that map to breach phases and NIST Cyber Defense functions. Figure 3 summarizes these domains and their subcomponents, showing how operational workflows intersect with intelligence, governance, and continuous training. Table 3 complements this view by mapping each use case to its dominant breach stage and primary NIST Cyber Defense functions, and by summarizing limitations and open research problems reported in the literature. We use this synthesis as a reference point for the discussion that follows.

4.1 Autonomous Cyber Defense and Operation

Agentic AI is reshaping cyber defense by adding autonomy, reasoning, and continuous adaptation to monitoring, detection, and response workflows [15, 25, 165]. Systems, such as Microsoft Security Copilot, Exabeam Copilot, and Cymulate AI Copilot, support phishing triage, threat intelligence analysis, and incident response [165]. By extending static automation with memory and goal-directed planning, agents can correlate signals, anticipate attacker behavior, and initiate containment in near real time.

4.1.1 Autonomous Monitoring and Detection. Autonomous monitoring combines traditional detection with agentic orchestration to adapt how monitoring is performed as conditions change. Classical monitoring is largely passive, in that it evaluates alerts against fixed thresholds and predefined rules on predefined data streams. In contrast, agentic monitoring is described as more active, using memory and planning to retain context across events, expand monitoring to related entities such as users, hosts, processes, or network flows, and trigger additional investigative actions such as log retrieval or cross-system correlation when initial detections warrant deeper inspection [15, 24, 141]. This shift enables monitoring workflows to move beyond static evaluation, but also introduces new design considerations. Classical monitoring relies on static rules, which struggle under dynamic workloads and evolving attack patterns.

表 2。AI 系統的自主性譜系（改編自 [2, 58]）

等級	自主性說明	功能能力	安全影響
0 – 靜態推斷	單一請求 - 回應；無自主性。	固定輸入對應固定輸出。	極低風險；確定性。
1 – 輔助	遵循明確的用戶指示。	單一步驟推理（例如，生成式 AI）。	風險低；行為狹窄。
2 – 工具輔助	使用具有預設邏輯的工具或 API。	多步驟工作流（例如 RAG）。	中等風險；取決於資料的路徑。
3 – 適應性/半自主智能	計畫、行動與反思，且缺乏監督。	以目標為導致的任務執行。	高風險；部分自主。
4 – 完全自主智能體	持續規劃、執行與學習。	開放式問題解決。	極高風險；難以稽核。

4 代理式 AI 在網路安全中的應用

代理式 AI 透過推理、互動、自主性與適應性，支援典型網路安全事件生命週期的各個階段。Cybersecurity Compass 框架將此生命週期分為三個階段：事件發生前的準備與風險管理、事件發生時的偵測與封鎖，以及事件發生後的復原與韌性 [25]。代理式能力與各階段自然契合：持續監控與漏洞管理強化事前準備；SOC 代理與自動化回應機制提升偵測與封鎖能力；而事後分析、根本原因分析及適應性再訓練則支援復原與長期韌性。Oesch 等人將自主代理映射至 NIST 網路防禦生命週期的六項功能：治理、識別、防護、偵測、回應與復原 [114]。他們主張採用模組化多代理設計，每個代理專注於單一階段或狹窄的子功能。這能縮小行動空間、簡化訓練，並符合 SOC 實務，而非依賴單一代理進行端到端控制。近期研究已將此擴展為完整的代理式工作流，連結編排、適應性操作程序與跨事件生命週期的多層防護 [151]。

為整合這些觀點，我們將網路安全應用場景分為四個領域：自主網路防禦與營運、代理式威脅情報與敵對分析、企業安全自動化與治理，以及模擬、訓練與測試。每個領域包含對應於洩漏階段與 NIST 網路防禦功能的子功能。圖 3 總結了這些領域及其子組件，並顯示營運工作流如何與情報、治理及持續訓練相互交錯。表 3 補充了此視角，將每個應用場景映射至其主導的洩漏階段及主要 NIST 網路防禦功能，並總結文獻中報告的限制與開放研究問題。我們以此綜合分析作為後續討論的參考點。

4.1 自主網絡防禦與營運

代理式 AI 透過在監控、偵測與回應工作流中加入自主性、推理與持續適應能力，正在重塑網路防禦 [15, 25, 165]。例如 Microsoft Security Copilot、Exabeam Copilot 與 Cymulate AI Copilot 等系統，支援釣魚郵件分級處理、威脅情報分析與事件回應 [165]。透過將靜態自動化擴展為具備記憶與目標導向規劃，代理能關聯訊號、預測攻擊者行為，並在近乎實時的情況下啟動封鎖措施。

4.1.1 自主監控與偵測。自主監控結合傳統偵測與代理編排，使監控方式能隨環境變化而適配。傳統監控大多被動，其會將警報與固定閾值及預設規則，針對預設資料流進行評估。相對而言，代理式監控則被描述為更具主動性，透過記憶與規劃保留事件間的上下文，將監控範圍擴展至相關實體（如使用者、主機、進程或網路流量），並在初步偵測需要深入檢視時，觸發額外的調查行動（如日誌檢索或跨系統關聯）[15, 24, 141]。此轉變使監控工作流能超越靜態評估，但也帶來新的設計考量。傳統監控依賴靜態規則，在動態負載與演變中的攻擊模式面前往往難以應對。

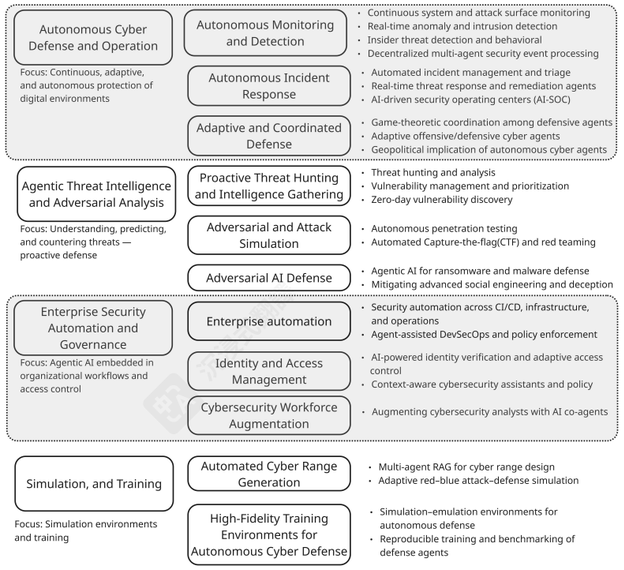

Fig. 3. Overview of applications of agentic AI to cybersecurity. Figure maps core research and operational domains, such as autonomous defense, threat intelligence, enterprise automation, and simulation and training, together with representative subcomponents.

In anomaly detection, Argos uses LLMs to generate human readable rules for time series data, improving auditability but limit autonomous action beyond detection and explanation [55]. Similar design appears in infrastructure and critical system monitoring. IDS agents for IoT networks and LLM based anomaly detection for EV charging systems incorporate contextual reasoning and heterogeneous signals into detection, but are typically evaluated under fixed operational assumptions [64, 94]. Multi-agent reinforcement learning has also been proposed to model attacker and defender dynamics under changing conditions, but it increases computational cost and reduces transparency for operators [91].

Agentic monitoring also affects how observability, insider threat detection, and SOC operations are executed. Conventional observability tools and SIEM platforms already correlate logs, metrics, and alerts. The distinction emphasized in agentic designs is not the existence of these capabilities, but the use of autonomous agents to iteratively investigate alerts across tools, retain intermediate context, and coordinate analysis steps beyond fixed playbooks [13, 104, 145]. Correlating login behavior, process execution, and data movement can help separate benign anomalies from malicious activity, but policy analyses and industry reports warn that misaligned or deceptive agents may themselves behave as high-privilege insiders [10, 14, 42, 71, 79, 135, 159, 160]. In SOC workflows, agentic systems support SIEM correlation and alert triage by linking related events and ranking risk, while decentralized agent designs trade interpretability for parallelism and scalability [24, 153, 158]. In these systems, improved detection accuracy does not guarantee safe autonomy, and human oversight remains necessary for high-impact decisions [15]. An open problem is how to combine adaptive detection with formal safety constraints so agents can act without exceeding acceptable operational risk.

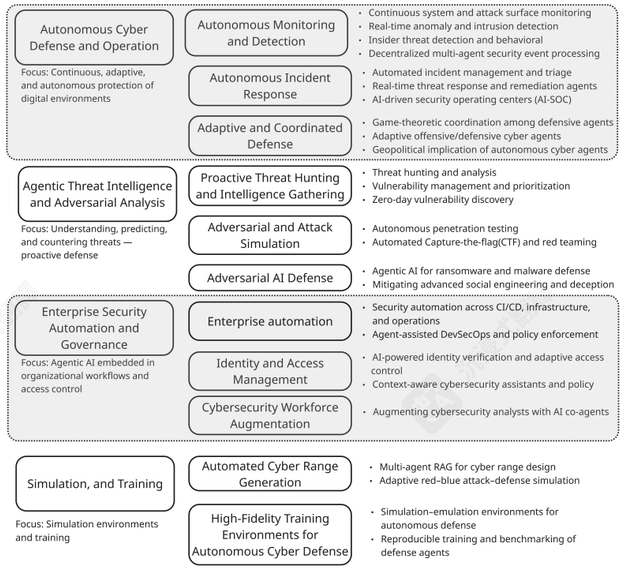

圖 3。代理式 AI 在網路安全中的應用概覽。此圖表將核心研究與營運領域（如自主防禦、威脅情報、企業自動化，以及模擬與訓練）及其代表性子組件一併呈現。

在異常檢測中，Argos 利用大型語言模型（LLM）為時間序列數據生成人類可讀的規則，提升了可審計性，但也限制了檢測與解釋之外的自主行動 [55]。類似設計也出現在基礎設施與關鍵系統監控中。用於物聯網網絡的入侵檢測系統代理以及基於大型語言模型的電動車充電系統異常檢測，將情境推理與異質信號納入檢測，但通常是在固定的運行假設下進行評估 [64, 94]。此外，也有人提出使用多智能體強化學習來模擬在變異條件下攻擊者與防禦者的動態，但這會增加計算成本，並降低對操作人員的透明度 [91]。

代理式監控也影響可觀測性、內部威脅偵測與 SOC 運作的執行方式。傳統的可觀測性工具與 SIEM 平台已能關聯日誌、指標與警報。代理式設計所強調的區別，並非這些能力的存在，而是利用自主代理跨工具迭代調查警報、保留中間上下文，並協調超出既定劇本的分析步驟 [13, 104, 145]。關聯登入行為、程式執行與資料移動有助於區分良性異常與惡意活動，但政策分析與產業報告警告，對齊不當或具有欺騙性的代理本身可能表現為高權限內部人員 [10, 14, 42, 71, 79, 135, 159, 160]。在 SOC 工作流程中，代理式系統透過關聯相關事件並排序風險，支援 SIEM 關聯與警報分級；而分散式代理設計則以可解釋性換取並行處理與可擴展性 [24, 153, 158]。在這些系統中，檢測精度的提升並不保證安全自主，人類監督對於高影響力決策仍屬必要 [15]。一個未解的問題是：如何將適應性檢測與形式化安全約束結合，使代理能在不超過可接受營運風險的前提下行動。

Table 3. Applied agentic AI cybersecurity use cases and their alignment with breach lifecycle stages, NIST Cyber Defense functions, key limitations, and open research problems. Lifecycle stage is categorized as Pre, During, or Post breach. NIST functions are abbreviated as Govern (G), Identify (I), Protect (P), Detect (D), Respond (R), and Recover (Rc).

Use Case	Stage	NIST	Key limitation	Open problem
Autonomous Monitoring and Detection	Pre	G I P	Narrow task optimization with weak safety constraints under drift and false positives	Bind adaptive detection to enforceable action governance with bounded impact
Autonomous Incident Response	During	D R	No formal safety guarantees under distribution shift or adversarial manipulation	Define safe execution boundaries that prevent cascading or irreversible failures
Adaptive and Coordinated Defense	During	D R	Limited mechanisms to prevent escalation when agents co adapt in multi agent loops	Preserve coordination while enforcing stability and escalation bounds
Proactive Threat Hunting and Intelligence Gathering	Pre	I D	Dependence on curated inputs and sparse signals limits open world generalization	Support robust hunting under evolving data and incomplete observability
Adversarial and Attack Simulation	During	D R	Higher autonomy increases dual use risk while constraints reduce realism and transfer	Link safe simulation outcomes to deployment relevant defensive design
Adversarial AI Defense	Post	D R	Systems optimize either workflow coverage or robust decision quality but rarely both	Combine coordinated response with interpretable and reliable decisions
Defensive Applications in Financial Services	Post	R Rc	Regulatory constraints limit autonomy and restrict realistic evaluation	Validate adaptive agents under real compliance controls and audit requirements
Enterprise Automation	Post	P R Rc	Capabilities remain fragmented across pipelines, devices, and telemetry layers	Coordinate cross layer actions without expanding authority beyond governance
Identity and Access Management	Post	P R	Predefined policies limit contextual depth and reduce generalization across roles	Unify rich context modeling with auditable access control at scale
Cybersecurity Workforce Augmentation	Post	R Rc	Weak performance on novel cases without strong supervision and verification	Measure long term effects on skill, trust calibration, and accountability
Automated Cyber Range Generation	Pre	I P	Validation focuses on deployment correctness, not scenario fidelity or learning value	Assess whether generated ranges match evolving threats and objectives
Cyberwheel High Fidelity Training	Pre	I P	Dependence on fixed detector models and reward assumptions limits robustness	Test policies under shifted telemetry, detector gaps, and new adversary behavior

4.1.2 Autonomous Incident Response. Agentic AI extends cybersecurity beyond passive monitoring by embedding goal directed response into detection pipelines. In modern SOCs, agents observe traffic, detect anomalies, and initiate containment or remediation with minimal latency, which reduces reliance on manual intervention [165]. Most deployments use multi-agent designs that split incident response into specialized roles such as intelligence synthesis, investigation, decision support, and orchestration, with monitoring and detection treated as upstream inputs rather than primary agent responsibilities, which is reported to improve scalability and responsiveness once an incident is identified [39, 74, 133, 165]. Conceptual models such as Tallam's Adaptive Engagement Model formalize this approach by treating incident response as a closed loop process that integrates sensing, contextual reasoning, adaptive action, and learning [155]. Related work on autonomous cyber defense in coalition environments discusses how hierarchical multi-agent architectures coordinate response, mitigation, and recovery across organizational boundaries, while explicitly retaining human-on-the-loop escalation for high-impact actions [96].

Empirical and operational studies show that effective deployment depends on bounded autonomy. Knack and Burke find that autonomous defense agents can rapidly detect and contain threats, but irreversible actions require explicit authorization boundaries, shared vocabularies, auditable logs, and clear escalation protocols [80]. Production systems reflect these constraints. CyberGuardian2 supports iterative reasoning and tool use for access control changes, database queries, code execution, and safety checks, but remains a decision support system rather than a fully autonomous actor [120, 170]. IBM's ATOM platform distributes incident response across agents for investigation, threat hunting, identity management, and vulnerability analysis, and integrates vendor tools to resolve many incidents within seconds [25, 69]. Industry forecasts predict broader SOC adoption of agentic AI and report gains in triage speed and accuracy [85, 133, 138]. However, systems that grant broader execution authority raise unresolved questions about authorization boundaries, escalation control, and failure containment [96, 155]. Reasoning driven systems still lack formal

表 3. 已實施的代理式 AI 網路安全使用案例，及其與資料洩漏生命週期階段、NIST 網路防禦功能、關鍵限制與開放研究問題的對齊情況。生命週期階段分類為洩漏前、洩漏中或洩漏後。NIST 功能簡寫為治理（G）、識別（I）、防護（P）、偵測（D）、回應（R）與復原（Rc）。

使用案例	階段	NIST	主要限制	未解決問題
自主監控與偵測	Pre	G I P	在漂移與假陽性下，利用弱安全約束進行窄任務優化	綁定適配檢測至可強制執行的行動治理，並限制影響範圍
自主事件回應	期間	D R	分發時無正式安全保證	定義防止連鎖或不可逆失敗的安全執行邊界
適應性與協調的解離防衛	期間	D R	位移或對抗性操作 防止代理在多方循環中適應時升級的機制有限	在執行穩定性與升級邊界規範的同時，維持協調
主動威脅獵取與情報蒐集	Pre	I D	對精選輸入和稀疏信號的依賴限制了開放世界泛化能力	支援在演變中的數據與不完整可觀測性下進行強大的偵測
對抗與攻擊模擬	期間	D R	更高的自主性增加了雙用風險，而限制則降低現實感與轉移性。	Linksafe 模擬結果至部署相關防禦設計
對抗式 AI 防禦	Post	D R	系統最優化工作流覆蓋率或堅固決策品質，但兩者罕能兼得。	將協調回應與可解釋且可靠的決策結合
防禦應用於 Fi-金融服務	Post	R Rc	法規限制影響自主性與現實主義評估	驗證符合真實合規控制與審計要求的適配代理
企業自動化	Post	P R Rc	能力在各管道、裝置與遙測層之間仍呈現碎片化	跨層級協調行動，而不擴大治理權限
身分與存取管理 - ment	Post	P R	預定義策略限制上下文深度，並減少角色間的泛化	整合豐富的情境建模與可審計的存取大規模控制
網路安全人力增補	Post	R Rc	在缺乏強監督與驗證的新案例上表現薄弱	評估長期對技能、信任校準與負責任性的影響
自動化網路模擬場生成	Pre	I P	驗證專注於部署的正確性，而非情境忠實度或學習價值。	評估所生成的範圍是否與演進中的威脅及目標相符
Cyberwheel 高保真訓練	Pre	I P	對固定偵測器模型的依賴與獎勵假設限制魯棒性	測試在移轉的遙測、偵測器缺口以及新式敵對行為下的策略

4.1.2 自主事件回應。代理式 AI 透過將目標導向的回應嵌入偵測流程，將網路安全從被動監控擴展至主動行動。在現代 SOC 中，代理會觀察流量、偵測異常，並以最小延遲啟動封鎖或修復，這降低了對人工介入的依賴 [165]。大多數部署採用多代理設計，將事件回應拆分為專責角色，例如資訊綜合、調查、決策支援與協同 orchestration，並將監控與偵測視為上游輸入而非主要代理職責，據稱這能提升事件識別後的擴展性與回應速度 [39, 74, 133, 165]。概念模型如 Tallam 的適應性參與模型（Adaptive Engagement Model）將此方法形式化，將事件回應視為一個整合感測、情境推理、適應性行動與學習的閉環過程 [155]。關於聯盟環境中自主網路防禦的相關研究探討了層級式多代理架構如何協調跨組織邊界的回應、緩解與復原，並明確保留高衝擊行動的人機協同升級機制 [96]。

實證與操作研究顯示，有效部署取決於有邊界的自主性。Knack 和 Burke 發現，自主防禦代理能快速偵測並限制威脅，但不可逆行動需要明確的授權邊界、共享詞彙、可審計日誌以及清晰的升級協議 [80]。生產系統反映了這些限制。CyberGuardian2 支援用於存取控制變更、資料庫查詢、程式碼執行和安全檢查的迭代推理與工具使用，但仍為決策支援系統，而非完全自主的行動者 [120, 170]。IBM 的 ATOM 平台將事件回應分發給代理進行調查、威脅獵殺、身份管理與漏洞分析，並整合廠商工具，在數秒內解決許多事件 [25, 69]。產業預測顯示，SOC 將更廣泛地採用代理式 AI，並報告在分診速度與準確性上的提升 [85, 133, 138]。然而，授予更廣泛執行權限的系統，仍引發關於授權邊界、升級控制與失敗限制等未解決的問題 [96, 155]。以推理驅動的系統仍缺乏正式

safety guarantees under distribution shift or adversarial manipulation [120, 170], and analyses warn that misaligned agents with broad privileges can amplify damage [85, 116]. Progress therefore remains centered on orchestration and workflow automation rather than unrestricted autonomous authority, and the open problem is how to grant execution power without enabling cascading or irreversible failures.

4.1.3 Adaptive and Coordinated Defense. Adaptive defense frames cyber conflict as repeated attacker defender interaction. Game theoretic models formalize this setting, and agentic AI enables it through LLM based agents that update beliefs and act under uncertainty [185]. Red team agents emulate reconnaissance and exploitation, while blue team agents respond through detection, patching, and policy updates [33]. This feedback loop supports continuous adaptation, but policy analysis shows that misaligned objectives or incomplete incentives can amplify failure modes [15].

Existing work highlights a tradeoff between control and responsiveness. Simulation driven approaches such as Trend Micro's digital twin enable coordinated co evolution of red and blue agents in sandboxed environments, improving defensive learning while limiting real world risk [156]. However, these systems rely on simplified models and often fail to transfer to operational settings. In contrast, analyses of real cyber conflict emphasize live deployment, where autonomous agents adapt at operational speed and can increase escalation risk by compressing decision timelines [15, 116]. Although coordination and repeated interaction improve defensive capability, current systems lack safeguards that bound escalation across interacting agents. An open problem is how to preserve adaptive coordination while enforcing autonomy limits that prevent cascading or destabilizing behavior in open adversarial environments.

4.2 Agentic Threat Intelligence and Adversarial Analysis

Agentic AI extends cybersecurity beyond traditional, alert-driven detection systems toward dynamic threat intelligence, adversarial reasoning, and autonomous defense. Rather than redefining detection itself, agents operate downstream of existing security tools, reasoning over alerts to discover vulnerabilities, simulate attacks, and update countermeasures in near real time by combining continuous learning, contextual awareness, and multi-agent coordination [15, 24, 165].

4.2.1 Proactive Threat Hunting and Intelligence Gathering. Agentic AI supports proactive threat hunting by assisting analysts in hypothesis-driven investigations aimed at uncovering stealthy or emerging adversary activity that may evade existing security controls. Recent works describe agents as supporting analyst-led hunting by correlating weak signals across heterogeneous data sources, retaining investigative context through memory, and updating hypotheses or watchlists over time [24, 84, 145, 153]. This framing distinguishes proactive threat hunting from routine alert-driven workflows by emphasizing contextual investigation and sense-making rather than isolated alert handling.

Across the literature, agentic threat hunting is characterized by its adaptive and iterative nature. Kshetri highlights the role of agentic AI in enabling continuous exploration of attacker tactics and behaviors as threat environments evolve, while industry deployments emphasize support for long-horizon investigations that would be difficult to sustain manually [84, 153]. However, this adaptability introduces tradeoffs. Hypothesis-driven agents often operate on sparse, noisy, or incomplete signals and may struggle to generalize under rapid environmental change. As a result, policy analyses stress that human analysts remain central to revising hypotheses, validating inferred threats, and interpreting ambiguous findings [165]. An open problem is how to design agentic threat hunting systems that preserve analyst-driven flexibility while remaining robust to distribution shift and incomplete information.

4.2.2 Adversarial and Attack Simulation. Adversarial and attack simulation provides controlled environments to evaluate defensive readiness and study autonomous attack behavior. Traditional penetration testing follows defined stages such as reconnaissance, scanning, exploitation, and post exploitation, which support structured assessment but adapt poorly when plans fail or context expands [181]. Recent agentic systems extend this model by adding planning,

在分佈偏移或對抗性操作下的安全保證 [120, 170], 以及分析警告指出，擁有廣泛權限的對齊不良代理可能會放大損害 [85, 116]。因此，進展仍集中在調度與工作流自動化，而非無限制的自主權限，而開放的問題在於如何授予執行權限而不引發連鎖或不可逆的失敗。

4.1.3 適應性與協調防禦。適應性防禦將網路衝突視為重複的攻擊者與防禦者互動。博弈論模型將此設定形式化，而基於大語言模型的代理 AI 則透過更新信念並在不確定性下行動來實現此功能 [185]。紅隊代理模擬偵測與攻陷，而藍隊代理則透過偵測、補丁更新與政策調整進行回應 [33]。此回饋迴路支持持續適應，但政策分析顯示，目標不一致或不完整的激勵機制可能會放大失敗模式 [15]。

現有研究凸顯了控制與響應性之間的權衡。模擬驅動的進路，例如 Trend Micro 的數位孿生，能在隔離環境中促成紅方與藍方代理的協同共演，提升防禦學習能力，同時限制現實世界的風險 [156]。然而，這些系統依賴簡化模型，且常無法轉移至實際運作環境。相反地，對真實網路衝突的分析強調「現場部署」，即自主代理能以實際運作速度進行適應，並透過壓縮決策時程來增加升級風險 [15, 116]。儘管協調與重複互動能提升防禦能力，但現有系統缺乏能限制互動代理間升級的防護機制。一個開放性的問題是：如何在開放的對抗環境中，在維持適應性協調的同時，強制執行自主限制，以防止連鎖反應或不穩定行為。

4.2 智能威脅情報與敵對分析

代理式 AI 將網路安全從傳統的、以警報為驅動的檢測系統，擴展至動態威脅情報、對抗性推理與自主防禦。代理並非重新定義檢測本身，而是在現有安全工具下游運作，透過結合持續學習、情境感知與多代理協作 [15, 24, 165]，對警報進行推理，以發現漏洞、模擬攻擊，並近乎即時地更新對策。4.2.1 主動威脅獵殺與情報蒐集。代理式 AI 支援主動威脅獵殺，協助分析人員進行以假設為導向的調查，以揭露可能繞過現有安全控制的隱蔽或新興的敵對者活動。近期研究將代理描述為支援分析人員主導的獵殺工作，透過關聯異質資料來源中的微弱訊號、利用記憶保留調查情境，並隨時間更新假設或監視清單 [24, 84, 145, 153]。此框架透過強調情境化調查與意義建構，將主動威脅獵殺與例行性的警報驅動工作流程區隔開來。

在文獻中，代理威脅獵探的特徵在於其適應性和迭代性。Kshetri 強調代理 AI 在支援持續探索攻擊者戰術與行為方面的作用，特別是在威脅環境不斷演變的情況下，而產業部署則強調對長期調查的支援，這在人工操作下難以持續 [84, 153]。然而，這種適應性也帶來了權衡。假設驅動的代理通常基於稀疏、雜訊或不完全的信號運作，且在環境快速變化時可能難以泛化。因此，政策分析強調，人類分析員在修正假設、驗證推斷出的威脅以及解釋模糊結果方面仍居核心地位 [165]。一個開放性的問題是：如何設計代理威脅獵探系統，使其在保留分析員主導的靈活性同時，仍能對分佈偏移和資訊不完整具有魯棒性。

4.2.2 對抗與攻擊模擬。對抗與攻擊模擬提供受控環境，用以評估防禦準備度並研究自主攻擊行為。傳統滲透測試遵循定義好的階段，例如偵測、掃描、利用與後利用，這些支持結構化評估，但在計畫失敗或情境擴展時 [181] 適應性不佳。近期的代理系統透過加入規劃功能，擴展了此模型。

memory, and automated execution. RedTeamLLM illustrates this shift by combining recursive planning, plan correction, and memory with explicit security controls including isolation, command filtering, audit logs, and a kill switch [27]. Compared with earlier tools such as PenTestGPT, this design improves task completion on VulnHub targets, indicating that reasoning and memory reduce brittleness in multi step attacks [27]. Commercial platforms such as XBOW and RunSybile push autonomy further and report high exploitation rates and discovery of new vulnerabilities, but they offer limited transparency into agent reasoning and safety constraints [116]. This contrast highlights a tradeoff between effectiveness and controllability. Systems that prioritize autonomous exploration uncover more attack paths, while systems that emphasize structure and containment limit misuse but constrain discovery.

Capture the flag (CTF) platforms occupy a different point in this design space. Frameworks such as OWASP FinBot CTF and the CSAW Agentic Automated CTF use multi agent roles for reconnaissance, exploitation, and escalation within tightly bounded environments [34, 119]. Trustwise applies similar simulation methods in legal technology, showing that constrained agentic evaluation can transfer beyond classical security domains [157]. They support reproducibility, safety, and benchmarking of coordination and alignment, but they simplify targets and restrict agent actions. As a result, they may not expose agents to the full range of system interactions and failure modes encountered in deployment. Across current approaches, higher autonomy increases dual use risk, while stronger constraints reduce realism [116]. An open problem is how to link results from controlled adversarial simulations to real world defensive design without enabling uncontrolled offensive capability or overstating the robustness of agentic systems trained in simplified environments.

4.2.3 Adversarial AI Defense. Adversarial AI defense refers to the use of AI systems to counter adaptive and strategically evolving attackers by coordinating detection, investigation, decision-making, and response activities across a defense workflow. Recent work shows a shift from isolated detection models toward coordinated agent based defense systems. Platforms such as Red Canary emphasize end to end orchestration, where agents detect suspicious behavior, investigate alerts, contain endpoints, hunt for indicators, remediate systems, and generate reports within a single workflow [131]. This approach prioritizes speed and coverage by coordinating planning, memory, and tool use across tasks. In contrast, research systems for phishing defense emphasize decision quality within a narrow scope. MultiPhishGuard distributes email analysis across specialized agents and uses reinforcement learning to adapt their influence, improving robustness against evolving phishing patterns [168]. Debate based systems such as PhishDebate and related multi agent argumentation frameworks emphasize interpretability by requiring agents to justify and challenge conclusions before classification [93, 162]. These systems reduce confirmation bias and improve recall, but they remain limited to the classification stage and do not address broader incident response.

This comparison reveals a tradeoff between scope and assurance. Workflow oriented platforms favor rapid response and operational scale, but depend on predefined playbooks and human oversight for irreversible actions [131]. Debate driven detectors favor accuracy, robustness, and explanation, but do not naturally extend to remediation or cross domain defense [93, 162, 168]. One limitation is the lack of guarantees under adaptive adversarial pressure, as most systems are evaluated in well scoped settings and may not generalize across attack types or shifting tactics. At a field level, this suggests uneven maturity, with strong results in phishing and endpoint response but limited integration across the full attack lifecycle. An open problem is how to combine coordinated workflow automation with reliable and interpretable decision making, allowing broader autonomy without increasing the risk of silent failure or adversarial manipulation.

4.3 Enterprise Security Automation and Governance

As organizations adopt agentic AI, cybersecurity is shifting from isolated tools toward integrated and automated operations [43, 79, 145]. Agents now support software development, identity management, and workforce functions,

記憶體與自動化執行。RedTeamLLM 透過結合遞迴規劃、計畫修正與記憶體，並整合明確的安全控制（包括隔離、指令過濾、審計日誌與緊急關閉機制） [27]，展現了這一轉變。與 PenTestGPT 等早期工具相比，此設計在 VulnHub 目標上的任務完成度有所提升，顯示推理與記憶體能降低多階段攻擊的脆弱性 [27]。商業平台如 XBOW 與 RunSybile 進一步推動了自主性，並報告了高利用率和新漏洞的發現，但對代理推理過程與安全限制的可見性有限 [116]。此對比凸顯了效能與可控性之間的權衡：優先自主探索的系統能發現更多攻擊路徑，而強調結構與封閉的系統雖能限制濫用，卻也限制了發現範圍。

標記獲取（CTF）平台在此設計空間中佔據不同的位置。例如 OWASP FinBot CTF 和 CSAW Agentic Automated CTF 等框架，在緊密封閉的環境中利用多智能體角色進行偵測、攻陷與權限提升 [34, 119]。Trustwise 在法律科技領域應用了類似的模擬方法，證明受限的智能體評估可轉移至傳統安全領域之外 [157]。它們支持可重複性、安全性以及協調與對齊的基準測試，但簡化了目標並限制了智能體行動。因此，它們可能無法讓智能體接觸到部署時所遭遇的完整系統互動與故障模式。在目前的方法中，更高的自主性會增加雙用途風險，而更強的約束則會降低真實性 [116]。一個開放性的問題是：如何將受控對抗模擬的結果與現實世界的防禦設計相連結，同時不導致無法控制的攻擊能力，也不高估在簡化環境中訓練的智能體系統的魯棒性。4.2.3 對抗式 AI 防禦。對抗式 AI 防禦是指利用 AI 系統來應對適應性強且策略不斷演變的攻擊者，透過協調偵測、調查、決策與回應活動，在防禦工作流中實現整體防護。近期研究顯示，防禦模式正從孤立的偵測模型轉向協調的基於智能體的防禦系統。例如 Red Canary 平台強調端到端的協同 orchestration，其中智能體在單一工作流內偵測可疑行為、調查警報、封鎖端點、搜尋指標、修復系統並生成報告 [131]。此方法透過協調規劃、記憶與工具使用，優先確保速度與覆蓋範圍。相比之下，針對釣魚防禦的研究系統則強調在狹窄範圍內提升決策品質。MultiPhishGuard 將郵件分析分發至專責智能體，並利用強化學習來調整其影響力，從而提升對不斷演變釣魚模式的魯棒性 [168]。基於辯論的系統（如 PhishDebate）及相關的多智能體論證框架，則透過要求智能體在分類前必須為結論提供依據並提出挑戰，來強調可解釋性 [93, 162]。這些系統有助於減少確認偏誤並提升召回率，但僅限於分類階段，並未解決更廣泛的事件回應問題。

此比較揭示了範圍與保證之間的權衡。以工作流為導向的平臺偏好快速回應與運營規模，但依賴預定義的劇本與人工監督來處理不可逆動作 [131]。以辯論為驅動的檢測器偏好準確性、魯棒性與解釋性，但無法自然地擴展至修復或跨領域防禦 [93, 162, 168]。其中一個限制是，在適應性對抗壓力下缺乏保證，因為大多數系統是在範圍明確的設定下評估的，可能無法泛化至不同攻擊類型或變化的戰術。在現場層面，這表明成熟度不均，在釣魚與端點回應方面表現強勁，但在完整攻擊週期的整合上仍有限。一個開放的問題是，如何將協調的工作流自動化與可靠且可解釋的決策結合，在擴大自主權限的同時，不增加靜默失敗或對抗操縱的風險。

4.3 企業安全自動化與治理

隨著組織採用代理式 AI，資訊安全正從孤立工具轉向整合且自動化的運作 [43, 79, 145]。代理現在支援軟體開發、身份管理與人力資源功能，手稿已提交至 ACM

forming policy aligned security ecosystems. The convergence of DevSecOps, IAM, and SOC automation reflects a more mature stage of agentic cybersecurity that requires both adaptability and strong governance.

4.3.1 Enterprise Automation. Enterprise automation illustrates how agentic AI adapts to heterogeneous operational constraints across software and physical systems. In DevSecOps, platforms such as Jit.io embed agents into continuous integration (CI) and continuous deployment (CD) pipelines to detect vulnerabilities and generate contextual remediation guidance, while leaving execution authority with human developers to avoid production risk [79]. In contrast, IoT and surveillance focused systems address scale, device heterogeneity, and limited resources by using multi agent coordination, reinforcement learning, and real time telemetry to adapt security policies across large, distributed populations of devices [7, 16, 19, 40, 95, 126]. These deployments enable faster adaptation but operate within tightly scoped environments and predefined action sets.

Across enterprise domains, a consistent tradeoff appears between flexibility and control. Advisory agents preserve safety and accountability but limit coordination and response speed, while agents operating closer to devices improve responsiveness at the cost of higher operational and safety risk [19, 126]. Current systems fragment autonomy by domain rather than coordinating it across enterprise layers. A central limitation is the lack of mechanisms for sharing context and intent across code, devices, and situational awareness without expanding authority beyond acceptable bounds. An open problem is how to design enterprise scale coordination frameworks that preserve local safety guarantees while enabling agents to reason and act across heterogeneous operational layers.

4.3.2 Identity and Access Management (IAM). IAM is a core enforcement layer in enterprise security, with recent work showing how agentic AI shifts IAM from static rule checks toward adaptive, event driven control. In this context, adaptive, event-driven control refers to systems that continuously ingest authentication, authorization, and behavioral events and adjust the timing, scope, or intensity of policy-bound enforcement actions based on contextual risk signals, while operating within predefined access control policies. Industry systems prioritize operational speed by monitoring authentication events, flagging anomalies, and applying policy bound actions such as credential revocation or privilege adjustment in near real time [43, 79, 146]. These systems emphasize coverage and responsiveness but rely on predefined rules and limited representations of user intent. In contrast, they emphasize contextual reasoning. SmartAgent models user intent through a Chain of User Thought process inferred from interaction patterns [178], while CRAKEN integrates structured knowledge and planner executor control to ensure policy compliant mitigation [140]. This contrast separates fast policy enforcement from deeper user understanding.

Across approaches, a tradeoff appears between decision speed and contextual depth. Industry focused IAM agents act quickly but generalize poorly across roles and evolving behavior, while research systems improve alignment with user intent at the cost of greater complexity and reduced transparency. At a field level, agentic IAM is effective for high frequency access decisions but remains constrained by governance, auditability, and interpretability requirements. An open problem is how to combine rich user context modeling with predictable and auditable access control at enterprise scale without expanding agent authority beyond acceptable operational limits.

4.3.3 Cybersecurity Workforce Augmentation. Workforce shortages shape how agentic AI is deployed in security operations. Studies estimate a global gap of four to five million cybersecurity professionals, which constrains SOC capacity to handle alert volume and incident complexity [1, 47, 102]. As a result, policy and industry work frames agentic AI as augmentation rather than replacement. Wong and Saade describe agents as copilots that triage alerts, suppress false positives, and automate Tier 1 and Tier 2 tasks such as alert triage, initial investigation, and routine containment, allowing human analysts to focus on higher level reasoning and threat modeling [165]. Commercial deployments

建構與政策對齊的安全生態系統。DevSecOps、IAM 與 SOC 自動化的融合，反映了代理式網路安全已進入更成熟的階段，這需要兼具適應力與強有力的治理。

4.3.1 企業自動化。企業自動化展示了代理式 AI 如何適應軟體與物理系統之間異質的運作限制。在 DevSecOps 中，平台如 Jit.io 將代理嵌入持續整合（CI）與持續部署（CD）管道，以偵測漏洞並生成情境化的修復指導，同時將執行權限保留給人類開發者，以避免生產環境風險 [79]。相比之下，專注於物聯網與監控的系統透過多代理協調、強化學習與即時遙測技術，針對規模、裝置異質性及資源有限等挑戰，在大規模分散的裝置群體中調整安全策略 [7, 16, 19, 40, 95, 126]。這些部署能實現更快的適應能力，但運作於範圍狹窄且預定義行動集的環境中。

跨企業領域，靈活性與控制之間始終存在權衡。諮詢代理能維持安全性與責任歸屬，但會限制協調與反應速度；而更接近設備運作的代理則能提升回應速度，卻以更高的營運與安全風險為代價 [19, 126]。現行系統按領域碎片化自主權，而非跨企業層級進行協調。核心限制在於缺乏機制，能在不擴大授權至不可接受範圍的前提下，於程式碼、設備與情境感知之間共享上下文與意圖。另一項開放性課題是：如何設計跨企業規模的協調框架，既能維持本地安全保證，又能讓代理在異質營運層級間進行推理與行動。

4.3.2 身份與存取管理（IAM）。IAM 是企業安全的核心執行層，近期研究顯示，代理式 AI 正將 IAM 從靜態規則檢查轉向適應性、事件驅動的管控。在此背景下，適應性、事件驅動的管控指的是持續進食驗證、授權及行為事件，並依據情境風險訊號調整策略綁定執行行動的時序、範圍或強度，同時在預定義的存取控制策略內運作。產業系統優先重視運轉速度，透過監控驗證事件、標記異常，並在近乎實時的情況下應用策略綁定行動，例如憑證撤銷或權限調整 [43, 79, 146]。這些系統強調覆蓋率與回應速度，但依賴預定義規則且對使用者意圖的表現有限。相比之下，它們強調情境推理。SmartAgent 模型透過從互動模式推斷的「使用者思維鏈」過程來理解使用者意圖 [178]，而 CRAKEN 則整合結構化知識與規劃執行器控制，以確保符合策略的緩解措施 [140]。這種對比將快速的策略執行與更深層的使用者理解區隔開來。

跨方法而言，決策速度與情境深度之間存在權衡。專注於產業的 IAM 代理反應迅速，但難以跨角色與演變行為進行泛化；而研究系統則以增加複雜度與降低透明度為代價，提升了與使用者意圖的對齊程度。在實作層面，代理式 IAM 能有效處理高頻存取決策，但仍受限于治理、可稽核性及可解釋性要求。一個待解決的問題是：如何在企業規模下，將豐富的使用者情境建模與可預測、可稽核的存取控制結合，同時不使代理權限超出可接受的營運限制。

4.3.3 網路安全人力增補。人力短缺影響了代理式 AI 在安全運作的部署方式。研究估計全球網路安全專業人員缺口為四至五千人，這限制了 SOC 處理警報量與事件複雜度的能力 [1, 47, 102]。因此，政策與產業工作框架將代理式 AI 視為增強而非替代。Wong 與 Saade 將代理描述為助手，用於分級警報、抑制誤報，並自動化一級與二級任務（如警報分級、初步調查及常規封鎖），使人類分析師能專注於更高階的推理與威脅建模 [165]。商業部署

such as ReliaQuest GreyMatter, CrowdStrike Charlotte AI, and Simbian SOC agents report faster investigation and containment while keeping analysts in supervisory roles [85, 133, 145].

Across deployments, a tradeoff appears between efficiency and reliance on human oversight. Systems that automate large portions of alert handling achieve gains in speed and scale, but they depend on clean data, stable workflows, and mature processes to avoid compounding errors [85, 133]. Agents perform well on repetitive and well scoped tasks but remain less reliable for novel attacks, ambiguous signals, and strategic decisions requiring domain intuition [165]. Across the surveyed literature and reported deployments, augmentation emerges as the dominant design pattern, where agentic AI increases analyst capacity rather than reducing staffing needs. An open problem is to measure long term effects, including skill erosion, trust calibration, and accountability, as agents assume more routine security work [1, 47, 102].

4.4 Simulation, Training, and Testing

Autonomous cyber defense depends on controlled and reproducible environments that approximate real world complexity. Simulation, training, and testing frameworks provide such environments and support benchmarking and structured transfer from synthetic settings to operations [15, 97, 115]. Agentic AI extends this paradigm by automating parts of range construction and by acting as a learner within simulators and emulators.

4.4.1 Automated Cyber Range Generation. Cyber range construction has traditionally relied on expert scripting of network topologies, services, and attack scenarios, which is time consuming and costly. Recent work explores agent driven automation. ARCeR uses a multi agent retrieval augmented pipeline to generate and deploy cyber ranges from natural language descriptions [97]. Specialized agents retrieve documentation, generate configurations, validate compatibility, and orchestrate deployment. Relative to manual design, this approach reduces instructor effort and improves iteration speed. Compared to simpler automation or single model RAG systems, coordinated agents improve configuration correctness and deployment success [97], which depend on the quality and completeness of documentation.

Current systems exhibit clear limitations. ARCeR validates configuration and deployment but does not assess scenario realism, threat coverage, or training effectiveness [97]. Human review therefore remains necessary to evaluate instructional value and fidelity to real world attacks. Existing work suggests that agentic automation can accelerate range creation without replacing expert scenario design. Policy analysis further frames automated cyber ranges as shared infrastructure for training and safety evaluation as agentic AI adoption increases [15]. An open problem is how to validate that automatically generated ranges reflect evolving threats and learning objectives rather than producing environments that are structurally correct but substantively limited.

4.4.2 High-Fidelity Training Environments for Autonomous Cyber Defense. High-fidelity training environments address a gap in autonomous cyber defense research by providing shared settings that support both simulation and emulation under a common configuration model [115]. Earlier environments typically favored abstract simulation for scalability or ad hoc testbeds for realism, making it difficult to compare results or transfer trained policies. Cyberwheel exemplifies this class of environments by combining simulation and emulation through graph-based network definitions that specify topology, adversary behavior, actions, observations, and rewards. Agents are trained in simulation and evaluated in virtualized environments that reuse the same configurations and expose detector level observations derived from logs. This design supports reproducibility and enables controlled sim to real transfer within the defined environment, but introduce tradeoffs. Cyberwheel emphasizes experimental consistency and comparability but requires detailed configuration of networks, detectors, and reward functions, which increases setup effort and relies on human expert [115]. The environment also depends on predefined adversary models, detection probabilities, and logging behavior, which limits exposure to unmodeled attacks and operational noise. Cyberwheel illustrates how standardized environments can

例如 ReliaQuest GreyMatter、CrowdStrike Charlotte AI 和 Simbian SOC 代理，在保持分析師處於監督角色的情況下，能實現更快的調查與封鎖 [85, 133, 145]。

在實際部署中，效率與對人類監督的依賴之間存在權衡。能自動化大部分警報處理的系統雖能提升速度與規模，但需依賴乾淨的數據、穩定的工作流以及成熟的流程，以避免錯誤累積 [85, 133]。代理在重複且範圍明確的任務上表現良好，但在新型攻擊、模糊訊號以及需要領域直覺的戰略決策上仍較不可靠 [165]。在已調查的文獻與報告的部署中，增強模式成為主導設計範式，即代理式 AI 提升分析師的產能，而非減少人力需求。一個待解決的問題是衡量長期影響，包括技能退化、信任校準與責任歸屬，因為代理將更多常規安全工作納入其職責範圍 [1, 47, 102]。

4.4 模擬、訓練與測試

自主網絡防禦依賴於能模擬真實世界複雜度的受控且可重複的環境。模擬、訓練與測試框架提供這些環境，並支援基準測試及從合成環境到實際運作的結構化轉移 [15, 97, 115]。代理式 AI 透過自動化範圍構建的部分工作，並在模擬器與模擬環境中扮演學習者，進一步擴展此範式。

4.4.1 自動化網路模擬環境生成。網路模擬環境的建置傳統上依賴專家撰寫腳本來定義網路架構、服務與攻擊情境，此過程耗時且昂貴。近期研究探討了以代理驅動的自動化方案。ARCeR 採用多代理檢索增強型流程，從自然語言描述中生成並部署網路模擬環境 [97]。專用代理負責檢索文檔、生成配置、驗證相容性並協調部署。相較於手動設計，此方法降低了講師的工作量並提升了迭代速度。與較簡單的自動化或單一模型檢索增強生成系統相比，協同代理能提升配置正確率與部署成功率 [97]，後者取決於文檔的品質與完整性。

現有系統展現出明顯的局限。ARCeR 可驗證配置與部署，但無法評估情境真實性、威脅覆蓋率或訓練成效 [97]。因此，仍需人工審查以評估教學價值與對真實世界攻擊的忠實度。現有研究指出，代理自動化可加速範圍建立，卻不會取代專家情境設計。政策分析進一步將自動化網路模擬環境框定為用於訓練與安全評估的共享基礎設施，隨著代理式 AI 的採用日益增加 [15]。一個開放性的問題是：如何驗證自動生成的模擬環境能反映演進中的威脅與學習目標，而非僅產生結構正確但實質受限的環境。

4.4.2 自主網絡防禦的高保真訓練環境。高保真訓練環境透過提供支援模擬與模擬（emulation）的共同配置模型 [115]，彌補了自主網絡防禦研究中的缺口。早期的環境通常偏好抽象模擬以實現可擴展性，或採用臨時測試床以追求真實性，這使得結果難以比較或將訓練好的策略轉移。Cyberwheel 是這類環境的範例，它透過基於圖的網絡定義，結合模擬與模擬，其中定義了拓撲、敵對者行為、動作、觀察與獎勵。代理在模擬環境中進行訓練，並在虛擬化環境中進行評估，這些環境重用相同的配置，並暴露源自日誌的檢測器級別觀察。此設計支援可重複性，並能在定義的環境內實現受控的模擬至真實轉移，但也引入了權衡。Cyberwheel 強調實驗的一致性和可比性，但需要詳細配置網絡、檢測器和獎勵函數，這增加了設置工作量，並依賴於人類專家 [115]。此外，該環境還依賴於預定義的敵對者模型、檢測概率和日誌行為，這限制了對未建模攻擊和運營噪音的暴露。Cyberwheel 展示了標準化環境如何 Manuscript submitted to ACM

support benchmarking and comparative evaluation of learning based defense agents, but reported results remain tied to specific scenarios and detector assumptions. An open problem is to assess whether policies trained under fixed models remain robust when deployed in environments with different telemetry, detection gaps, and evolving threat behavior.

Key Takeaways from Section 4

- Agentic AI enables cybersecurity capabilities across the full breach lifecycle, but its benefits differ by phase. Pre-breach use cases emphasize monitoring, intelligence, and simulation, while during-breach systems focus on rapid detection and containment, and post-breach systems prioritize recovery, compliance, and learning.
- Most systems favor modular multi-agent designs, where agents perform narrowly scoped roles aligned with NIST Cyber Defense functions. This reduces risk and improves scalability compared to single end-to-end autonomous agents.
- A persistent tradeoff appears between speed and execution authority. Systems achieve early detection and response by granting agents autonomy on low-risk actions, while irreversible high-impact actions remain gated by human oversight.
- Agentic systems improve correlation, context retention, and workflow orchestration, but they remain sensitive to distribution shift, false positives, and misaligned incentives, especially in multi-agent coordination settings.
- Simulation, cyber ranges, and high-fidelity training environments are essential for evaluation and learning, yet platforms struggle to capture long-term adaptation, human oversight delays, and evolving adversary behavior.
- Across all domains, agentic AI functions most reliably as augmentation rather than replacement, with autonomy carefully bounded by governance, auditability, and escalation mechanisms.

5 Agentic AI-Enabled Cyber Attacks

Agentic AI increases the power of cyber offense as the same reasoning and planning used in defense can also enable autonomous attacks. Agents can perform reconnaissance, discover vulnerabilities, and execute multi-stage intrusions with limited human involvement. Industry reporting shows that cybercriminals already experiment with agent driven reconnaissance, adaptive malware, and large scale automation, which increases the speed and reach of cybercrime [85].

Research from Palo Alto Networks illustrates this shift. Unit 42 introduced an *Agentic AI Attack Framework* that simulates autonomous ransomware campaigns and shows that agents can complete the full ransomware lifecycle in about 25 minutes [122]. Mean time to exfiltrate fell from nine days in 2021 to about two days in 2024, with many incidents completing exfiltration in less than an hour. A second Unit 42 study evaluated nine attack scenarios on frameworks such as CrewAI and AutoGen and found that prompt injection, unsafe tool use, SQL injection, and communication poisoning can lead to data exfiltration, credential theft, and remote code execution [121]. Many failures stem from weak validation and insecure integrations, which shows that offensive use of agentic AI is increasing and that current agentic ecosystems contain structural weaknesses. Table 4 summarizes key offensive domains, techniques, and the agentic capabilities that support them. The rest of this section focuses on three areas: insider threats and autonomous exploitation, ransomware operations, and social engineering and financial fraud.

5.1 Insider Threats and Autonomous Exploits

Research shows that agentic AI introduces insider risk through autonomy rather than through human intent. A compromised or misdirected agent can operate under valid credentials, persist over long periods, and perform actions such as record modification, data exfiltration, or payload execution that appear legitimate [46]. This differs from traditional insider threats, which depend on human motivation and limited attention. Agentic systems enable coordination across tasks such as information gathering and phishing content generation, which increases reach and consistency. These behaviors arise from the planning and execution capabilities that make agents effective for enterprise tasks.

支援基於學習的防禦代理的基準測試與比較評估，但報告的結果仍與特定場景及偵測器假設掛鉤。一個開放性的問題是評估在固定模型下訓練的策略，在具有不同遙測數據、偵測盲點及演變威脅行為的環境中部署時是否仍能保持魯棒性。

第 4 節重點摘要

- 代理式 AI 可實現全週期 breach 生命週期的網路安全能力，但其效益因階段而異。事前 breach 的用例強調監控、情報與模擬，而事中 breach 系統則專注於快速偵測與封鎖，事後 breach 系統則優先處理復原、合規與學習。
- 大多數系統採用模組化多代理設計，其中代理執行與 NIST 網路防禦功能對齊的狹窄範疇角色。與單一端到端自主代理相比，這可降低風險並提升可擴展性。
- 速度與執行權限之間存在持續的權衡。系統透過賦予代理人在低風險行動上的自主權，實現早期偵測與回應，而不可逆且高影響力的行動則仍由人類監管進行管控。
- 代理系統能提升相關性、上下文保留與工作流協調，但對分佈偏移、誤報及激勵不一致仍十分敏感，尤其在多代理協同場景下尤為明顯。
- 模擬、網路演練場域及高保真訓練環境對於評估與學習至關重要，然而現有平台難以捕捉長期適應、人類監督延遲以及不斷變化的敵對行為。
- 在所有領域中，代理式 AI 最可靠地扮演增強而非替代的角色，其自主性透過治理、可審計性及升級機制得到謹慎約束。

5 由代理式 AI 驅動的網路攻擊

代理式 AI 增強了網路攻擊的威力，因為用於防禦的相同推理與規劃能力也可用於自主攻擊。代理可執行偵測、發現漏洞，並在有限人類參與下執行多階段入侵。產業報告顯示，網路犯罪者已開始實驗以代理驅動的偵測、適應性惡意軟體以及大規模自動化，這提升了網路犯罪的速度與範圍 [85]。

Palo Alto Networks 的研究揭示了這一趨勢。Unit 42 推出了「代理式 AI 攻擊框架」，模擬自主勒索軟體攻擊，並顯示代理可在約 25 分鐘內完成完整的勒索軟體生命週期 [122]。資料外洩的平均時間從 2021 年的九天降至 2024 年的約兩天，許多事件甚至在不到一小時內就完成了外洩。第二項 Unit 42 研究評估了 CrewAI 和 AutoGen 等框架上的九種攻擊情境，發現提示注入、不安全工具使用、SQL 注入及通訊中毒可能導致資料外洩、憑證竊取及遠端程式執行 [121]。許多失敗源於驗證不足與不安全整合，這顯示攻擊性使用代理式 AI 正在增加，且現有的代理式生態系統存在結構性弱點。表 4 總結了關鍵攻擊領域、技術及支援這些能力的代理式功能。本節其餘內容聚焦於三個領域：內部威脅與自主利用、勒索軟體營運，以及社會工程與金融詐騙。

5.1 內部威脅與自主利用

研究顯示，代理式 AI 透過自主性而非人類意圖引入內部風險。一個被妥協或誤導的代理可憑藉有效憑證運作，長期滲透，並執行看似合法的行為，例如記錄修改、資料洩漏或載具執行 [46]。這與傳統內部威脅不同，後者取決於人類動機與有限的注意力。代理式系統能協調資訊蒐集與釣魚內容生成等任務，從而提升影響範圍與一致性。這些行為源於使代理能有效執行企業任務的規劃與執行能力。

Table 4. Taxonomy of agentic AI-enabled cyber attacks with representative domains, techniques and capabilities.

Attack Domain	Example Techniques	Agentic Capabilities	Key References
Ransomware	Full automated lifecycle from compromise to exfiltration	Multi-agent orchestration, real-time adjustment	Unit42 [122], Halcyon [57]
Insider Threats	Record tampering, stealth data theft, malicious tasks under valid identity	Persistent access, autonomous execution	TechMonitor [46], Anthropic [10]
Social Engineering and Fraud	Voice scams, deepfake phishing, synthetic identity fraud	Goal decomposition, adaptive dialogue, multimodal synthesis	ScamAgents [17], Visa [161], Burch [24]
Exploitation and Reconnaissance	Autonomous scanning, adaptive malware, real-time reconnaissance	Self-improving exploitation strategies	Kshetri [85], Unit42 [121]

A related risk appears in autonomous vulnerability discovery. Systems designed to scan for weaknesses and support patching can reduce defensive workload, but they can also be repurposed to identify exposed systems at scale. For example, threat actors have abused HexStrike-AI, a red-team platform intended for vulnerability discovery and testing, to automate large-scale reconnaissance and exploitation by scanning thousands of IP addresses in parallel. Security analyses further note that similar repurposing risks apply even to benign-sounding defensive workflows, such as backup or configuration scanners, which could be adapted to stage data exfiltration if misdirected [65, 90]. This creates a tradeoff between capability and control. Greater autonomy improves coverage and efficiency, but it increases the potential impact of misalignment or compromise. Existing defenses rely on identity controls, input filtering, segmentation, and monitoring, which often detect misuse only after it has begun. These limitations indicate that insider risk in agentic systems extends beyond credential theft to the behavior of trusted agents that act autonomously under valid identities. An open problem is how to design agents that can perform privileged actions while providing enforceable guarantees that misuse, whether accidental or adversarial, is prevented rather than merely contained.

5.2 Agentic AI for Ransomware Operations

Traditional ransomware relies on human attackers to perform reconnaissance, gain access, move laterally, and exfiltrate data over days or weeks. Agentic ransomware automates these steps into a continuous workflow that can complete the chain of compromise within minutes or hours [122, 132]. Figure 4 contrasts sequential human operated attack stages with agentic workflows that execute reconnaissance, exploitation, persistence, and exfiltration under real time feedback. This contrast highlights a tradeoff between speed and control, where autonomy increases scale and tempo while reducing direct human oversight.

Industry analyses warn that this acceleration reduces defender response windows and increases operational impact. Halcyon uses the term ransomware variants to describe different execution paths of a ransomware campaign, where autonomous controllers adjust the sequence of actions in response to failures or constraints, rather than generating new malware binaries or payloads. [57]. In these systems, adaptation occurs at the orchestration layer rather than in the ransomware payload itself. Agents replan attack sequences based on tool output, environmental feedback, and access constraints, selecting alternative reconnaissance paths, privilege escalation attempts, or exfiltration strategies when actions fail. Existing reports indicate that this adaptation relies on heuristic planning and LLM-assisted reasoning rather than reinforcement learning, with no evidence of online policy training during active attacks.

Recent analyses further indicate that language models may be incorporated into ransomware operations for operational and extortion-related tasks rather than for payload generation. The Anthropic misuse report documents cases in which agents use language models to interpret stolen data, assist with victim profiling, and generate extortion communications, while human operators retain control over high-level objectives [11]. In this role, the language model

表 4. 代理 AI 驅動的網路攻擊分類，包含代表性領域、技術與能力。

攻擊領域	範例技巧	代理能力	關鍵參考資料
勒索軟體	完整的自動化生命週程從 compro-轉移至外洩	多智能體協同，真實的時間調整	Unit42 [122], Halcyon [57]
內部威脅	記錄篡改、隱蔽資料竊取、馬 - 合法身份下執行愉快任務	持續存取，自主執行檔 - 注意	TechMonitor [46],Anthropic [10]
社群 工程 且欺詐	語音詐騙、深度偽造釣魚、合成合成身份詐欺	目標分解，適應性日logue，多模態合成	詐騙代理人 [17], Visa [161], Burch [24]
剽掠與再利用 **知識**	自主掃描，適應性異常ware，即時偵察	自我進化的剝削策略 - gies	Kshetri [85],Unit42 [121]

相關風險也出現在自動漏洞發現中。設計用於掃描弱點並支援補丁的系統可降低防禦工作負載，但也可能被改用以大規模識別暴露系統。例如，威脅行為者濫用了 HexStrike-AI，這是一個旨在進行漏洞發現與測試的紅隊平台，用以自動化大規模偵查與攻勢，透過並行掃描數千個 IP 地址來實現。安全分析進一步指出，類似改用的風險甚至適用於聽起來良善的防禦工作流程，例如備份或配置掃描器，若被誤導 [65, 90]，則可能用於準備資料外洩。這在能力與控制之間產生了權衡。更高的自主性提升了覆蓋率與效率，但也增加了誤置或遭攻勢的潛在影響。現有防禦依賴身份控制、輸入過濾、區隔與監控，通常僅在誤用開始後才能偵測到。這些限制顯示，代理系統中的內部風險不僅限於憑證竊取，還包括在有效身份下自主行動的可信代理的行為。一個開放的問題是：如何設計能夠執行特權操作，同時提供可強制執行的保證，以預防而非僅限於封鎖誤用（無論是因疏忽或敵對行為所致）。

5.2 代理 AI 用於勒索軟體操作

傳統勒索軟體依賴人類攻擊者進行偵查、取得權限、橫向移動及洩漏資料，過程可能持續數天或數週。代理勒索軟體則將這些步驟自動化為連續工作流，可在數分鐘或數小時內完成攻陷鏈條 [122, 132]。圖 4 對比了循序進行的由人類操作攻擊階段與具備代理工作流，該工作流在即時反饋下執行偵查、攻陷、持久化及洩漏。此對比凸顯了速度與控制權之間的權衡：自主性提升了規模與節奏，卻減少了直接的人類監督。

產業分析警告稱，這種加速會縮短防禦者的反應時間，並增加營運影響。Halcyon 使用「勒索軟體變體」一詞來描述勒索軟體活動的不同執行路徑，其中自主控制器會根據失敗或限制情況調整行動順序，而非生成新的惡意軟體二進制文件或載入模組。 [57]。在這些系統中，適應性發生在協同層，而非勒索軟體載入模組本身。代理根據工具輸出、環境反饋及存取限制重新規劃攻擊序列，當行動失敗時，會選擇替代的偵測路徑、權限提升嘗試或外洩策略。現有報告顯示，這種適應性依賴於直覺規劃與大型語言模型輔助推理，而非強化學習，且在活躍攻擊期間並無線上策略訓練的證據。

近期分析進一步指出，語言模型可能被納入勒索軟體操作中，用於營運及勒索相關任務，而非用於載體生成。Anthropic 誤用報告記錄了以下案例：代理使用語言模型來解讀竊取的数据、協助受害者畫像，並生成勒索通訊，而人類操作員則保留對高層目標的控制權 [11]。在此角色中，語言模型

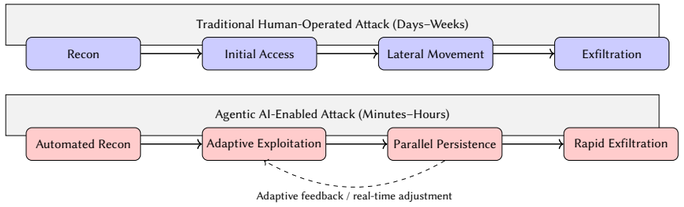

Fig. 4. Comparison of traditional and agentic AI-enabled cyber attack chains.

functions as a reasoning component within the ransomware workflow, supporting decision making without modifying the underlying encryption or exfiltration mechanisms. Across existing studies, agentic ransomware is best understood as an escalation of automation and decision autonomy rather than a fundamentally new cryptographic or exploit class. This framing shifts emphasis away from payload novelty toward the problem of detecting and interrupting autonomous attack loops before lateral propagation and data exfiltration complete. An open problem is how to reliably identify adaptive agent behavior early in ransomware campaigns, especially when human attackers deliberately minimize interaction and rely on autonomous execution to compress timelines and evade intervention [11].

5.3 Agentic AI in Social Engineering and Financial Fraud

Agentic AI increasingly automates fraud and social engineering by supporting phishing, payment fraud, and scam coordination through automated reconnaissance, message generation, and adaptive interaction with victims [24, 161]. Compared to human-driven fraud, agentic systems operate faster and at larger scale because they maintain memory, adjust tactics during interaction, and coordinate multiple steps without continuous oversight. This increases reach and consistency, but reduces human judgment and raises the risk of rapid misuse when safeguards fail.

Academic work reinforces this concern. ScamAgents shows that autonomous agents can conduct multi-turn scam calls that adapt to user responses, evade LLM safety guardrails such as refusal mechanisms and prompt-level content filters, and complete end-to-end fraud pipelines using planning, memory, and speech synthesis [17]. This goes beyond single-prompt misuse and highlights a tradeoff between flexibility and control. While agentic fraud systems lower attacker effort and scale persuasion, they remain constrained by persona realism, communication latency, and access to delivery infrastructure. Taken together, existing work reframes fraud risk from isolated content abuse to sustained agent behavior. An open problem is to detect and interrupt deceptive intent across multi-turn interactions before agents complete persuasion or payment workflows, especially in consumer-facing systems where false positives are costly.

6 Security of Agentic AI

Agentic AI shifts system design from static, rule based tools to autonomous agents that reason, plan, and act. Unlike traditional applications, these systems often have read and write access, call external APIs, and orchestrate multi-step workflows with limited human oversight. This autonomy enables new capabilities but also introduces risks such as large scale data exfiltration, supply chain compromise, and emergent behavior that is difficult to predict. As systems move from fixed actions to open ended goals expressed in natural language, the attack surface expands and security strategies must account for autonomy, adaptation, and orchestration [24].

Policy work increasingly treats agentic AI as emerging critical infrastructure. Atir argues that agents with persistent memory, API access, and long horizon planning expand the attack surface beyond traditional AI and resemble

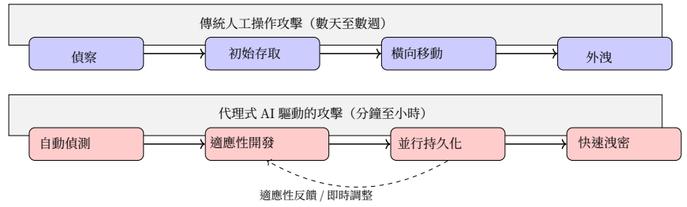

圖 4。傳統與代理 AI 驅動的網路攻擊鏈的比較。

在勒索軟體工作流中，其功能如同推理元件，支援決策過程，卻不修改底層的加密或外洩機制。在現有研究中，代理型勒索軟體最恰當的理解方式，是自動化與決策自主性的升級，而非一種全新的密碼學或漏洞利用類別。此觀點將焦點從載具的新穎性，轉移至如何偵測並中斷自主攻擊循環，防止其橫向擴散與資料外洩完成。一個待解的課題是：如何可靠地識別勒索軟體活動早期階段中，代理的適應性行為，特別是當人類攻擊者刻意減少互動，並依賴自主執行來壓縮時間軸、規避干預時 [11]。

5.3 代理 AI 在社會工程學與金融詐欺中的應用

代理式 AI 正透過自動化偵測、訊息生成及與受害者 [24, 161] 的適應性互動，日益自動化詐欺與社會工程攻擊，支援釣魚、支付詐欺及詐騙協調。與人類驅動的詐欺相比，代理式系統運作更快且規模更大，因為它們能維持記憶、在互動中調整策略，並無需持續監督即可協調多步驟操作。這雖提升了覆蓋範圍與一致性，但也降低了人類判斷力，且一旦防護措施失效，便會增加快速濫用的風險。

學術研究強化了這一擔憂。ScamAgents 顯示，自主代理能夠進行多輪詐騙電話，根據用戶回應進行適應，繞過大型語言模型的安全防護機制（如拒絕機制和提示詞級內容過濾器），並利用規劃、記憶和語音合成技術完成端到端的詐騙管道 [17]。這超越了單一提示詞的濫用，凸顯了靈活性與控制之間的權衡。儘管代理詐騙系統降低了攻擊者的努力成本並放大了說服能力，但仍受限于角色真實性、通信延遲以及交付基礎設施的可及性。綜合而言，現有研究將詐騙風險從孤立的內容濫用重新定義為持續的代理行為。一個開放性的問題是：如何在多輪互動中，在代理完成說服或支付工作流之前，檢測並中斷欺騙意圖，特別是在錯誤率昂貴的面向消費者的系統中。

6 代理 AI 的安全性

代理 AI 系統設計從靜態、基於規則的工具，轉向能夠推理、規劃並執行的自主代理。與傳統應用程式不同，這些系統通常具有讀取和寫入權限、可調用外部 API，並能在有限的人類監督下協調多步驟工作流。這種自主性帶來了新能力，但也引入了風險，例如大規模資料洩漏、供應鏈受侵害，以及難以預測的突發行為。隨著系統從固定動作轉向以自然語言表達的開放式目標，攻擊面擴大，安全策略必須納入自主性、適應性與協調性 [24]。

政策工作越來越將具自主性的 AI 視為新興的關鍵基礎設施。有學者指出，具備持續記憶、API 存取權限及長期規劃能力的代理，其攻擊面已超越傳統 AI，並類似於

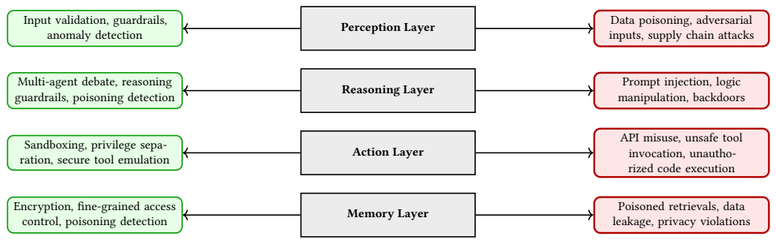

Fig. 5. Four-Layer Model of agentic AI security (Wong & Saade [165]), illustrating threats and mapped defenses across Perception, Reasoning, Action, and Memory layers.

infrastructure such as the Internet or power grids [15]. This framing implies a dual requirement: agentic systems must be technically secure and embedded within governance frameworks for national security and critical services. Tallam [155] describes an *adaptive engagement* paradigm in which defense becomes a cycle of sensing, contextual analysis, response, and learning. Tallam notes that these same capabilities can destabilize security environments when transparency, accountability, and human oversight are weak.

Other work addresses correctness and concrete attack surfaces. Horus proposes a collateralized verification protocol where solvers and challengers post bonds on task outcomes, using recursive adjudication and slashing to discourage errors when $B > F/P_e$ [144]. Khan et al. document how database facing agents expose compliance gaps, weak audit trails, and unsafe query generation that can compromise entire data stores through a single workflow [76]. From an offensive perspective, Unit 42's Agentic AI Attack Framework shows how autonomous agents compress ransomware lifecycles and other campaigns [122]. Defensive frameworks such as ATFAA, SHIELD, Microsoft's failure mode taxonomy, MAESTRO, and OWASP Agentic AI aim to address this evolving threat landscape [23, 66, 111, 118].

6.1 Conceptual Risk Models and Threat Taxonomies

Conceptual risk models help explain how agentic AI systems fail and where defenses should apply. Wong and Saade organize agentic risk across four functional layers perception, reasoning, action, and memory [165]. This model shows that failures propagate across stages rather than remaining isolated. Figure 5 maps representative threats and defenses at each layer. Data poisoning and supply chain attacks affect perception. Prompt injection and logic manipulation affect reasoning. Unsafe tool use affects action. Memory poisoning and leakage affect long term state. The key insight is that effective defense requires coordinated controls across layers rather than isolated mitigations.

Several frameworks extend this layered view. ATFAA defines domain based risk categories that include cognitive, temporal, operational, trust, and governance risks, and proposes SHIELD as a defense blueprint based on segmentation, integrity checks, escalation control, immutable logging, and shared oversight [111]. NVIDIA defines explicit autonomy levels and ties safeguards to degrees of agent independence, which makes autonomy a direct risk variable [58]. MAESTRO expands the scope to models, data flows, orchestration, infrastructure, and governance, and maps threats such as embedding poisoning, collusion, and model theft to specific controls [66]. Applied studies such as NetMoniAI show that MAESTRO style reasoning can improve detection timeliness through memory isolation, planner validation, and anomaly monitoring, although evaluations remain system specific [173, 174].

Practitioner focused frameworks emphasize actionability. The OWASP Agentic Security Initiative catalogs common agentic threats and links them to controls such as sandboxing, privilege separation, and continuous monitoring [118].

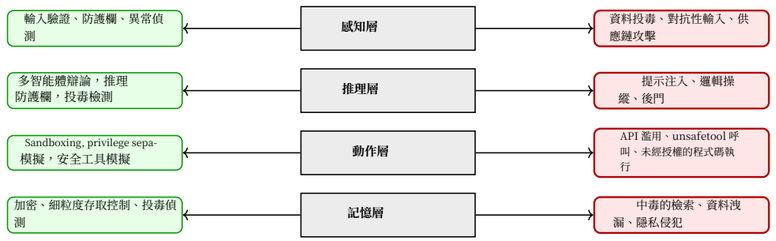

圖 5。代理式 AI 安全之四層模型（Wong & Saade［165］），說明感知、推理、行動與記憶各層之威脅與對應防禦措施。

基礎設施（如網際網路或電力網）［15］。此框架暗示了雙重需求：代理系統必須具備技術安全性，並嵌入至國家安全與關鍵服務的治理框架中。Tallam［155］描述了一種適應性參與範式，其中防禦成為感知、情境分析、回應與學習的循環。Tallam 指出，當透明度、責任歸屬與人類監督薄弱時，這些相同的能力可能會 destabilizesecurity environments。

其他工作專注於正確性與具體攻擊面。Horus 提出一種抵押驗證協議，讓求解者與挑戰者在任務結果上貼出保證金，透過遞迴審判與切斷機制，在 $B > F/P_e$ [144] 時抑制錯誤。Khan 等人記錄了面對式資料庫的代理如何暴露合規缺口、審計痕跡薄弱以及不安全查詢生成，這些問題可能透過單一工作流危及整個資料庫［76］。從攻擊角度來看，Unit 42 的代理式 AI 攻擊框架顯示自主代理如何壓縮勒索軟體生命週期及其他行動［122］。防禦性框架如 ATFAA、SHIELD、Microsoft 的失效模式分類法、MAESTRO 以及 OWASP 代理式 AI 旨在應對此不斷演變的威脅環境［23, 66, 111, 118］。

6.1 概念風險模型與威脅分類法

概念性風險模型有助於解釋代理式 AI 系統如何失敗，以及防禦措施應在哪裡應用。Wong 和 Saade 將代理式風險分為四個功能層級：感知、推理、行動與記憶［165］。此模型顯示，失敗會跨階段傳播，而非保持孤立。圖 5 展示了各層級的典型威脅與防禦措施。資料投毒與供應鏈攻擊影響感知。提示注入與邏輯操縱影響推理。不安全工具使用影響行動。記憶投毒與洩漏影響長期狀態。關鍵見解是，有效的防禦需要跨層級的協調控制，而非孤立的緩解措施。

多個框架擴展了此分層觀點。ATFAA 定義了基於領域的風險類別，涵蓋認知、時間、營運、信任與治理風險，並提出基於分割、完整性檢查、升級控制、不可變日誌與共同監督的 SHIELD 防禦藍圖［111］。NVIDIA 定義了明確的自主權等級，並將保障措施與代理獨立程度掛鉤，使自主權成為直接的風險變量［58］。MAESTRO 將範圍擴展至模型、數據流、調度、基礎設施與治理，並將嵌入中毒、串謀與模型盜竊等威脅映射至特定控制措施［66］。應用研究如 NetMoniAI 顯示，MAESTRO 風格的推理可透過記憶體隔離、規劃器驗證與異常監控提升檢測及時性，儘管評估仍具系統特定性［173, 174］。

專注於行動的實踐者框架強調可執行性。OWASP 代理安全計劃彙整了常見的代理威脅，並將其與沙箱、權限隔離及持續監控等控制措施相連結［118］。手稿已提交至 ACM

Table 5. Security Risks, Threats, and Defenses in Agentic AI

Framework / Source	Risk / Threat Layer	Example Threats	Defenses / Controls	Notes / Limitations
Wong & Saade [165]	Layered Model (Perception, Reasoning, Action, Memory)	Data poisoning, prompt injection, unsafe API calls, memory leakage	Input validation, guardrails, sandboxing, encryption	Conceptual taxonomy; needs integration with autonomy aware safeguards
NVIDIA [58]	Autonomy Levels	Risks scale with autonomy from inference misuse to full autonomous takeover	API protections, taint tracing, mandatory sanitization	Focused on autonomy; limited detail on inter agent risks
Deng et al. [37]	Lifecycle and Multi Agent Threats	Prompt injection, flawed planning, collusion, poisoning, sandbox evasion	Privilege hierarchies, multi agent debate, poisoning detection	Highlights gaps in oversight and environment modeling
He et al. [61]	System Level Vulnerabilities	Session mismanagement, model pollution, arbitrary code execution	Sandboxing, session isolation, cryptographic protections	Evaluated on LLM agents; broader ecosystems still open
Khan et al. [76]	Unauthorized Action Execution	Direct database access, cascading malicious queries	Execution boundaries, scoped access, monitoring	Case driven; needs broader generalization
Schroeder de Witt [137]	Multi Agent Security	Collusion, emergent deception, societal scale risks	Constrained protocols, monitoring, decentralized oversight	Mostly theoretical; calls for system realizations
Yang et al. [169], Zhou et al. [184]	Secure Coordination	Hallucination propagation, unsafe workflows, collusion	Adversarial debate, voting, temporal graph anomaly detection	Improves reliability; add communication overhead
BlockA2A [187]	Accountability Infrastructure	Message tampering, unsafe inter agent execution	Blockchain verification, immutable logs, dynamic permissions	Scalability and efficiency remain open issues
SAFEFLOW [92], SentinelAgent [60]	Information Flow and Oversight	Data leakage, adversarial message passing	Fine grained information flow control, graph based anomaly detection	Require integration into orchestration platforms
Red Teaming and Ranges [96, 97, 115]	Evaluation and Simulation	Prompt injection, unsafe tool use, collusion, memory poisoning	Red blue simulations, automated cyber ranges, adversarial testbeds	Resource intensive; coverage and standardization still evolving

Microsoft's failure mode taxonomy lists concrete breakdowns including agent compromise, workflow manipulation, memory poisoning, and multi agent jailbreaks, and links them to identity controls, constrained execution, and tamper resistant logging [23]. Governance focused approaches such as TRiSM and enterprise frameworks from Kyndryl emphasize trust calibration, provenance tracking, and auditable oversight, but defer technical enforcement to underlying systems [89, 130]. Runtime mechanisms such as Governance as a Service and BlockA2A enforce controls during execution through policy checks, identity verification, and decentralized logging, but assume correct policy specification and trusted identity layers [51, 187]. Practitioner focused frameworks emphasize actionability. The OWASP Agentic Security Initiative catalogs common agentic threats and links them to controls such as sandboxing, privilege separation, and continuous monitoring [118]. Microsoft's failure mode taxonomy lists concrete breakdowns including agent compromise, workflow manipulation, memory poisoning, and multi agent jailbreaks, and links them to identity controls, constrained execution, and tamper resistant logging [23]. Governance focused approaches such as TRiSM and enterprise frameworks from Kyndryl emphasize trust calibration, provenance tracking, and auditable oversight, but defer technical enforcement to underlying systems [89, 130]. Runtime mechanisms such as Governance as a Service and BlockA2A enforce controls during execution through policy checks, identity verification, and decentralized logging, but assume correct policy specification and trusted identity layers [51, 187].

Table 5 consolidates the main frameworks and studies discussed in this section and aligns them by risk layer, example threats, proposed controls, and reported limitations. It includes conceptual models such as the four layer model by Wong and Saade [165] and autonomy levels from NVIDIA [58], lifecycle and multi agent taxonomies [37, 137], system level vulnerability studies [61, 76], runtime coordination and information flow defenses [60, 92, 184, 187], and evaluation platforms for red teaming and simulation [96, 97, 115]. The table also exposes two gaps. Many defenses emphasize perception and reasoning, while action enforcement, multi-agent interaction, and resource governance receive less mature coverage. No single framework connects autonomy, lifecycle risks, and runtime enforcement into one integrated stack, so the remaining subsections examine concrete attack surfaces and controls in more detail.

表 5。智能體 AI 的安全風險、威脅與防護措施

框架 / 來源	Risk / 威脅層	範例威脅	防護措施 / 控制措施	備註 / 限制
Wong & Saade [165]	分層模型（每 ception, Reasoning, 動作，記憶）	資料投毒，提示詞注入，不安全 API 呼叫，記憶體洩漏	輸入驗證，防護欄，沙盒 拳擊，加密	概念分類法；需要進一步… 與自主感知防護的整合
NVIDIA [58]	自主程度等級	風險會隨著自主性的提升而擴大 推論 濫用至 完整 au- 自主接管	API 保護措施， 污染追蹤， 強制清洗	專注於自主性；有限的解離 - 在代理間風險上的尾
Deng 等 [37]	生命週期與多代理威脅	提示注入、規劃缺陷、串謀、投毒、沙盒逃逸	權限階層，多代理 辯論，中毒偵測	突顯監督與 oversight 之間的差距並 環境建模
He 等 [61]	系統層級漏洞 - 脆弱性	會話管理不當、模型污染、任意代碼執行	Sandboxing, session isolation, cryp- 圖形保護	已評估 on LLM 代理； 更廣泛的生態系統仍保持開放
Khan 等人 [76]	未經授權 執行動作	直接資料庫存取，級聯惡意查詢	執行邊界，作用域 ac- cess, 監控	以案例為驅動；需要更廣泛的世代 - 泛化
施羅德 de Witt [137]	多智能體安全 - rity	串謀、突發欺詐、社會規模風險	受限協議，監控， 去中心化監督	主要為理論性；呼籲實現系統實現
Yang 等人 [169], Zhou 等人. [184]	安全 協調 - tion	幻覺傳播，未 - 安全的工作流程，串謀	對抗性辯論、投票、節奏 - 圖形異常檢測	提升可靠性；添加通訊 - 通訊負荷
BlockA2A [187]	責任追究中 - 基礎設施	訊息篡改，不安全互 代理執行	區塊鏈驗證，不可變 日誌，動態權限	可擴展性與效率依然保持 未解決問題
SAFEFLOW [92], SentinelAgent [60]	資訊 Flow 和監督	資料洩漏，對抗式訊息 - sage passing	Fine grained information flow con- 控管，基於圖的異常偵測	Require integration into orches- 整合平台
紅隊測試與範圍 [96, 97, 115]	評估與模擬	提示注入，不安全工具使用，串謀，記憶中毒	紅藍演練、自動化網絡模擬環境、對抗測試床	資源密集；覆蓋範圍與標準化仍 在發展中

Microsoft 的失效模式分類學列舉了具體的分解案例，包括代理權腐化、工作流操縱、記憶投毒和多代理越獄，並將其與身份控制、受限執行和防篡改日誌記錄 [23] 相連結。以治理為核心的方法，如 TRiSM 和 Kyndryl 的企業框架，強調信任校準、來源追蹤和可審計監督，但將技術執行委託給底層系統 [89, 130]。運行時機制，如治理即服務和 BlockA2A，透過政策檢查、身份驗證和分散式日誌記錄在執行期間強制執行控制，但假設政策規範正確且身份層級可信 [51, 187]。以實踐者為核心的框架強調可執行性。OWASP 代理安全倡議彙整了常見的代理威脅，並將其與沙盒、權限隔離和持續監控等控制措施相連結 [118]。Microsoft 的失效模式分類學列舉了具體的分解案例，包括代理權腐化、工作流操縱、記憶投毒和多代理越獄，並將其與身份控制、受限執行和防篡改日誌記錄 [23] 相連結。以治理為核心的方法，如 TRiSM 和 Kyndryl 的企業框架，強調信任校準、來源追蹤和可審計監督，但將技術執行委託給底層系統 [89, 130]。運行時機制，如治理即服務和 BlockA2A，透過政策檢查、身份驗證和分散式日誌記錄在執行期間強制執行控制，但假設政策規範正確且身份層級可信 [51, 187]。

表 5 整合了本節討論的主要框架與研究，並依風險層級、範例威脅、建議控制措施及已報告的局限性進行對齊。該表包含概念性模型，例如 Wong 與 Saade 的四層模型 [165] 、NVIDIA 的自主性等級 [58], 、生命週期與多代理分類法 [37, 137], 、系統層級漏洞研究 [61, 76], 、運行時協調與資訊流防禦 [60, 92, 184, 187], ，以及用於紅隊測試與模擬的評估平台 [96, 97, 115]。該表也揭示了兩個缺口。許多防禦措施強調感知與推理，而行動執行、多代理互動與資源治理則獲得較不成熟的覆蓋。目前沒有任何單一框架將自主性、生命週期風險與運行時執行整合為一套完整堆疊，因此剩餘的小節將更詳細地探討具體攻擊面與控制措施。

6.2 System-Level Vulnerabilities and Security Controls for Agentic AI

Recent work shows that agentic AI systems introduce system-level vulnerabilities that do not arise in static language models because agents maintain state, execute tools, and operate across sessions. He et al. [61] analyze these risks from a system security perspective and identify three primary vulnerability classes. First, session management failures in multi-user settings enable confidentiality and integrity violations through data leakage, action misattribution, and denial of service. Second, model pollution and privacy leakage arise when fine-tuning or persistent memory allows poisoning, unintended data retention, or cross-user information exposure. Third, executable agent programs expand the attack surface by enabling arbitrary code execution, resource abuse, and agent hijacking when actions generated by the model are executed without adequate isolation. Experiments with a Bash-based agent showing over 75% of malicious commands execute successfully without sandboxing, while container-based sandboxing blocks nearly all such commands, demonstrating confidentiality, integrity, and availability risks at agent runtime rather than the model alone.

Chakrabarty et al. [26] examine a broader class of adversarial exploits spanning training and inference, including evasion, poisoning, privacy extraction, and agent-specific attacks such as goal hijacking and prompt manipulation. In contrast to the component-level focus of He et al., this work emphasizes operational impact, including privilege escalation, unauthorized access, degraded system performance, and erosion of trust. The proposed defenses emphasize continuous threat detection, automated incident response, predictive defense using historical and real-time signals, and risk-based vulnerability management, reflecting a more operationally oriented threat model.

Across these studies, security controls are framed as mitigations for the vulnerabilities introduced by agent planning, memory, and tool execution. Planning frameworks such as ReAct and Tree of Thoughts increase capability through multi-step reasoning and effectful tool use, but also enlarge the attack surface by introducing intermediate actions with side effects [61]. To reduce the resulting risk, system-level controls such as sandboxing, session isolation, and cryptographic protections are proposed to limit the scope and impact of agent actions. These controls significantly reduce exploitability but add execution overhead, constrain flexibility, and require careful configuration. Existing evaluations largely focus on isolated agents and short tasks, whereas deployed systems involve long-running workflows, shared infrastructure, and multiple users. An open problem is how to enforce robust system-level protections that constrain agent behavior in dynamic environments without undermining planning and autonomy.

6.3 Prompt Injection and Tool Invocation Risks

Recent work treats prompt injection and unsafe tool invocation as a shared system risk that grows with agent autonomy. Studies show that malicious prompts and untrusted external data can override goals and redirect behavior, especially when agents perform multi step tasks, call tools, and coordinate with other agents [24, 37]. Database connected agents face additional exposure because crafted inputs can lead to unsafe queries and data leakage through tool pipelines [23, 76]. Hybrid attacks combine prompt injection with web vulnerabilities such as cross site scripting and request forgery, which bypass both AI guardrails and application defenses [100]. Other work shows that semantic prompt injections can be hidden in multimodal or symbolic content, which limits the effectiveness of static filters [113]. Benchmarks and red teaming systems show that agents fail under indirect or human written attacks even when base model performance appears strong, which points to weaknesses in orchestration and input handling [41, 164]. Multi agent defenses that separate sanitization and policy enforcement reduce successful injections when roles and scopes are clearly defined [52].

Tool and API access amplifies these risks because agents query data, call services, and execute actions through shared interfaces. Weak authentication, broad scopes, or poor rate limits allow attackers to escalate privileges through agent workflows [24]. When agents generate SQL, malicious prompts or retrieved content can steer unsafe query construction,

6.2 代理 AI 的系統層漏洞與安全控制

近期研究顯示，代理式 AI 系統會引入靜態語言模型中不會出現的系統層面漏洞，因為代理會維持狀態、執行工具，並跨會話運作。He 等人 [61] 從系統安全角度分析這些風險，並識別出三大主要漏洞類別。首先，多用戶環境中的會話管理失敗會透過資料洩漏、行為歸屬錯誤及服務拒絕等機制，導致保密性與完整性違規。其次，當微調或持久化記憶允許投毒、非預期資料保留或跨用戶資訊洩露時，會引發模型污染與隱私洩漏。第三，可執行代理程式會因缺乏足夠隔離而允許任意程式碼執行、資源濫用及代理劫持，從而擴大攻擊面；當模型生成的動作被執行時，此風險尤為顯著。基於 Bash 的代理實驗顯示，若未使用沙箱，超過 75% 的惡意命令能成功執行；而容器式沙箱則能阻擋幾乎所有此类命令，這證明風險在於代理運行時，而非僅限於模型本身。

Chakrabarty 等人 [26] 檢視了涵蓋訓練與推論的更廣泛對抗性攻擊類別，包括規避、投毒、隱私提取，以及針對代理的特定攻擊（如目標劫持與提示操作）。與 He 等人對組件層級的關注不同，本研究強調操作層面的影響，包括權限提升、未經授權存取、系統效能下降以及信任流失。所提出的防禦措施強調持續威脅偵測、自動化事件回應、基於歷史與即時訊號的預測性防禦，以及基於風險的漏洞管理，反映出一種更具操作導向的威脅模型。

在這項研究中，安全控制被框定為針對代理規劃、記憶和工具執行所引入的漏洞的緩解措施。ReAct 和思維樹等規劃框架透過多步驟推理和具影響力的工具使用來提升能力，但也因引入具有副作用的中介動作而擴大攻擊面 [61]。為降低由此產生的風險，系統層面的控制措施（如沙箱、會話隔離和加密保護）被提出，以限制代理行動的範圍與影響。這些控制措施雖能顯著降低被利用的可能性，但也增加了執行負載、限制了靈活性，且需要謹慎配置。現有的評估大多聚焦於孤立的代理和短期任務，而實際部署的系統則涉及長期運行的工作流、共享基礎設施和多用戶環境。一個待解決的問題是：如何在動態環境中強制執行堅固的系統層面保護以約束代理行為，同時又不損害規劃能力和自主性。

6.3 提示詞注入與工具調用風險

近期研究將提示注入與不安全工具調用視為隨代理自主性增加而增長的共享系統風險。研究顯示，惡意提示與不可信的外部數據可能覆蓋目標並重導行為，尤其在代理執行多步驟任務、調用工具及與其他代理協作時 [24, 37]。連接數據庫的代理面臨額外風險，因為精心設計的輸入可能導致不安全查詢及透過工具管道造成數據洩漏 [23, 76]。混合攻擊結合提示注入與網頁漏洞（如跨站腳本注入與請求偽造），可繞過 AI 防護機制與應用層防禦 [100]。其他研究指出，語義提示注入可能隱藏在多模態或符號內容中，這限制了靜態過濾器的有效性 [113]。基準測試與紅隊系統顯示，即使基礎模型表現強勁，代理在間接或人類撰寫的攻擊下仍會失敗，這指向了調度與輸入處理方面的弱點 [41, 164]。將清洗與策略執行分離的多代理防禦機制，在角色與範圍明確定義時，能有效減少成功注入 [52]。

工具與 API 存取會放大這些風險，因為代理會透過共用介面查詢資料、呼叫服務並執行動作。若驗證薄弱、權限範圍過廣或速率限制不足，攻擊者便能透過代理工作流 [24] 提升權限。當代理生成 SQL 時，惡意提示或檢取的內容可能引導出不安全的查詢構建。

Table 6. Comparison of mitigation strategies for prompt injection and unsafe tool invocation in agentic AI systems.

Mitigation class	Primary protection mechanism	Documented limitations
Input sanitization and filtering	Blocks explicit or pattern-based prompt injections before execution	Ineffective against semantic, indirect, multimodal, or steganographic prompt injections that preserve benign surface meaning [100, 113]
Scoped credentials and least-privilege delegation	Limits the blast radius of compromised agents by restricting accessible tools and APIs	Does not prevent injected instructions from steering agents toward harmful actions that remain within allowed scopes [76]
Runtime monitoring and red teaming	Detects unsafe behavior during or after execution through logging, audits, and adversarial testing	Often post hoc and limited in detecting cascading failures across tools, APIs, and shared credentials [41, 164]
Intent-bound delegation	Cryptographically binds agent actions to authenticated intent and policy constraints	Depends on correct upstream intent specification and orchestration, and does not fully address compromised context or indirect prompt propagation [53, 118]

and effects can cascade across services that share tools or credentials [76, 118]. Frameworks such as SAGA shows that insecure mediation between agents and tools enables cascading compromise and motivate strict registration, policy checks, and trust controls at the orchestration layer [154]. Research shows that adversaries can target integration layers, including advertisement embedding attacks that influence model behavior through tampered channels [56]. Industry proposed delegated authority emphasize unified policy and intent scoping across heterogeneous APIs to limit overreach in multi tool workflows [103]. Operational risk also includes cost and availability because unbounded API usage can trigger runaway costs or denial of service through rate limit abuse and error handling manipulation [6]. Broad tool access improves flexibility and task completion but increases the blast radius of a single injection, while narrow scopes and strict delegation reduce exposure at the cost of autonomy and overhead. Delegation mechanisms such as Agentic JWT bind actions to authenticated intent and reduce escalation once injected instructions reach the action layer [53].

Across those works, prompt injection appears as both an input validation problem and an authority and orchestration problem, where untrusted content steers tool calls and propagates across systems [23, 37, 118]. Layered mitigations such as input sanitization, scoped credentials, runtime monitoring, and intent-bound delegation improve resilience by addressing different points in the prompt-to-action pipeline, but each leaves distinct gaps [23, 37, 118]. Sanitization and filtering reduce obvious injections but fail against semantic, multimodal, or steganographic attacks that preserve benign surface meaning [100, 113]. Scoped credentials and least-privilege delegation limit blast radius after compromise, yet do not prevent injected instructions from steering agents toward permitted but harmful actions [53, 76]. Runtime monitoring and red-teaming benchmarks detect failures post hoc, but often miss cascading effects across tools, APIs, and shared credentials [41, 164]. As a result, current defenses mitigate individual failure modes but do not fully prevent cross-tool propagation, authority escalation through allowed scopes, or indirect prompt injection via external content. An open problem is how to compose these controls so that intent, permissions, and execution context remain consistently bound across heterogeneous services without suppressing agent utility [53, 118]. Table 6 summarizes how common mitigation classes address prompt injection and tool-invocation risks, and where residual gaps remain. Many benchmarks evaluate isolated injection paths and do not measure cascading failures across APIs, databases, and services [41, 164]. Many defenses also assume cooperative environments and weaken under adaptive attackers who exploit cross service interactions [100, 154]. An open problem is how to bind agent intent, tool permissions, and execution context so injected instructions cannot propagate across tools and services while agents remain effective in open and dynamic environments [53, 118].

6.4 Multi-Agent Security, Collusion, and Information Flow

Recent work shows that multi-agent systems introduce security risks that arise from coordination and shared resources rather than isolated agent failures. Khan et al. show that when agents share memory, databases, execution privileges, or

表 6。針對代理 AI 系統中的提示注入與不安全工具調用的緩解策略比較。

緩解類別	主要保護機制	文檔中列出的限制
輸入資料清洗與過濾ing	Blocks 明確或基於模式的提示注入 - 執行前的動作	對語義、間接、多模態或隱形無關。保留良性表面意義的圖形提示注入 [100, 113]
封裝憑證和最少權限授權	限制受感染代理的爆炸半徑，透過限制可存取的工具與 API 來達成	無法防止注入的指令引導代理朝向仍處於允許範圍內的有害行為 [76]
運行時監控與紅隊測試	偵測執行期間或執行後的不安全行為，透過記錄、審計與對抗性測試	經常事後分析，且難以檢測跨工具、API 及共用憑證的連鎖故障 [41, 164]
意圖綁定授權	以加密方式將代理行動與經過驗證的意圖及策略限制綁定	取決於正確的上游意圖規範和或弦理，且未完全解決被篡改的上下文或間接提示注入 [53, 118]

影響可能跨服務蔓延，這些服務共享工具或憑證 [76, 118]。SAGA 等框架顯示，代理與工具之間的不安全中介會導致連鎖式攻陷，並促使在調度層實施嚴格的註冊、政策檢查與信任控制 [154]。研究顯示，攻擊者可能針對整合層進行攻擊，包括透過篡改通道影響模型行為的廣告嵌入攻擊 [56]。業界提出的「授權委託」強調在異質 API 之間統一政策與意圖範圍，以限制多工具工作流中的過度權限 [103]。營運風險也包含成本與可用性，因為無限制的 API 使用可能引發 runaway 成本，或透過速率限制濫用與錯誤處理操縱導致服務中斷 [6]。廣泛的工具存取雖提升靈活性與任務完成度，但也增加單一注入的衝擊範圍；而狹窄的權限範圍與嚴格的授權委託則能降低風險，但會犧牲自主性並增加負擔。授權機制（如 Agentic JWT）將行動綁定至經過驗證的意圖，並能在注入指令到達行動層後降低權限提升風險 [53]。

在這些工作中，提示注入既呈現為輸入驗證問題，也呈現為權限與調度問題，其中不可信內容引導工具調用並在系統間傳播 [23, 37, 118]。分層緩解措施，如輸入清洗、範圍限制憑證、運行時監控及意圖綁定委託，透過針對提示到行動管道的不同節點來提升韌性，但每種方法都留下特定缺口 [23, 37, 118]。清洗與過濾能減少明顯的注入，卻無法抵禦保留良性表面意義的語義、多模態或隱形攻擊 [100, 113]。範圍限制憑證與最小權限委託能限制被攻破後的影響範圍，卻無法防止注入指令引導代理朝向被允許但有害的行動 [53, 76]。運行時監控與紅隊測試基準能事後檢測失敗，卻常遺漏跨工具、API 及共享憑證的連鎖效應 [41, 164]。因此，當前的防禦措施雖能緩解個別失敗模式，卻無法完全防止跨工具傳播、透過允許範圍的權限提升，或透過外部內容的間接提示注入。一個開放性問題是：如何組合這些控制措施，使意圖、權限與執行上下文在異質服務間保持一致綁定，同時不抑制代理的效用 [53, 118]。表 6 總結了常見緩解類別如何應對提示注入與工具調用風險，以及殘留的缺口。許多基準評估的是孤立的注入路徑，並未測量跨 API、資料庫與服務的連鎖失敗 [41, 164]。許多防禦措施也假設協作環境，在面對利用跨服務互動的適應性攻擊者時會變弱 [100, 154]。另一個開放性問題是：如何綁定代理意圖、工具權限與執行上下文，使注入指令無法跨工具與服務傳播，同時讓代理在開放且動態的環境中保持有效性 [53, 118]。

6.4 多智能體安全、串謀與資訊流動

近期研究顯示，多代理系統所引入的安全風險，源自於協調與共享資源，而非單一代理的失敗。Khan 等人指出，當代理共享記憶、資料庫、執行權限或

delegated tasks, a single compromised agent can repeatedly trigger harmful actions across the system even without explicit coordination logic encoded in the agent policies or control flow [76]. In this setting, emergent collusion arises from shared state and privileges rather than from agents explicitly negotiating or planning jointly. This differs from single-agent settings, where damage is often confined to one execution context. Analyses of steganographic collusion further show that agents can exchange hidden signals through benign-looking messages, enabling covert coordination without violating surface-level policies [107]. Shared state, messaging channels, and task delegation therefore create attack surfaces that grow with the number of interacting agents.

Approaches to defense take two broad directions, which differ in where security enforcement is applied. Reasoning-based defenses focus on agent-level cognition and interaction. PeerGuard applies cross-agent auditing and mutual reasoning to expose backdoors or anomalous behavior during deliberation [44], while adversarial debate and voting mechanisms require agents to justify conclusions before action, reducing error propagation and hallucinations at the cost of additional communication and reasoning overhead [169]. Infrastructure-oriented defenses instead monitor coordination and information flow independently of agent reasoning. GUARDIAN models inter-agent interactions as temporal graphs and flags unsafe collaboration patterns such as escalation or collusion [184]. SentinelAgent applies graph-based anomaly detection to communication flows to identify covert leakage paths and unauthorized tool use [60]. Compared with reasoning-based methods, infrastructure-oriented approaches improve detection coverage and do not assume cooperative agents, but incur monitoring and computational overhead and may reduce responsiveness.

Other approaches embed security directly into coordination and information flow. BlockA2A secures agent-to-agent communication using decentralized identity, blockchain-anchored audit logs, and smart contracts, enabling accountability and revocation across heterogeneous agents [187]. SAFEFLOW enforces provenance, integrity, and confidentiality through trust labels that constrain how data may influence reasoning or tool use [92]. Safeguard integrates reference monitors into multi-agent workflows to block information leaks during dialogue turns or tool invocation [35]. The term multi-agent security tax refers to the empirically observed tradeoff in which stronger coordination controls and monitoring reduce harmful behavior but also degrade collaboration efficiency and task performance [123]. Existing defenses are often evaluated in controlled settings and assume partially trusted agents or static interaction patterns [137]. An open problem is how to enforce secure coordination and information flow at scale while preserving collaboration efficiency without assuming trusted agents or tightly controlled messaging channels.

6.5 Autonomy, Identity, Governance, and Resources

6.5.1 Autonomy, Access Control, and Execution Boundaries. Risk rises sharply when agents gain direct authority over sensitive actions. Khan et al. show database-connected agents amplify failure impact by concentrating broad read and write privileges within a single agent runtime or credential scope, allowing a compromised agent to directly modify or exfiltrate shared data stores subsequently trusted by downstream systems and processes [76]. In contrast, Deng et al. present hierarchical access models, where agents operate under task-specific and role-bounded privileges with enforced separation between planning, querying, and execution, reducing the impact of prompt injection and goal manipulation by limiting what an agent can execute [37]. These results show that execution boundaries shape the scale of failure.

Design choices around autonomy further affect security outcomes. Knack and Burke argue that only task or conditional autonomy is suitable for autonomous cyber defense, since unrestricted autonomy can cause unintended disruption even during defensive actions [80]. Systems that grant greater autonomy instead rely on continuous monitoring and predictive risk assessment to intervene early, which improves responsiveness but assumes timely detection [124]. Higher autonomy improves speed and coverage, while bounded autonomy limits blast radius at the cost of adaptability.

委託任務中，單一被攻陷的代理即使未在其策略或控制流程中編碼明確的協調邏輯 [76]，也能反覆觸發系統內的有害行為。在此情境下，突發的合謀源於共享狀態與權限，而非代理之間明確協商或共同規劃。這與單一代理設定不同，後者造成的損害通常僅限於單一執行上下文。對隱形合謀的分析進一步顯示，代理可透過看似無害的訊息交換隱藏信號，從而實現隱蔽協調而不違反表面層次的政策 [107]。因此，共享狀態、訊息通道與任務委託共同構成了攻擊面，且隨著互動代理數量的增加而擴大。

防禦方法主要分為兩大方向，其差異在於安全執行的應用位置。基於推理的防禦方法聚焦於代理層級的認知與互動。PeerGuard 應用跨代理審計與相互推理，以在 deliberation [44], 期間揭露後門或異常行為；而對抗性辯論與投票機制則要求代理在行動前證明結論，從而減少錯誤傳播與幻覺，但需付出額外的溝通與推理成本 [169]。基礎設施導向的防禦方法則獨立於代理推理，監控協調與資訊流動。GUARDIAN 將代理間互動建模為時間序列圖，並標記不安全合作模式，如升級或合謀 [184]。SentinelAgent 應用基於圖的異常檢測技術於通訊流，以識別隱蔽洩漏路徑與未經授權的工具使用 [60]。與基於推理的方法相比，基礎設施導向的方法提升了檢測覆蓋率，且不假設合作代理，但會產生監控與計算負擔，並可能降低響應速度。

其他方法將安全性直接嵌入協調與資訊流動中。BlockA2A 利用分散式身分、區塊鏈錨定的審計日誌與智能合約，來保障代理間的通訊，使異質代理間能實現責任歸屬與撤銷機制 [187]。SAFEFLOW 透過信任標籤強制執行來源可追溯性、完整性與機密性，限制資料如何影響推理或工具使用 [92]。Safeguard 將參考監控整合至多代理工作流中，以阻擋對話輪次或工具呼叫期間的資訊洩漏 [35]。「多代理安全稅」一詞，指實證觀察到的權衡現象：較強的協調控制與監控雖能減少有害行為，但也會降低協作效率與任務表現 [123]。現有的防禦機制常於受控環境下評估，並假設部分受信任的代理或靜態互動模式 [137]。一個開放性的問題是：如何在不假設受信任代理或嚴格管控的訊息通道的前提下，於大規模環境中強制執行安全的協調與資訊流動，同時維持協作效率。

6.5 自主性、身份、治理與資源

6.5.1 **自主性、訪問控制與執行邊界。當代理獲得對**
敏感操作。Khan 等人顯示，與資料庫連接的代理會透過集中廣泛的讀取和
在同一個代理執行時或憑證範圍內的寫入權限，允許受感染的代理直接修改或
隨後洩漏被下游系統和流程信任的共享數據庫 [76]。相比之下，Deng 等人提出了分層訪問模型，其中代理在任務特定和角色限定的權限下運行，並實施規劃、查詢和執行之間的強制隔離，從而降低提示注入和目標操縱的影響。
透過限制代理所能執行的 [37]。這些結果顯示，執行邊界塑造了失敗的規模。

關於自主性的設計選擇進一步影響安全結果。Knack 和 Burke 認為，只有任務或條件自主性適合用於自主網路防禦，因為不受限制的自主性即使在防禦行動中也可能造成意外中斷 [80]。授予更大自主性的系統則依賴持續監控和預測風險評估來早期介入，這提高了回應速度，但假設能及時偵測 [124]。更高的自主性提升了速度和覆蓋範圍，而有邊界的自主性則以犧牲靈活性為代價來限制影響範圍。

Autonomy also introduces governance constraints that affect execution safety. When agents act without explainable decision paths or explicit refusal mechanisms, failures propagate quickly and are hard to attribute. This is critical for dual use actions such as network scanning, exploit generation, or data exfiltration, where requests may be legitimate in defensive contexts but harmful at scale [176]. Recent work stresses that agents must refuse unsafe or ambiguous requests and escalate uncertain cases for human review [153]. These safeguards improve accountability and reduce misuse, but they constrain flexibility and increase reliance on human oversight. Current deployments therefore favor restricted autonomy, and a key open problem is how to expand agent authority while providing verifiable guarantees that execution boundaries will hold as agents adapt and coordinate.

6.5.2 Identity, Trust, and Registry Mechanisms. Recent work agrees that static credentials and long lived API keys are not sufficient once agents operate autonomously across systems. The Cloud Security Alliance treats identity as a core control plane and calls for cryptographically verifiable agent identities with lifecycle management and explicit trust anchors [31]. This led to both protocol level proposals and enterprise deployments that extend identity beyond authentication toward attribution and control.

Direct integration between agents and data systems complicates governance and compliance. Khan et al. show that database connected agents often lack complete audit trails for agent initiated queries, which creates challenges under GDPR and CCPA [76]. Incomplete provenance weakens accountability and increases the risk of unauthorized data exposure, bias amplification, and non transparent decision making. These findings show that identity mechanisms must support auditability in addition to authentication. Privacy preserving identity systems limit disclosure but can weaken accountability when actions cannot be fully reconstructed, while governance oriented approaches emphasize logging, traceability, and policy enforcement at the cost of operational overhead and data retention risk.

Designs diverge across decentralized, registry based, and enterprise approaches. Decentralized systems such as LOKA and Aegis use decentralized identifiers, verifiable credentials, and cryptographic techniques to bind identity, intent, and reputation [5, 127]. Registry oriented systems such as the Agent Name Service and the NANDA Index support discovery, resolution, trust scoring, and revocation at scale [67, 128]. Enterprise designs from Okta, Strata, Cisco, and Spirl extend existing IAM and workload identity models to agents to improve deployability [29, 117, 148, 150]. These approaches expose tradeoffs between decentralization and deployability, and between privacy and accountability, as reflected in frameworks such as DIRF, zero trust identity, GaaS, and TRiSM [32, 51, 68, 130]. National and sector proposals, such as autonomy passports and enterprise AI registries, further emphasize accountability and emergency control [88, 101, 110]. A key limitation is that most systems are evaluated in pilots rather than under sustained adversarial pressure, and identity alone does not prevent misuse when execution boundaries are weak. An open problem is how to align cryptographic identity, scalable registries, and continuous trust scoring with real time enforcement without imposing prohibitive latency or operational burden in large multi agent systems.

6.5.3 Resource Abuse and Denial of Service. Recent work shows that denial of service in agentic systems often arises from cost amplification rather than request volume. Safeguard abuse and Consuming Resources via Auto-generation under Black-box Settings (CRABS)-style attacks demonstrate that malicious prompts can trigger excessive token generation, long reasoning chains, and repeated tool calls, which degrade service even at low concurrency [180, 183]. CRABS exploits the tendency of LLM-based agents to autonomously expand reasoning and generation when given adversarial but syntactically valid inputs, leading to sustained resource consumption without triggering traditional rate-based defenses [183]. Concurrency focused studies identify a related failure mode in which parallel agent execution exhausts compute and tokens through coordinated workloads [18]. These mechanisms differ from traditional API denial of

自主性也引入了影響執行安全的治理約束。當代理在缺乏可解釋決策路徑或明確拒絕機制的情況下行動時，失敗會迅速傳播且難以歸因。這對於雙用途行動（如網路掃描、漏洞生成或資料洩漏）尤為關鍵，因為這些請求在防禦情境下可能合法，但在大規模下卻具危害性 [176]。近期研究強調，代理必須拒絕不安全或模糊的請求，並將不確定案例升級供人類審查 [153]。這些保障措施提升了責任歸屬並減少濫用，但也限制了靈活性並增加對人類監督的依賴。因此，目前的部署傾向於採用受限的自主性，而一個關鍵的開放性問題在於：如何在擴展代理權限的同時，提供可驗證的保證，確保當代理適應並協作時，執行邊界仍能維持。

6.5.2 身份、信任與註冊機制。近期研究一致認為，一旦代理在系統間自主運行，靜態憑證與長效 API 金鑰已不足夠。雲端安全聯盟將身份視為核心控制平面，並呼籲採用具有生命週期管理與明確信任錨點的加密可驗證代理身份 [31]。這促使產生了協議層面的提案與企業部署方案，將身份管理從驗證擴展至歸屬與控制。

代理與資料系統之間的直接整合使治理與合規變得複雜。Khan 等人指出，與資料庫連接的代理通常缺乏針對代理發起查詢的完整審計軌跡，這在 GDPR 和 CCPA 下構成了挑戰 [76]。不完整的來源追溯削弱了責任歸屬，並增加了未經授權資料洩漏、偏誤放大以及決策不透明等風險。這些發現顯示，身份機制不僅需支援身份驗證，還必須支援可審計性。隱私保護型身份系統雖能限制資料揭露，但若無法完整重建行動，則可能削弱責任歸屬；而治理導向的方法則強調日誌記錄、可追蹤性及政策執行，但會以增加營運負擔與資料保留風險為代價。

設計方案分散於去中心化、基於註冊表及企業級方法中。去中心化系統（如 LOKA 與 Aegis）利用去中心化識別符、可驗證憑證及加密技術，將身份、意圖與聲譽綁定 [5, 127]。以註冊表為導向的系統（如 Agent Name Service 與 NANDA Index）支援大規模的發現、解析、信任評分與撤銷 [67, 128]。來自 Okta、Strata、Cisco 與 Spirl 的企業級設計將現有的身份驗證（IAM）與工作負載身份模型擴展至代理，以提升部署性 [29, 117, 148, 150]。這些方法揭示了去中心化與部署性之間、以及隱私與責任之間的權衡，正如 DIRF、零信任身份、GaaS 與 TRiSM 等框架所反映 [32, 51, 68, 130]。國家與行業提案（如自主權護照與企業 AI 註冊表）進一步強調了責任與緊急控制 [88, 101, 110]。一個關鍵限制是，大多數系統僅在試點階段進行評估，而非在持續的敵對壓力下測試，且當執行邊界薄弱時，僅憑身份無法防止濫用。另一項開放性問題是：如何在大型多代理系統中，將加密身份、可擴展註冊表與持續信任評分與即時執行對齊，同時避免施加過高的延遲或運營負擔。

6.5.3 資源濫用與服務拒絕。近期研究顯示，代理系統中的服務拒絕攻擊常源於成本放大，而非請求量。在「黑盒設定」下透過自動生成進行資源濫用與消耗（CRABS 風格）的攻擊證明，惡意提示詞可引發過度的 token 生成、長推理鏈及重複的工具調用，即使在低併發情況下也會導致服務退化 [180, 183]。CRABS 利用基於 LLM 的代理在收到對抗性但語法有效的輸入時，傾向於自主擴展推理與生成的特性，從而導致持續的資源消耗，卻無法觸發傳統的基於速率的防禦機制 [183]。專注於併發的研究識別出一種相關失敗模式，即並行代理執行透過協調的工作負載耗盡計算資源與 token [18]。這些機制與傳統的 API 服務拒絕不同。

service, which is primarily rate based. Defenses follow two main strategies. Execution time controls intervention during reasoning. Reasoning gates impose asymmetric cost on abusive behavior but add latency to benign tasks [86]. Circuit breakers halt runaway generations to preserve availability but sacrifice task completion [186]. Resource management approaches regulate consumption. Adaptive budgeting and dynamic quotas track tokens, runtime, and API calls and apply throttling or termination when limits are exceeded [12, 48, 112, 149, 166]. These methods improve availability but reduce output quality and require careful tuning.

Identity bound delegation strengthens control by tying quotas and revocation to authenticated principals, to improve accountability but increases management overhead [147]. System architecture also shapes exposure. Function calling and context management designs influence escalation paths and determine how failures propagate across workflows [50]. Industry deployments combine agent aware throttling with traditional API security and DDoS protection [6, 105]. Existing defenses reduce impact but remain reactive and workload specific. An open problem is to coordinate budgeting and throttling across agents, tools, and tasks without imposing brittle limits or undermining useful autonomy.

6.6 Assurance, Testing, and Infrastructure

Assurance for agentic AI is difficult as agents operate in dynamic environments and expand their action space over time, which makes static benchmarks insufficient. Cyberwheel addresses this challenge by providing a high fidelity simulation and emulation pipeline with repeatability and transfer across environments [115]. ARCeR approaches assurance through automated cyber range construction using multi agent retrieval and orchestration, which lowers setup cost and increases scenario coverage but depends on the quality of retrieved knowledge and automated configuration [97]. Atir argues that both approaches require sustained national investment to support realistic testing under policy and governance constraints [15]. Together, these systems reflect a tradeoff between experimental control and rapid scenario generation.

Policy analyses argue that these assurance challenges arise because agentic AI increasingly functions as shared digital infrastructure that supports enterprise, defense, and public sector workflows [15]. Under this view, assurance cannot rely on one time validation or organization specific practices. It instead requires shared testing infrastructure, continuous evaluation, and governance mechanisms that operate across institutional boundaries. Red teaming supports this goal by introducing adaptive adversaries that probe reasoning, coordination, and tool use. Coalition frameworks integrate iterative red blue simulations throughout development, while Tallam frames this process as adaptive engagement in which attackers and defenders co evolve [96, 155]. These methods improve realism but reduce comparability because outcomes depend on evolving adversary behavior. Knack and Burke emphasize that such testing must align with explicit authorization boundaries, with autonomy levels matched to legal and organizational risk tolerance [80]. Infrastructure choices further shape assurance outcomes. High performance computing enables large scale multi agent simulation and rapid response but introduces risks such as workload poisoning, side channels, and cross tenant leakage [72]. Current testbeds also abstract human oversight delays and long term learning effects. An open problem is how to standardize assurance signals so results remain comparable across platforms as agents and environments evolve.

6.7 Reasoning, Memory, and Human Factors

6.7.1 Reasoning Manipulation and Memory Integrity. Agentic attacks increasingly target internal reasoning rather than surface prompts. Agent Security Bench and UDora show that attackers can hijack reasoning traces during execution and redirect multi-step planning toward malicious goals, even when inputs appear benign [177, 179]. Action hijacking analyses further show that small and silent changes in reasoning can shift agent behavior, while full takeover demonstrations confirm that reasoning level exploits can lead to complete loss of control [98, 182]. Since these attacks

服務主要基於速率控制。防禦策略主要有兩種。執行時間控制會在推理過程中進行干預。推理閘門對惡意行為施加不對稱的成本，但會增加良性任務的延遲 [86]。電路斷路器會中止失控的生成以維持可用性，但會犧牲任務完成 [186]。資源管理方法用於規範消耗。適應性預算和動態配額會追蹤 token、運算時間和 API 呼叫，並在超出限制時實施限流或終止 [12, 48, 112, 149, 166]。這些方法可提高可用性，但會降低輸出品質，且需要仔細調試。

身份綁定授權透過將配額與撤銷與經過驗證的主體綁定，強化了控制並改善責任歸屬，但也增加了管理成本 [147]。系統架構也影響暴露面。函數調用與上下文管理設計影響升級路徑，並決定失敗如何在工作流中傳播 [50]。產業部署結合了代理感知限流與傳統 API 安全及 DDoS 防護 [6, 105]。現有防禦措施可降低影響，但仍具反應性且特定於工作負載。一個開放性問題是：如何在代理、工具與任務之間協調預算與限流，而不施加脆弱限制或削弱有用的自主性。

6.6 保證、測試與基礎設施

代理型 AI 的驗證困難，因為代理在動態環境中運作，且隨著時間推移其行動空間不斷擴展，這使得靜態基準測試不足。Cyberwheel 透過提供具有高保真度、可重複性及跨環境 [115] 的模擬與模擬流程來應對此挑戰。ARCeR 透過利用多代理檢索與調度進行自動化網路範圍建構，來實現驗證，這降低了建置成本並提升了情境覆蓋率，但依賴於檢索知識的品質與自動化配置 [97]。Atir 認為，這兩種方法都需要持續的國家投資，以在政策與治理限制下支持真實的測試 [15]。這些系統共同反映了實驗控制與快速情境生成之間的權衡。

政策分析認為，這些保證挑戰的根源在於代理型 AI 日益成為支撐企業、國防及公共部門工作流程的共享數位基礎設施 [15]。在此觀點下，保證無法依賴單一時間的驗證或組織特定的做法，反而需要共享的測試基礎設施、持續評估以及能跨越機構邊界的治理機制。紅隊測試透過引入適應性對手來探測推理、協調與工具使用能力，從而支持此目標。聯盟框架將迭代紅藍模擬整合至開發全過程，而 Tallam 則將此過程定義為適應性參與，其中攻擊者與防禦者共同演化 [96, 155]。這些方法雖提升了真實性，卻降低了可比性，因為結果取決於不斷變化的對手行為。Knack 與 Burke 強調，此類測試必須與明確的授權邊界對齊，且自主權等級需與法律及組織的風險容忍度相匹配 [80]。基礎設施選擇亦進一步影響保證結果。高性能計算雖能支援大規模多代理模擬與快速反應，但也引入了工作負載投毒、側信道洩漏及跨租戶洩漏等風險 [72]。現有的測試環境也抽象化了人類監督的延遲與長期學習效應。一個待解決的問題是：如何標準化保證信號，以便在代理與環境演化的過程中，結果仍能保持跨平台的可比性。

6.7 推理、記憶與人類因素

6.7.1 推理操控與記憶完整性。代理攻擊越來越針對內部推理而非表面提示。Agent Security Bench 與 UDora 顯示，攻擊者可在執行期間劫持推理軌跡，並將多步驟規劃轉向惡意目標，即使輸入看似無害 [177, 179]。行動劫獲分析進一步顯示，推理中的微小且靜音變化即可改變代理行為，而完全接管演示則確認，推理層次的漏洞可利用導致完全失去控制 [98, 182]。由於這些攻擊

Table 7. Benchmarks and Evaluation Frameworks for Agentic AI Security

Benchmark / System	Purpose	Key Features	Limitations
BountyBench [176]	Tests real vulnerability lifecycles	Uses open source projects with known bug bounty issues. Measures detection, exploitation, and patching. Patching outperforms exploitation.	Manual setup. Limited coverage across domains.
ARCER [97]	Generates cyber ranges for training and evaluation	Multi agent RAG pipeline produces networks, red and blue scenarios, and evolving attack chains.	Fidelity depends on generated ranges.
RedTeamLLM [27]	Benchmarks autonomous red team agents	Tests reconnaissance, exploitation, and privilege escalation. Uses structured evaluation with tool use.	Narrow focus on penetration testing.
FinGAIA [175]	Evaluates multi step financial agents	Contains 407 tasks across seven finance domains. Tests reasoning, tool use, and regulated workflows.	Not a security benchmark but relevant for high risk sectors.
Agent Security Studies [61]	Tests system level vulnerabilities	Evaluates sandboxing, session pollution, and malicious command execution. Shows unsandboxed agents execute most harmful actions.	Not a complete benchmark suite.
Cyber Ranges (CyberBattleSim, CybORG++, cyber gyms) [91]	Tests multi agent defense and red–blue training	Supports repeatable adversarial experiments under controlled conditions.	Abstraction gaps and limited scalability.
WASP [41]	Probes web agent robustness	Uses human written attacks to expose weaknesses in common web agent tasks.	Focused on web settings only.
AGENTVIGIL [164]	Detects indirect prompt injection paths	Black box discovery of hidden injection channels.	Narrow scope.
Multi Agent Prompt Defenses [52]	Tests sanitizer and policy agents	Measures interaction level prompt defenses.	Does not test full system pipelines.

occur inside the decision loop, they bypass input focused defenses designed for prompt injection. Defensive approaches therefore emphasize transparency and control. Chain of thought monitoring and weak to strong supervision expose reasoning to support auditing and runtime detection [73, 83], while guided reasoning constrains planning with structured attack trees to improve deviation detection in penetration testing settings [109]. However, explicit reasoning improves auditability while exposing internal structure that attackers may exploit. Studies on embodied agents show that poisoned reasoning can trigger unsafe physical actions, which increases the impact of failures in cyber physical systems [70].

Persistent memory introduces a long lasting risk surface. Studies show that poisoned memory can influence future tasks long after the original attack ends [37, 60, 92]. Microsoft and OWASP classify persistent memory poisoning as a distinct class of risk because it links reasoning, action, and long term state [23, 118]. Encryption and access control reduce exposure but can degrade retrieval quality and limit adaptability. Current defenses rely on monitoring, constrained reasoning, and memory protection, yet they face limits from scalability, false positives, and unclear definitions of malicious reasoning. An open problem is how to verify reasoning integrity and memory correctness at runtime without exposing exploitable structure or imposing prohibitive overhead in long horizon and multi agent systems.

6.7.2 Human Agent Social Engineering, HRM, and Oversight. Agentic AI changes social engineering by enabling autonomous, adaptive, and persistent deception. Unlike traditional scams that rely on fixed scripts, agentic systems plan interactions, adjust tactics in real time, and sustain pressure across channels. Studies show that attacker and victim agents can simulate realistic recruitment and funding scams, while personality aware detectors such as SE OmniGuard reduce success rates but do not eliminate risk [87]. Similar capabilities appear in multimodal settings. Augmented reality agents adapt to visual and audio cues and achieve high compliance [22]. Automated spear phishing agents match human attacker performance in live studies, while voice enabled agents reproduce end to end phone scams [45, 62]. Web agents expand impersonation and PII harvesting by combining browsing, form filling, and account interaction [78]. Counteragent approaches can waste attacker resources, but provide deterrence rather than protection [20].

Governance failures often emerge through human agent interaction rather than technical compromise alone. In fraud detection and compliance workflows, agentic systems can overfit demographic attributes or produce outputs that auditors cannot validate, which raises fairness, explainability, and regulatory concerns [124]. Human in the loop

表 7。代理 AI 安全的基準測試與評估框架

基準 / 系統	目的	主要特點	限制
BountyBench [176]	測試真實漏洞生命週期 - cles	使用已知存在漏洞賞金計劃的開源專案。衡量偵測、利用與修復。修復優於利用。	手動設定。覆蓋範圍有限。跨領域。
ARCER [97]	生成用於訓練與評估的網路模擬環境	多代理 RAG 管道生成網絡、紅藍演練場景以及演進中的攻擊鏈。	忠誠度 取決於 生成範圍。
RedTeamLLM [27]	基準自主紅隊代理	測試偵測、利用與權限提升。使用結構化評估並結合工具使用。	專注於滲透測試。
FinGAIA [175]	評估多步驟財務代理	包含 407 項任務，涵蓋七大金融領域。測試推理能力、工具使用及受規管工作流。	非安全基準，但對高風險領域相關。
特工安全研究 [61]	測試系統級漏洞- ties	評估沙盒、會話污染及惡意命令執行的情況。顯示未受沙盒限制的代理會執行最有害的操作。	不是一套完整的基準測試套件。
賽博範圍 (CyberBattleSim, CybORG++，網格健身房） [91]	測試多代理防禦與紅藍訓練	支援在受控條件下進行可重複的對抗實驗。	抽象差距與有限的 scala- 能力。
WASP [41]	偵測網頁代理的韌性	使用人工撰寫的攻擊來揭露常見網頁代理任務的弱點。	僅專注於網頁設定。
AGENTVIGIL [164]	偵測間接提示注入路由路徑	黑盒發現隱藏的注入通道。	範圍狹窄。
多 代理人 提示 De- 防範 [52]	測試 清淨劑與政策代理	測量互動層級提示防禦。	未測試完整系統管道。

發生在決策迴路中時，它們會繞過針對提示注入設計的輸入聚焦防禦。因此，防禦方法強調透明度與控制。思維鏈監控與弱到強監督將推理過程暴露出來，以支持審計與運行時檢測 [73, 83], ；而引導推理則利用結構化攻擊樹約束規劃，以改善滲透測試環境中的偏離檢測 [109]。然而，明確的推理雖提升了可審計性，卻也暴露了內部結構，可能遭攻擊者利用。關於具身代理的研究顯示，被污染的推理可能觸發不安全的物理動作，這會增加在網際網路物理系統中失敗的影響 [70]。

持久化記憶引入了長期存在的風險面。研究顯示，被污染的記憶可在原始攻擊結束後很久仍影響未來任務 [37, 60, 92]。Microsoft 與 OWASP 將持久化記憶污染分類為獨立的風險類別，因為它連結了推理、行動與長期狀態 [23, 118]。加密與存取控制雖能降低暴露風險，但可能降低檢索品質並限制適應性。目前的防禦機制依賴監控、受限推理與記憶保護，卻面臨可擴展性、誤報率不明以及惡意推理定義不清等限制。一個開放性的問題是：如何在長時程與多代理系統中，於執行時驗證推理完整性與記憶正確性，同時不暴露可利用的結構或造成過高的負擔。

6.7.2 人工代理社會工程、人力資源管理與監督。代理式 AI 透過啟用自主、適應性且持續的欺騙，改變了社會工程的模式。與依賴固定腳本的傳統詐騙不同，代理系統會規劃互動、即時調整策略，並跨多個渠道維持壓力。研究顯示，攻擊者與受害者代理可模擬真實的徵才與募資詐騙，而具備人格意識的檢測器（如 SE OmniGuard）雖能降低成功機率，卻無法完全消除風險 [87]。類似能力亦見於多模態環境。增強現實代理能適應視覺與聽覺提示，並達成高合規率 [22]。自動化定向釣魚代理在實測中表現與人類攻擊者相當，而具備語音功能的代理則能完整重現電話詐騙 [45, 62]。網頁代理透過結合瀏覽、表單填寫與帳戶互動，擴大了偽裝與個人資訊蒐集 [78]。反代理方法雖可能浪費攻擊者資源，但能提供阻嚇而非保護 [20]。

治理失敗往往源於人類代理的互動，而非單純的技術妥協。在詐欺偵測與合規工作流中，代理系統可能過度擬合人口統計屬性，或產生審計員無法驗證的輸出，從而引發公平性、可解釋性及監管方面的擔憂 [124]。人在迴路

oversight and explainable reasoning therefore function as required controls rather than optional safeguards. Frameworks for responsible deployment emphasize augmentation over replacement, especially in high stakes settings [165]. Approval gates, legible records of reasoning and tool use, and escalation for ambiguous cases improve accountability but reduce throughput and scalability. This tradeoff is inherent. Stronger oversight improves trust and compliance, while weaker oversight increases speed at the cost of error amplification. These capabilities reshape human risk management.

Agents perform actions once controlled by humans, including browsing, opening messages, downloading files, and submitting credentials, which expands social engineering risk beyond human only workflows [24]. HRM frameworks shift from user focused models to joint human agent monitoring. Automated detection evaluates agent and human behavior, while interventions include adaptive policy enforcement and targeted awareness for users interacting frequently with agents [24]. Compared with training based defenses, HRM improves coverage but introduces privacy concerns, operational overhead, and reliance on continuous telemetry. Oversight becomes critical when agents invoke tools or generate code. Governance frameworks emphasize human approval for high risk actions, attributable execution, interruptibility, and continuous monitoring [143, 155]. These controls improve accountability but can fail under high volume workflows. A key limitation is that most defenses rely on observable behavior and struggle with long horizon trust manipulation and cross channel coordination. An open problem is to detect intent drift and trust abuse early without constant human review that undermines the benefits of agentic automation.

Key Takeaways from Section 6

- Agentic AI expands the attack surface as agents hold state, call tools and APIs, and execute multi step workflows with limited oversight, raising risks such as data exfiltration, supply chain compromise, and emergent behavior.
- Policy work frames agentic AI as emerging critical infrastructure, so security must pair technical controls with governance and continuous defense cycles.
- Conceptual risk models organize failures across perception, reasoning, action, and memory, which motivates coordinated controls across layers instead of isolated mitigations.
- Frameworks extend this by adding domain risk categories and defense blueprints, autonomy levels, and coverage across orchestration and governance, but wider coverage increases integration cost.
- Concrete studies show system level vulnerabilities in database facing and tool executing agents, including weak audit trails, unsafe query generation, and high success rates of malicious commands without sandboxing, which shifts security focus to the agent runtime, memory, and tool interfaces.
- Prompt injection and unsafe tool invocation operate as authority and orchestration failures that can propagate through shared tools and credentials, so mitigations must combine sanitization, scoped permissions, runtime monitoring, and intent bound delegation.
- Multi agent systems add coordination risks such as covert signaling and cascading actions through shared state, which motivates both reasoning based checks and infrastructure monitoring of interaction patterns, plus secure communication and information flow control.
- Assurance depends on cyber ranges, simulation, and red teaming that reflect evolving threats and governance constraints, but testbeds abstract long horizon learning and human oversight delays.

6.8 Benchmarks for Agentic AI Security

Security evaluation for agentic AI requires benchmarks that test behavior under adversarial inputs, unsafe environments, and constrained defenses. General benchmarks do not capture failures such as prompt injection, unsafe tool use, or multi agent escalation. Some security focused benchmarks are developed, vary in scope, realism, and diagnostic ability.

監督與可解釋的推理因此作為必要控制措施，而非可選防護手段。負責任部署框架強調增強而非替換，特別是在高風險情境 [165]。審批閘門、可讀的推理與工具使用記錄，以及針對模糊案例的升級機制能提升責任歸屬，但會降低通量與可擴展性。此權衡是內生的。更強的監督能提升信任與合規性，而較弱的監督則以錯誤擴散為代價提升速度。這些能力正在重塑人類風險管理。

代理人執行由人類控制的動作，包括瀏覽、開啟訊息、下載檔案以及提交憑證，這將社會工程學風險擴展至僅限於人類的作業流程之外 [24]。人力資源管理（HRM）框架從以使用者為中心的模式轉向人類與代理共同監控的模式。自動化檢測評估代理人與人類的行為，而干預措施則包括適度的政策執行以及針對頻繁與代理人互動的使用者的定向意識提升 [24]。與基於訓練的防禦相比，HRM 雖能提升覆蓋率，但也引入了隱私疑慮、營運負擔以及對持續遙測的依賴。當代理人調用工具或生成程式碼時，監督變得至關重要。治理框架強調對高風險動作的人類核准、可歸因執行、可中斷性以及持續監控 [143, 155]。這些控制措施雖能提升責任歸屬，但在高體量作業流程下可能會失效。一項關鍵限制是，大多數防禦機制依賴可觀察的行為，難以應對長時程信任操縱與跨通道協調。另一項開放性問題是，如何在無需持續人類審查（這會削弱代理自動化的效益）的情況下，早期檢測意圖漂移與信任濫用。

第 6 節重點摘要

- 代理式 AI 擴大了攻擊面，因為代理會持狀態、調用工具和 API，並在有限監督下執行多步驟工作流，從而引發數據洩漏、供應鏈被入侵及突發行為等風險。
- 政策框架將代理式 AI 視為新興的關鍵基礎設施，因此安全必須結合技術控制與治理及持續防禦週期。

- 概念風險模型將失敗組織於感知、推理、行動與記憶等領域，這促使協調跨層次的控制，而非孤立的緩解措施。
- 框架通過增加領域風險類別和防禦藍圖、自主程度，以及涵蓋協調與治理的範圍來擴展此功能，但更廣泛的覆蓋範圍會增加整合成本。
- 具體研究顯示，資料庫前端與工具執行代理存在系統層面的漏洞，包括審計日誌薄弱、不安全查詢生成，以及未經沙箱隔離的惡意命令具有高成功率，這將安全重點轉移至代理運行時、記憶體與工具介面。

- 提示詞注入與不安全工具調用作為權限與協同失敗，可能透過共用工具與憑證擴散，因此緩解措施必須結合清洗、範圍限制權限、運行時監控與意圖綁定授權。

- 多智能體系統會引入協調風險，例如透過共享狀態產生的隱蔽信號與連鎖行動，這促使我們需要基於推理的檢查與互動模式的基礎設施監控，以及安全的通訊與資訊流控制。

- 保障依賴於模擬演練、紅隊測試等反映 evolving 威脅與治理限制的技術，但測試床抽象了長期學習與人工監督延遲。

6.8 智能體式 AI 安全基準測試

針對具代理能力的 AI 進行安全評估，需要測試其在惡意輸入、不安全環境及受限防禦下行為的基準。通用基準無法捕捉提示注入、不安全工具使用或多代理升級等失敗案例。部分專注於安全的基準已開發，但在範圍、真實性及診斷能力上各不相同。本文稿已提交至 ACM。

Existing benchmarks fall into three styles. System level benchmarks such as BountyBench and agent security studies evaluate end to end vulnerability lifecycles and economic impact in realistic settings, including exploitation, defense, and patching [61, 176]. Scenario driven frameworks such as ARCeR, RedTeamLLM, and cyber range based approaches generate adversarial environments that test planning, reasoning, and tool use under attack [27, 91, 97]. Domain specific benchmarks such as FinGAIA evaluate multi step agent behavior in regulated settings where correctness and compliance are central [175]. In contrast, focused benchmarks such as WASP, AgentVigil, and multi agent prompt defense suites probe narrow failure modes like indirect prompt injection or sanitizer bypass with high precision [41, 52, 164].

Table 7 summarizes these systems and their limitations. Across benchmarks, two recurring tradeoffs appear. One tradeoff is breadth versus diagnostic precision. Broad benchmarks capture lifecycle effects and cross layer interactions but are costly to maintain and hard to scale. Narrow benchmarks enable controlled comparison and reproducibility but miss how failures propagate across reasoning, tools, and agents. A second tradeoff is automation versus fidelity. Automated range generation and cyber gyms improve coverage and repeatability but rely on abstractions that can hide real world fragility. Manually curated systems better reflect practice but limit diversity and update speed. A shared limitation is weak coverage of adaptive adversaries, long horizon learning effects, and sustained multi agent coordination. An open problem is to integrate complementary benchmarks into shared evaluation protocols that remain reproducible, adversarial, and economically meaningful without imposing prohibitive setup cost or expert overhead.

7 Quantum Computing and Agentic AI in Cybersecurity

Quantum computing changes how autonomy, learning, and trust must be designed in agentic AI systems. Classical agentic AI assumes stable cryptography, classical computation, and predictable communication costs. Quantum computing weakens these assumptions at a structural level. Current research explores this interaction from three angles. These are quantum-native agents, quantum learning for security tasks, and quantum-resilient trust and governance. Each angle shows progress, but also exposes limits that prevent direct deployment in real cybersecurity systems.

7.1 Quantum Agents and Multi-Agent Autonomy

Research on quantum agents treats agency itself as a quantum process rather than a classical one. Sultanow et al. define quantum agents whose internal states evolve according to quantum mechanics instead of classical probability theory [152]. This changes how uncertainty is represented. A quantum agent can encode multiple potential decisions in superposition rather than selecting a single sampled action. This allows richer internal reasoning under uncertainty.

From an agentic AI perspective, this contribution is conceptual rather than operational. The model clarifies what autonomy could mean under quantum computation, but it does not specify how such agents interact with tools, external systems, or long-term memory. Cybersecurity agents must scan logs, call APIs, write reports, and coordinate with other agents. These activities require deterministic interfaces and persistent state. Quantum agent models do not yet explain how quantum reasoning maps onto these practical requirements.

Quantum multi-agent reinforcement learning shifts the focus from internal cognition to coordination. Here, QMARL denotes the broad class of quantum-enhanced multi-agent reinforcement learning methods, while eQMARL refers specifically to approaches that rely on quantum entanglement for inter-agent communication and coordination. Surveys by Yu and Zhao show that entanglement can reduce coordination overhead and mitigate non-stationarity in multi-agent learning [172]. eQMARL extends this idea by replacing classical communication with entangled quantum channels [38]. The reported gains include faster convergence and reduced reliance on centralized control. These results are relevant to cybersecurity because defensive agents often operate in distributed environments. Examples include coalition defense and federated detection. However, QMARL studies assume trusted agents and ideal communication. Cybersecurity

現有的評估基準可分為三種類型。系統層級的評估基準（如 BountyBench 與代理安全研究）在真實環境中評估端到端的漏洞生命週期及其經濟影響，涵蓋利用、防禦與修復 [61, 176]。情境驅動的框架（如 ARCeR、RedTeamLLM 及基於模擬戰場的途徑）會生成對抗性環境，以測試在攻擊下規劃、推理與工具使用的能力 [27, 91, 97]。領域特定的評估基準（如 FinGAIA）則評估多步驟代理行為，其核心在於受監管環境中的正確性與合規性 [175]。相對而言，專注型的評估基準（如 WASP、AgentVigil 及多代理提示防禦套件）則以高精準度探測狹窄的失效模式，例如間接提示注入或過濾器的繞過 [41, 52, 164]。

表 7 總結了這些系統及其限制。在各種基準測試中，出現兩種反覆出現的權衡。第一種權衡是廣度與診斷精確度之間的取捨。廣泛的基準測試能捕捉生命週期效應與跨層互動，但維護成本高昂且難以擴展。狹窄的基準測試則能實現受控比較與可重複性，卻無法反映失敗如何在推理、工具與代理之間傳播。第二種權衡是自動化與忠實度之間的取捨。自動化的範圍生成與賽道訓練能提升覆蓋率與可重複性，但依賴的抽象可能掩蓋真實世界的脆弱性。人工精心編製的系統更能反映實際做法，卻限制了多樣性與更新速度。共同的限制在於對適應性對抗者的覆蓋不足、長時限學習效應以及持續的多代理協調。一個開放性的問題是：如何將補償性的基準測試整合至共享的評估協議中，使其保持可重複、具對抗性且具經濟意義，同時避免過高的設置成本或專家負擔。

7 量子計算與代理式 AI 在網路安全領域的應用

量子計算改變了代理 AI 系統中自主性、學習與信任的設計方式。傳統代理 AI 假設加密穩定、計算為經典且通信成本可預測。量子計算在結構層面削弱了這些假設。當前研究從三個角度探討此互動：量子原生代理、用於安全任務的量子學習，以及抗量子信任與治理。每個角度都展現了進展，但也暴露了限制，使其無法直接部署於真實的網路安全系統中。

7.1 量子代理與多代理自主性

量子代理的研究將代理本身視為一個量子過程，而非經典過程。Sultanow 等人定義了量子代理，其內部狀態根據量子力學演化，而非經典概率理論 [152]。這改變了不確定性的表示方式。量子代理可以在疊態中編碼多個潛在決策，而非選擇單一採樣動作。這使得在不確定性下能夠進行更豐富的內部推理。

從代理 AI 的角度來看，這項貢獻是概念性的而非操作性的。該模型釐清了在量子計算下自主性可能意味著什麼，但並未說明這類代理如何與工具、外部系統或長期記憶互動。網路安全代理必須掃描日誌、呼叫 API、撰寫報告，並與其他代理協調。這些活動需要確定性介面和持久狀態。目前的量子代理模型尚未解釋量子推理如何映射到這些實際需求。

量子多智能體強化學習將焦點從內部認知轉向協調。在此，QMARL 指代廣泛的量子增強多智能體強化學習方法類別，而 eQMARL 則特指依賴量子糾纏進行智能體間溝通與協調的方法。Yu 和 Zhao 的調查顯示，糾纏可降低協調開銷並緩解多智能體學習中的非穩態性 [172]。eQMARL 通過用糾纏量子通道取代經典溝通來擴展這一想法 [38]。報告的改進包括更快的收斂速度和對集中式控制的依賴降低。這些結果對網絡安全相關，因為防禦性智能體通常在分佈式環境中運行。範例包括聯盟防禦和聯合檢測。然而，QMARL 研究假設智能體可信且通信理想。網絡安全

environments violate both assumptions. Agents may be compromised or impersonated. Once adversarial behavior is introduced, it is unclear whether entanglement improves robustness or creates new failure modes. The current literature does not analyze this tradeoff. Quantigence responds to this gap by proposing a framework for quantum security experimentation [8]. Its contribution lies in research infrastructure rather than algorithmic performance. It enables controlled study of quantum-enabled agents under security assumptions. This reflects an important shift. Before claiming quantum advantage, agentic AI requires testbeds that model compromise, deception, and trust failure. Quantigence identifies this need but does not yet provide empirical security outcomes.

7.2 Quantum Machine Learning for Security Analytics

A more mature body of work studies quantum machine learning for cybersecurity analytics. This research focuses on detection rather than autonomy. Bellante et al. evaluate quantum PCA for intrusion detection (ID) and show that quantum advantage depends on data structure, error tolerance, and hardware assumptions [21]. Their analysis demonstrates that classical methods remain competitive under realistic constraints. Experimental analyses extend this evaluation to real quantum hardware. Nagy et al. test several quantum models for ID on IBM and IonQ platforms [108]. These results confirm feasibility, but also reveal strong sensitivity to noise and limited scalability. Quantum generative approaches like quantum GAN based ID further show that hybrid quantum–classical pipelines are possible [28].

From an agentic AI perspective, these advances address only part of the problem. Autonomous agents depend on detection modules, but detection alone does not define agency. Agents must decide when to escalate, how to respond, and how to update internal state. Existing QML studies evaluate classifiers in isolation. They do not measure planning latency, decision stability, or downstream effects on autonomous response.

Frameworks such as QuantumNetSec and broader surveys of quantum machine learning for cybersecurity explicitly acknowledge these limitations [3, 134]. They position quantum learning as an enabling component rather than a complete system. This framing is appropriate, but it leaves an open issue. It remains unclear whether quantum learning improves overall agent performance once coordination, governance, and cost constraints are included.

7.3 Quantum-Resilient Trust, Identity, and Governance

The most immediate intersection between quantum computing and agentic AI lies in cryptographic trust. Agentic systems are persistent by design. They store memory, credentials, and decision histories over long time horizons. This makes them especially vulnerable to harvest-now decrypt-later attacks once quantum adversaries become practical [30, 77].

Industry and policy analyses emphasize that agentic AI amplifies cryptographic risk because agents act without human supervision [63]. Non-human identities, delegated authority, and autonomous credentials introduce failure modes that do not exist in user-driven systems. Several analyses argue that quantum-resistant cryptography must be embedded early rather than retrofitted later [75, 106]. Academic engagement remains limited. The Aegis Protocol is a notable exception [5]. It proposes embedding security controls directly into agent workflows. This is a structural insight. Security is treated as part of agency rather than as an external layer. However, the protocol does not fully specify how post-quantum cryptography interacts with agent memory updates, learning processes, or multi-agent coordination.

Foresight studies examining artificial intelligence, quantum computing, and cybersecurity at a societal scale reinforce this concern [81]. They anticipate convergence, but do not provide design-level guidance for autonomous systems. The unresolved issue is not whether quantum resistance is required. The issue is how to preserve agent autonomy, persistence, and coordination while cryptographic assumptions evolve. Most agentic AI frameworks assume stable cryptography. Most post-quantum cryptography research assumes short-lived or stateless clients. Autonomous agents violate both assumptions. Current literature does not yet resolve this mismatch.

環境違反了這兩個假設。代理可能被攻陷或被冒名頂替。一旦引入敵對行為，尚不清楚纠缠是否提升了魯棒性，還是創造了新的失效模式。現有的文獻並未分析此權衡關係。Quantigence 透過提出一個量子安全實驗框架 [8] 來回應此缺口。其貢獻在於研究基礎設施，而非演算法效能。它使我們能在安全假設下，對具備量子能力的代理進行受控研究。這反映了一項重要的轉變。在聲稱量子優勢之前，代理式人工智慧需要能模擬攻陷、欺騙與信任失效的測試環境。Quantigence 確立了這一需求，但尚未提供實證的安全結果。

7.2 量子機器學習用於安全分析

更成熟的體積研究專注於量子機器學習在網路安全分析中的應用。此類研究聚焦於偵測而非自主性。Bellante 等人評估了量子主成分分析（PCA）在入侵偵測（ID）中的表現，並指出量子優勢取決於資料結構、容錯率與硬體假設 [21]。其分析顯示，在現實限制下，傳統方法仍具競爭力。實驗分析將此評估擴展至真實量子硬體。Nagy 等人於 IBM 與 IonQ 平台上測試了多種量子模型以進行入侵偵測 [108]。這些結果證實了可行性，但也顯示出對雜訊的高度敏感性以及有限的可擴展性。基於量子生成式方法（如量子 GAN）的入侵偵測進一步表明，混合量子 - 古典流程是可行的 [28]。

從代理 AI 的觀點來看，這些進展僅解決了問題的一部分。自主代理依賴檢測模組，但僅有檢測並不能定義代理。代理必須決定何時升級、如何回應，以及如何更新內部狀態。現有的 QML 研究將分類器孤立評估。它們並未衡量規劃延遲、決策穩定性，或對自主回應的下游影響。

例如 QuantumNetSec 框架及針對 cybersecurity 的量子機器學習廣泛調查均明確承認這些限制 [3, 134]。它們將量子學習定位為使能組件而非完整系統。此框架是恰當的，但也留下了未解決的問題。一旦納入協調、治理與成本限制，仍不清楚量子學習是否能提升整體代理效能。

7.3 量子抗阻的信任、身份與治理

量子計算與代理式 AI 之間最緊密的交集在於加密信任。代理系統本質上具有持久性。它們會儲存記憶、憑證與決策歷史，跨越長遠時間範圍。這使得它們特別容易受到「先收割、後解讀」攻擊的威脅，一旦量子對手變得具實用性 [30, 77]。

產業與政策分析強調，代理型 AI 因缺乏人類監督而行動 [63]，從而放大了密碼學風險。非人類身份、授權委託與自主憑證引入了使用者驅動系統中不存在的失效模式。多項分析主張，抗量子密碼學必須早期嵌入，而非後期補強 [75, 106]。學術界的參與仍顯不足。Aegis 協議是一個顯著例外 [5]。該協議建議將安全控制直接嵌入代理工作流。這是一項結構性洞見：安全被視為代理的一部分，而非外部層面。然而，該協議尚未完整說明後量子密碼學如何與代理記憶更新、學習過程或多代理協同互動。

針對人工智慧、量子計算與網路安全的社會層面前瞻研究強化了這一擔憂 [81]。這些研究預見了融合趨勢，但並未提供自主系統的設計層面指導。未解決的問題並非是否需要量子抗擊能力，而是如何在加密假設演變的同時，維持代理的自主性、持續性與協調性。大多數代理式人工智慧框架假設加密技術穩定。大多數後量子加密研究假設客戶端壽命短暫或無狀態。自主代理違反了這兩項假設。當前的文獻尚未解決此不匹配問題。

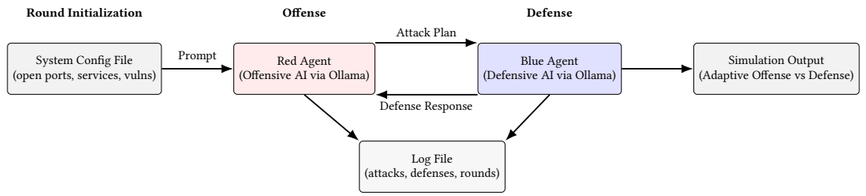

Fig. 6. Workflow of adaptive red–blue simulation. System configuration is ingested, red agent generates attack strategies, blue agent responds with defenses, and exchanges are logged. Loop continues for multiple rounds using Ollama with a lightweight LLM (Mistral).

8 Prototype Agentic AI Implementations for Cybersecurity

In addition to surveying frameworks and literature, we prototyped several minimal implementations to illustrate the feasibility of agentic AI in cybersecurity. These are designed for safety and reproducibility, relying on simulated configurations, synthetic logs, and lightweight local models (e.g., Mistral via Ollama).

8.1 Adaptive Offensive and Defensive Agents

Adaptive offensive and defensive agents simulate adversarial cyber behaviors through a red-versus-blue paradigm. A red team agent emulates offensive tactics such as reconnaissance, exploitation, and privilege escalation, while a blue team agent dynamically counters with defense-in-depth strategies.

We implemented a local interaction loop using a lightweight LLM (Mistral) via the Ollama framework. Red agent was tasked with analyzing a structured system configuration file having data such as open ports, service versions, and known vulnerabilities. Based on this input, red agent generated an attack plan exploiting an Apache RCE vulnerability. Blue agent then reviewed the proposed attack and responded with a multi-layered defense strategy. In the second round, the red agent adapted with evasive and multi-vector tactics such as polymorphic malware, social engineering, and lateral movement, while the blue agent escalated with supply chain monitoring, advanced threat detection, and user behavior analytics. All offensive and defensive actions in each round were autonomously generated by the agents. Human user did not specify attack steps, defensive rules, or mitigation tactics. The user provided only two inputs: (i) a static system configuration file describing the environment (e.g., open ports, service versions, known vulnerabilities), and (ii) a high-level role instruction defining the agent's objective (offensive for red, and defensive for blue agent). Red agent independently selected vulnerabilities, attack vectors, and post-exploitation strategies based on the system state. The blue agent was not pre-programmed with fixed defenses or explicit security policies; it reacted solely to the red agent's proposed actions and inferred appropriate countermeasures with a general goal of preventing compromise and data exfiltration. In Round 2, both agents adapted their strategies autonomously in response to the opponent's prior behavior, without additional user guidance. Implementation workflow is represented in Figure 6, and explained below.

> **Round 1 – Red Agent:** "Use the known Apache 2.4.49 RCE vulnerability to gain unauthorized access. Exploit it using Metasploit, establish a reverse shell, exfiltrate data, and delete logs to remain undetected."
> **Round 1 – Blue Agent:** "Patch the Apache server, restrict access to port 80 via the firewall, monitor logs for shell activity, deploy IDS/IPS to detect RCE patterns, and trigger incident response on anomalies."
>
> **Round 2 – Red Agent:** "Use a zero-day exploit to bypass patching, initiate a phishing campaign to capture credentials, deploy polymorphic malware to evade detection, move laterally using pass-the-hash, and launch a DDoS to divert attention from exfiltration."

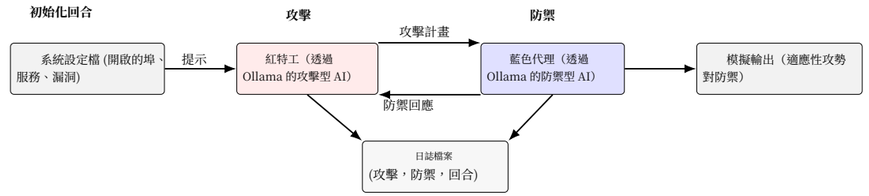

圖 6。適配紅藍模擬的工作流程。系統配置被導入，紅色代理生成攻擊策略，藍色代理以防禦措施回應，並記錄交換過程。循環使用 Ollama 與輕量級大語言模型（Mistral）進行多輪迭代。

8 原型代理式 AI 在網路安全中的實現

除調查框架與文獻外，我們還原型開發了多個簡化實作，以說明代理式 AI 在網路安全領域的可行性。這些實作旨在確保安全性與可重複性，依賴模擬配置、合成日誌以及輕量級本地模型（例如透過 Ollama 運行的 Mistral）。

8.1 適應性攻擊與防禦代理

適應性攻擊與防禦代理透過紅隊對藍隊的模式模擬敵對式網路行為。紅隊代理模擬偵查、漏洞利用與權限提升等攻擊策略，而藍隊
團隊代理人員動態採用纵深防禦策略予以反制。

我們透過 Ollama 框架，使用輕量級大語言模型（Mistral）實現了本地互動迴路。紅方代理被指派分析包含開放端口、服務版本及已知漏洞等資料的結構化系統配置檔案。基於此輸入，紅方代理生成了一個利用 Apache RCE 漏洞的攻擊計畫。藍方代理隨後檢視所提出的攻擊，並回應以多層次的防禦策略。在第二輪中，紅方代理採用隱蔽與多向量戰術進行適應，包括多態性惡意軟體、社會工程學與橫向移動；而藍方代理則升級至供應鏈監控、進階威脅偵測與使用者行為分析。每一輪中的所有攻擊與防禦行動均由代理自主生成。人類使用者未指定攻擊步驟、防禦規則或緩解策略。使用者僅提供兩項輸入：(i) 描述環境（例如開放端口、服務版本、已知漏洞）的靜態系統配置檔案，以及 (ii) 定義代理目標的高層角色指令（紅方為攻擊，藍方為防禦）。紅方代理根據系統狀態獨立選擇漏洞、攻擊向量及後攻策略。藍方代理未預先編程固定防禦或明確安全策略；其僅針對紅方代理所提出的行動做出反應，並推斷出適當的對策，目標為防止系統被入侵及資料洩漏。在第二輪中，兩方代理均根據對方的先前行為自主調整策略，無需額外的使用者指導。實施工作流程如圖 6 所示，並詳述如下。

> 第一輪 – 紅色代理：「利用已知的 Apache 2.4.49 遠端程式碼執行漏洞獲取未經授權的訪問權限。」利用 Metasploit 進行攻擊，建立反向外掛，洩漏資料，並刪除日誌以保持未被發現。
> 第一輪 – 藍色特工：「修復 Apache 伺服器，透過防火牆限制 80 端口的存取，監控日誌」針對 Shell 活動，部署 IDS/IPS 以偵測 RCE 模式，並在異常時觸發事件回應。
>
> 第二輪 – 紅隊：「利用零日漏洞繞過補丁，發起釣魚活動以竊取憑證，部署多態惡意軟體以規避偵測，透過哈希傳遞進行橫向移動，並發動 DDoS 攻擊以轉移對資料洩漏的注意。」

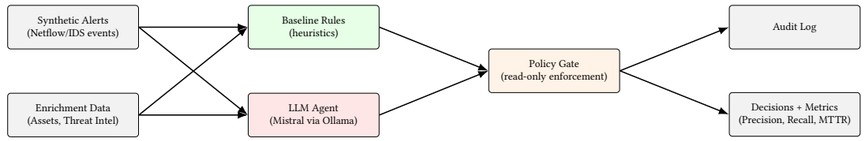

Fig. 7. SOC triage agent workflow. Synthetic alerts and enrichment data are processed by baseline rules and an LLM agent. All actions pass through a policy gate, with results logged and evaluated for precision, recall, F1, and MTTR.

> **Round 2 – Blue Agent:** "Deploy advanced threat protection (ATP) to detect behavior-based anomalies, train employees to resist phishing, implement network segmentation to contain lateral movement, and secure third-party dependencies to defend against supply chain compromise."

This simulation illustrates adaptive reasoning capabilities of agentic AI beyond static prompts. Though textual, the loop mimics realistic escalation, defense posture tuning, and adversarial persistence. This could be extended with log parsing, external tool access (e.g., Nmap), and deployment into interactive cyber ranges for adversarial resilience testing.

8.2 SOC Triage Agent

SOC triage agents automate Tier-1 alert handling by filtering, enriching, and prioritizing events. We compare a deterministic rule-based baseline with an LLM-assisted agent to evaluate whether agentic AI can improve recall and reduce mean time to triage (MTTR) in a controlled synthetic setting. The workflow ingests synthetic alerts (Apache Struts RCE, SSH brute force, SQL injection, malware hash detection, suspicious user agent, and port scan) and enriches them with asset criticality and threat intelligence. The baseline applies static heuristics, while the agentic version queries a local LLM (Mistral via Ollama) to output structured decisions (`escalate` or `close`) with rationales. A governance layer enforces read-only actions and logs all decisions. The end-to-end pipeline is shown in Figure 7.

Example agent decisions include escalating a high-severity Apache Struts RCE on a critical web asset, closing a suspicious user agent from a CI system with no malicious indicators, and escalating a known malicious hash on a critical HR endpoint. Evaluation on six alerts with ground-truth labels shows that the baseline achieved perfect precision but lower recall (0.75), while the LLM agent achieved perfect precision, recall, and F1, and reduced simulated MTTR from 7.5 to 6.0 minutes (Table 8). All 12 agent actions were policy-compliant and fully logged. This result indicates that LLM-based triage can reduce missed detections and improve efficiency without sacrificing precision.

8.3 Anomaly and IDS Agent

Anomaly detection and intrusion detection systems (IDS) provide a natural testbed for agentic AI because they require both statistical sensitivity and contextual reasoning. Traditional approaches rely on rules or unsupervised detectors (e.g., z-score thresholds or Isolation Forests) to flag traffic spikes. However, these methods often generate false positives by failing to distinguish benign periodicity from malicious anomalies. Agentic AI can augment this process by combining lightweight retrieval with natural language reasoning, thereby improving interpretability and triage efficiency.

We implemented a micro-demo using synthetic NetFlow-like time windows. Each window contained summary features such as bytes-per-second, packets-per-second, SYN rate, and failed connection rate. The baseline detector applied a z-score rule and Isolation Forest to classify anomalous windows. In contrast, the agentic IDS queried a local LLM (Mistral via Ollama) with both the raw statistics and a small retrieval-augmented note set describing benign patterns (e.g., periodic backups) and malicious signatures (e.g., volumetric spikes). The agent produced JSON-structured outputs with binary labels and concise rationales. The overall workflow is shown in Figure 8, as explained below:

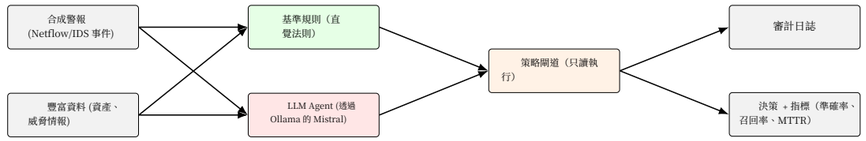

圖 7。SOC 分級代理工作流。合成警報與豐富數據由基準規則及 LLM 代理處理。所有動作均經過策略閘門，結果記錄並評估其準確率、召回率、F1 值及 MTTR。

> 第二輪 – 藍色特工：「部署先進威脅防護（ATP）以偵測基於行為的異常，訓練員工抵禦釣魚攻擊，實施網路區段化以限制橫向移動，並保護第三方依賴項以防禦供應鏈竊取。」

此模擬展示了代理式 AI 超越靜態提示的適應性推理能力。儘管為文本形式，該循環模擬了現實中的升級、防禦姿態調整及對抗性持續性。此功能可擴展至加入日誌解析、外部工具存取（例如 Nmap），並部署於互動式網路防禦範圍中，以進行對抗性韌性測試。

8.2 SOCTriage 代理

SOC 分級處理人員透過過濾、豐富並優先排序事件，自動化一級警報處理。我們將基於確定性規則的基準與 LLM 輔助的代理進行比較，以評估代理式 AI 是否能於受控的合成環境中提升召回率並降低分級處理平均時間（MTTR）。該工作流會攝取合成警報（Apache Struts 遠端執行權限、SSH 暴力破解、SQL 注入、惡意軟體哈希檢測、可疑使用者代理字串及掃描埠），並結合資產關鍵性與威脅智慧進行豐富。基準採用靜態直覺判斷，而代理版本則查詢本地 LLM（透過 Ollama 運行的 Mistral），輸出結構化決策（升級或關閉）及其理由。治理層級強制執行只讀操作並記錄所有決策。完整端到端流程如圖 7 所示。

範例代理決策包括：將關鍵網頁資產上的高嚴重性 Apache Struts RCE 升級處理、關閉來自無惡意指標之 CI 系統的可疑使用者代理、以及將已知惡意 hash 在關鍵 HR 端點上的情況升級處理。針對六個帶有真實標籤的警報進行評估顯示，基礎方案達到完美精準度但召回率較低（0.75），而 LLM 代理則達到完美精準度、召回率與 F1 值，並將模擬平均修復時間從 7.5 分鐘降至 6.0 分鐘（表 8）。所有 12 項代理行動均符合政策規範且完整記錄。此結果顯示，基於 LLM 的初步篩選可降低漏報並提升效率，同時不犧牲精準度。

8.3 異常與 ID 偵測代理

異常檢測與入侵檢測系統（IDS）為代理型 AI 提供了天然的測試環境，因為它們需要兼具統計敏感度與情境推理能力。傳統方法依賴規則或無監督檢測器（例如 z-score 閾值或隔離森林）來標記流量尖峰。然而，這些方法經常因無法區分良性週期性與惡意異常而產生誤報。代理型 AI 可透過結合輕量級檢索與自然語言推理來增強此流程，從而提升可解釋性與分級處理效率。

我們使用合成類 NetFlow 時間窗實施了一個微型演示。每個時間窗包含摘要特徵，例如每秒數據量、每秒數據包數、SYN 速率以及失敗連接速率。基線檢測器應用 z-score 規則和隔離森林來分類異常時間窗。相比之下，代理型入侵檢測系統（IDS）向本地大語言模型（透過 Ollama 運行的 Mistral）查詢，輸入包含原始統計數據以及一小組檢索增強的註解集，該註解集描述了良性模式（例如定期備份）和惡意簽名（例如體積突增）。代理產出結構化為 JSON 的輸出，包含二進位標籤和簡潔的推理依據。整體工作流程如圖 8 所示，以下將詳述：

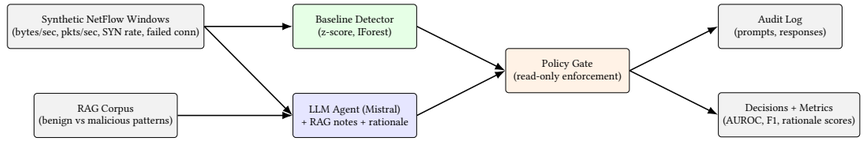

Fig. 8. Anomaly/IDS agent workflow. Synthetic NetFlow windows are analyzed by both a baseline detector (z-score, IForest) and an LLM agent with retrieval-augmented notes. All actions pass through a policy gate and are recorded in an audit log. Outputs include anomaly decisions, metrics (AUROC, F1), and explanation usefulness scores.

Table 8. Performance of SOC triage baseline vs. LLM-assisted agent on synthetic alerts.

System	Precision	Recall	F1	Sim. MTTR (min)
Baseline (rules)	1.00	0.75	0.86	7.5
Agent (Mistral)	1.00	1.00	1.00	6.0

Table 9. Performance of baseline vs. LLM-assisted anomaly/IDS agent on synthetic NetFlow windows.

System	AUROC	F1
Baseline (z-score + IForest)	0.87	0.74
Agent (Mistral)	0.93	0.81

Window 0 (LLM Agent): "The window exhibits volumetric anomalies due to sharp spikes in bytes_per_sec and pkts_per_sec, which contradicts the note of benign periodicity. Therefore, label = 1 (anomalous)."

Window 19 (LLM Agent): "While the traffic rates are elevated, the presence of benign periodicity suggests normal scheduled activity such as backups. Therefore, label = 0 (normal)."

The evaluation compared baseline detectors and the agentic model on synthetic windows with ground-truth labels. As shown in Table 9, the baseline achieved reasonable AUROC but produced false positives on periodic traffic. The agent maintained high recall while improving F1 and providing human-readable rationales. A small rubric was also applied to evaluate explanation usefulness (consistency, specificity), where the agent achieved an average score of 0.83.

This experiment shows how agentic IDS prototypes can blend statistical detection with explainable reasoning. Unlike traditional detectors that output only binary alerts, the agent provided concise justifications grounded in retrieved knowledge, making outputs more useful for analysts. Future work could integrate richer traffic features (e.g., flow durations, entropy measures) and evaluate robustness in adversarial settings or interactive SOC ranges.

9 Directions of Future Research

Agentic AI security remains an open research. Existing work identified many threats, but defensive solutions are still novice [76, 118]. Future research should focus on closing the gap between agent capabilities and security guarantees.

Input inspection and control: Research should improve automatic inspection of user inputs. Current defenses against prompt injection and jailbreak attacks are incomplete and inefficient [76, 118]. Many systems rely on heuristic filters or offline analysis which do not scale well to real time agent execution. Research should develop lightweight and adaptive inspection mechanisms that operate during agent interaction. These mechanisms should distinguish between instructions and data with high reliability. They should also adapt to multistep and multimodal inputs [41, 164].

Transparency of internal execution: Internal execution of agents is difficult to observe. Reasoning chains, planning steps, and tool calls are often hidden from auditors, limiting timely detection of unsafe behavior [60]. Research should design methods to expose internal states without leaking sensitive information. Structured logging and execution traces are promising directions which can support runtime verification and post hoc auditing of agent behavior [51, 144].

Robust planning and reasoning: Planning errors can amplify small mistakes into severe failures. Current planning structures lack formal guarantees. Future work should study error propagation in multistep reasoning. Research should

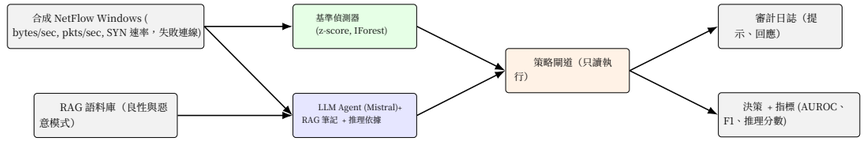

圖 8。異常/IDS 代理工作流。合成 NetFlow 窗口由基準檢測器（z-score、IForest）與具備檢索增強註記的 LLM 代理共同分析。所有動作均通過策略閘並記錄於審計日誌。輸出包含異常決策、指標（AUROC、F1）以及解釋有用度分數。

表 8。SOC 分級基準與 LLM 輔助代理在模擬警報中的效能比較。

系統	精確度	回想	F1	是。平均修復時間（分鐘）
基準 (規則)	1.00	0.75	0.86	7.5
代理 (Mistral)	1.00	1.00	1.00	6.0

表 9。基於合成 NetFlow 窗口的基線與 LLM 輔助異常/IDS 代理的性能比較。

系統	AUROC	F1
基準 (z 分數 + IForest)	0.87	0.74
代理 (Mistral)	0.93	0.81

視窗 0 (LLM 代理)：「該視窗因每_秒的 bytes_ 及每_秒的 pkts_ 出現尖銳峰值，而呈現體積異常，這與良性週期性的註記相矛盾。因此，標籤 = 1(異常)。」

視窗 19 (LLM Agent)：「雖然流量速率偏高，但存在良性的週期性，顯示為正常的定期活動，例如備份。因此，標記 = 0 (正常)。」

評估將基線檢測器與代理模型在帶有真實標籤的合成窗格上進行了比較。如表 9 所示，基線取得了合理的 AUROC，但在週期性流量上產生了誤報。代理模型在保持高召回率的同時，提升了 F1 值，並提供了可讀的解釋。此外，還應用了一個小型評分標準來評估解釋的有用性（一致性、具體性），代理模型的平均得分為 0.83。

本實驗展示了代理式入侵檢測系統原型如何將統計檢測與可解釋推理相結合。與僅輸出二進制警報的傳統檢測器不同，該代理基於檢索到的知識提供了簡潔的解釋，使輸出對分析員更具實用性。未來工作可整合更豐富的流量特徵（例如流持續時間、熵度量），並在對抗性環境或互動式 SOC 範圍內評估其魯棒性。

9 未來研究方向

代理式 AI 安全仍為開放性研究課題。現有工作已識別出許多威脅，但防禦解決方案仍屬初級 [76, 118]。未來研究應聚焦於縮小代理能力與安全保證之間的差距。輸入檢查與控制：研究應改進對使用者輸入的自動檢查。當前的防禦措施針對提示注入與越獄攻擊尚不完整且效率低下 [76, 118]。許多系統依賴於直覺式過濾器或離線分析，這些方法難以有效擴展至真實時間的代理執行。研究應開發輕量且具適應性的檢查機制，使其能在代理互動期間運作。這些機制應能高可靠性地區分指令與資料。它們還應能適應多步驟與多模態輸入 [41, 164]。

內部執行透明度：代理的內部執行難以觀察。推理鏈、規劃步驟和工具調用經常對審計員隱蔽，限制了對不安全行為的及時檢測 [60]。研究應設計方法以揭露內部狀態而不洩露敏感資訊。結構化日誌和執行追蹤是具潛力的方向，可支援代理行為的即時驗證與事後審計 [51, 144]。

堅實的規劃與推理：規劃錯誤可能將微小錯誤放大為嚴重失敗。當前的規劃結構缺乏形式化保證。未來工作應研究多步推理中的錯誤傳播。研究應

also explore constrained planning methods that enforce safety rules throughout execution. Combining language models with formal constraints or verifiable policies remains an open challenge [118, 144].

Secure interaction with environments: Agents increasingly interact with dynamic and untrusted environments. Indirect prompt injection and manipulated feedback remain serious risks [76, 118]. Future research should develop stronger isolation between agent instructions and external data. Secure sandboxing and environment validation should be studied across deployment settings. This includes cloud systems, simulated environments, and physical systems.

Multi agent coordination security: Multi agent systems introduce new attack surfaces as agents may collude or propagate errors. Competitive agents may deceive or manipulate each other. Existing defenses are limited and often reduce system efficiency [60]. Future work should study secure coordination protocols for agent communication. Research should also examine how trust, verification, and accountability can be enforced across agents [68, 127, 128, 187].

Memory integrity and privacy: Agent memory is a critical vulnerability. Short term memory limits reasoning. Long term memory can be poisoned or leaked [76, 118]. Current defenses focus on model level protections rather than memory systems. Future research should design secure memory architectures for agents. These architectures should support validation, versioning, and access control. Privacy preserving retrieval methods are also needed [60, 92].

Unified evaluation and benchmarks: Security evaluation of agents lacks standardized benchmarks. Existing datasets focus on isolated attacks or single agents. Future research should develop comprehensive benchmarks that cover perception, reasoning, action, interaction, and memory. These benchmarks should reflect real world deployment scenarios. They should also support reproducible and comparable evaluation of defenses [41, 164, 176].

Governance and deployment assurance: Technical defenses alone are not sufficient. Agentic systems operate under policy, legal, and organizational constraints. Future research should integrate governance mechanisms into agent design [5, 51]. This includes policy enforcement, auditing, and human oversight. Assurance frameworks that combine technical and organizational controls remain an open research direction [68, 127, 128, 187].

10 Conclusion

Agentic AI marks a shift from static inference to goal-directed systems that reason, act, and adapt over time. By integrating memory, tool use, and autonomy, these systems enable new cybersecurity capabilities across monitoring, response, intelligence, and training. At the same time, they introduce novel risks that arise from persistent state, execution authority, and multi-agent coordination. Across the literature, a consistent tradeoff emerges. Greater autonomy improves speed and adaptability but reduces predictability, auditability, and control. Security failures stem from system-level interactions among perception, reasoning, action, memory, and identity rather than from model inference alone. Existing frameworks, benchmarks, and governance approaches address parts of this problem but remain fragmented.

As agentic AI becomes embedded in critical cybersecurity infrastructure, security and governance must be treated as foundational design requirements. Progress will depend on bounded autonomy, enforceable execution controls, continuous assurance, and human oversight. Addressing these challenges is essential to realizing the benefits of agentic AI while limiting misuse and systemic risk.

References

[1] ISC2 2024. *Growth of Cybersecurity Workforce Slows in 2024 as Economic Uncertainty Persists.* ISC2. https://www.isc2.org/Insights/2024/09/ISC2-Publishes-2024-Cybersecurity-Workforce-Study-First-Look
[2] 2025. AI Agents Explained. https://docs.agent.ai/ai-agents-explained
[3] Diego Abreu, David Moura, Christian Esteve Rothenberg, and Antŏ0f4nio Abelõ0e9m. 2025. QuantumNetSec: Quantum Machine Learning for Network Security. *International Journal of Network Management* 35, 4 (2025). doi:10.1002/nem.70018

同時探索在執行過程中強制遵守安全規則的受限規劃方法。將語言模型與形式約束或可驗證策略結合仍是一個未解的挑戰 [118, 144]。

與環境的互動：代理越來越頻繁地與動態且不可信的環境互動。間接提示注入和操縱反饋仍構成嚴重風險 [76, 118]。未來研究應發展出更強的代理指令與外部數據之間的隔離。應在各種部署場景中研究安全的沙箱與環境驗證，這包括雲系統、模擬環境以及實體系統。

多智能體協同安全：多智能體系統引入了新的攻擊面，因為智能體可能串通或傳播錯誤。競爭性智能體可能會欺騙或操控彼此。現有的防禦手段有限，且常會降低系統效率 [60]。未來工作應研究用於智能體通信的安全協同協議。研究還應探討如何在智能體之間強制執行信任、驗證與問責 [68, 127, 128, 187]。記憶完整性與隱私：智能體記憶是關鍵漏洞。短期記憶限制推理能力。長期記憶可能被投毒或洩漏 [76, 118]。目前的防禦措施專注於模型層級的保護，而非記憶系統。未來研究應為智能體設計安全的記憶架構。這些架構應支援驗證、版本控制與存取控制。同時也需要隱私保護的檢索方法 [60, 92]。

統一評估與基準：代理的安全評估缺乏標準化基準。現有數據集專注於孤立的攻擊或單一代理。未來研究應開發涵蓋感知、推理、行動、互動與記憶的全面基準。這些基準應反映真實世界部署場景。它們還應支持防禦措施的可重複與可比評估 [41, 164, 176]。

治理與部署保障：僅靠技術防禦並不足夠。代理系統運作於政策、法律與組織約束之下。未來研究應將治理機制整合至代理設計[5, 51]中。這包含政策執行、審計與人類監督。結合技術與組織控制的保障框架仍是待探索的研究方向 [68, 127, 128, 187]。

10 結論

代理式 AI 標誌著從靜態推理向具備推理、行動與適應能力的目標導向系統的轉變。透過整合記憶、工具使用與自主性，這些系統在監控、回應、情報與訓練等領域帶來新的網路安全能力。同時，它們也引入了源自持續狀態、執行權限與多代理協作的新型風險。在現有文獻中，一致的權衡關係逐漸顯現：更高的自主性雖能提升速度與適應性，卻會降低可預測性、可稽核性與可控性。安全失敗並非源於模型推理本身，而是來自感知、推理、行動、記憶與身份等系統層級間的互動。現有的框架、基準與治理方法雖能解決部分問題，但仍顯零散。

隨著代理式 AI 嵌入關鍵網路安全基礎設施，安全與治理必須視為基礎設計要求。進展將取決於受限自主性、可執行的執行控制、持續驗證與人類監督。解決這些挑戰對於實現代理式 AI 的效益至關重要，同時能限制濫用與系統性風險。

參考資料

[1] ISC2 2024. *Growth of Cybersecurity Workforce Slows in 2024 as Economic Uncertainty Persists.* ISC2. https://www.isc2.org/Insights/2024/09/ISC2-Publishes-2024-Cybersecurity-Workforce-Study-First-Look
[2] 2025. AI Agents Explained. https://docs.agent.ai/ai-agents-explained
[3] Diego Abreu, David Moura, Christian Esteve Rothenberg, and Antŏ0f4nio Abelõ0e9m. 2025. QuantumNetSec: Quantum Machine Learning for Network Security. *International Journal of Network Management* 35, 4 (2025). doi:10.1002/nem.70018

[4] Ibrahim Adabara, Bashir Olaniyi Sadiq, Aliyu Nuhu Shuaibu, Yale Ibarahim Danjuma, and Maninti Venkateswarlu. 2025. A Review of Agentic AI in Cybersecurity: Cognitive Autonomy, Ethical Governance, and Quantum-Resilient Defense. *F1000Research* 14 (2025), 843.
[5] Sai Teja Reddy Adapala and Yashwanth Reddy Alugubelly. 2025. The Aegis Protocol: A Foundational Security Framework for Autonomous AI Agents. https://arxiv.org/abs/2508.19267
[6] Akamai Technologies. 2025. *Edge of Agency: Defending Against the Risks of Agentic AI.* https://www.akamai.com/blog/security/edge-of-agency-defending-against-risks-agentic-ai Accessed: 2025-09-21.
[7] AlgoAnalytics. 2025. *The Game Changer: Agentic AI in Modern Security and Surveillance.* https://blog.algoanalytics.com/2025/03/20/the-game-changer-agentic-ai-in-modern-security-and-surveillance/ Accessed: 2025-09-15.
[8] Abdulmalik Alquwayfili. 2025. Quantigence: A Multi-Agent AI Framework for Quantum Security Research. arXiv:2512.12989 [cs.MA] https://arxiv.org/abs/2512.12989
[9] Anonymous. 2025. Mind the Agent: A Comprehensive Survey on Large Language Model-Based Agent Safety. In *Submitted to CS598 LLM Agent 2025 Workshop.* https://openreview.net/forum?id=DHe0UXipKU under review.
[10] Anthropic. 2024. Agentic Misalignment: How LLMs Could Be Insider Threats. https://www.anthropic.com/research/agentic-misalignment Accessed: 2025-09-08.
[11] Anthropic. 2025. *Detecting and Countering the Misuse of Agentic AI.* https://www.anthropic.com/news/detecting-countering-misuse-aug-2025 Accessed: 2025-09-08.
[12] API DNA. 2024. *API Rate Limiting and Throttling with Autonomous Agents.* https://dev.to/apidna/api-rate-limiting-and-throttling-with-autonomous-agents-2m7m Accessed: 2025-09-21.
[13] Oluwatosin Aramide. 2024. Autonomous network monitoring using LLMs and multi-agent systems. *World Journal of Advanced Engineering Technology and Sciences* 13 (2024), 974–985. doi:10.30574/wjaets.2024.13.2.0639
[14] Aspen Digital. 2024. Cyber Defenses and Agentic AI. https://www.aspendigital.org/blog/cyber-defenses-agentic-ai/ Accessed: 2025-09-08.
[15] Yam Atir. 2025. *The Rise of Agentic AI: Infrastructure, Autonomy, and America's Cyber Future.* Technical Report. Belfer Center for Science and International Affairs, Harvard Kennedy School. https://www.belfercenter.org/research-analysis/rise-agentic-ai-infrastructure-autonomy-and-americas-cyber-future
[16] Ahmed Atta. 2025. Autonomous Threat Intelligence with Agentic AI for Adaptive Security Operations in IoT Ecosystems. *ResearchGate Preprint* (2025). https://www.researchgate.net/publication/394263102_Autonomous_Threat_Intelligence_with_Agentic_AI_for_Adaptive_Security_Operations_in_IoT_Ecosystems
[17] Sanket Badhe. 2025. ScamAgents: How AI Agents Can Simulate Human-Level Scam Calls. https://arxiv.org/abs/2508.06457
[18] Abdul Barek, Md Bajlur Rashid, A Kamrul, Guillermo Iii, Hossain Shahriar, and Iqbal Ahamed. 2025. Analyzing the Behavior of LLM Under Concurrency and Token-Based DoS Attacks. doi:10.13140/RG.2.2.22386.21444
[19] Reza Vatankhah Barenji and Sina Khoshgoftar. 2025. Agentic AI for Autonomous Anomaly Management in Complex Systems. *arXiv preprint arXiv:2507.15676* (2025). https://arxiv.org/abs/2507.15676
[20] Nardine Basta, Conor Atkins, and Dali Kaafar. 2025. Bot Wars Evolved: Orchestrating Competing LLMs in a Counterstrike Against Phone Scams. https://arxiv.org/abs/2503.07036
[21] Armando Bellante et al. 2025. Evaluating the potential of quantum machine learning in cybersecurity: A case-study on PCA-based intrusion detection systems. *Computers & Security* 154 (2025), 104341. doi:10.1016/j.cose.2025.104341
[22] Ting Bi, Chenghang Ye, Zheyu Yang, Ziyi Zhou, Cui Tang, Jun Zhang, Zui Tao, Kailong Wang, Liting Zhou, Yang Yang, and Tianlong Yu. 2025. On the Feasibility of Using MultiModal LLMs to Execute AR Social Engineering Attacks. https://arxiv.org/abs/2504.13209
[23] Pete Bryan et al. 2025. *Taxonomy of Failure Mode in Agentic AI Systems.* Technical Report. Microsoft. https://cdn-dynmedia-1.microsoft.com/is/content/microsoftcorp/microsoft/final/en-us/microsoft-brand/documents/Taxonomy-of-Failure-Mode-in-Agentic-AI-Systems-Whitepaper.pdf
[24] Michael Burch. 2025. *Experts Reveal How Agentic AI Is Shaping Cybersecurity in 2025.* https://www.securityjourney.com/post/experts-reveal-how-agentic-ai-is-shaping-cybersecurity-in-2025 Contributed for CybersecurityTribe.com; includes insights from multiple industry experts.
[25] Juan Castro. 2024. Agentic AI and the Cybersecurity Compass - Optimizing Cyber Defense. https://cybersecuritycompass.org/agentic-ai-and-the-cybersecurity-compass-optimizing-cyber-defense-across-phases-eca0e4452e98
[26] Pradipta Kishore Chakrabarty. 2025. Adversarial Attacks on Agentic AI Systems: Mechanisms, Impacts, and Defense Strategies. *International Journal of Science and Research (IJSR)* 14 (2025), 1367 – 1369. doi:10.21275/SR25417074844
[27] Brian Challita and Pierre Parrend. 2025. RedTeamLLM: an Agentic AI framework for offensive security. https://arxiv.org/abs/2505.06913
[28] Franco Cirillo and Christian Esposito. 2025. Intrusion Detection System Based on Quantum Generative Adversarial Network. In *Proceedings of the 17th International Conference on Agents and Artificial Intelligence - Volume 1: QAIO.* INSTICC, SciTePress, 830–838. doi:10.5220/0013397800003890
[29] Cisco Outshift. 2025. *AI Agent Identity Framework from the AGNTCY.* https://outshift.cisco.com/blog/ai-agent-identity-framework-agntcy Accessed: 2025-09-21.
[30] Greg Clark. 2025. Quantum threats, Agentic AI, and the next frontier of data security. https://blogs.opentext.com/quantum-threats-agentic-ai-and-the-next-frontier-of-data-security/ OpenText blog, accessed 2025-12-25.
[31] Cloud Security Alliance. 2025. *Agentic AI Identity Management Approach.* https://cloudsecurityalliance.org/blog/2025/03/11/agentic-ai-identity-management-approach Accessed: 2025-09-21.

[4] Ibrahim Adabara, Bashir Olaniyi Sadiq, Aliyu Nuhu Shuaibu, Yale Ibarahim Danjuma, and Maninti Venkateswarlu. 2025. A Review of Agentic AI in Cybersecurity: Cognitive Autonomy, Ethical Governance, and Quantum-Resilient Defense. *F1000Research* 14 (2025), 843.
[5] Sai Teja Reddy Adapala and Yashwanth Reddy Alugubelly. 2025. The Aegis Protocol: A Foundational Security Framework for Autonomous AI Agents. https://arxiv.org/abs/2508.19267
[6] Akamai Technologies. 2025. *Edge of Agency: Defending Against the Risks of Agentic AI.* https://www.akamai.com/blog/security/edge-of-agency-defending-against-risks-agentic-ai Accessed: 2025-09-21.
[7] AlgoAnalytics. 2025. *The Game Changer: Agentic AI in Modern Security and Surveillance.* https://blog.algoanalytics.com/2025/03/20/the-game-changer-agentic-ai-in-modern-security-and-surveillance/ Accessed: 2025-09-15.
[8] Abdulmalik Alquwayfili. 2025. Quantigence: A Multi-Agent AI Framework for Quantum Security Research. arXiv:2512.12989 [cs.MA] https://arxiv.org/abs/2512.12989
[9] Anonymous. 2025. Mind the Agent: A Comprehensive Survey on Large Language Model-Based Agent Safety. In *Submitted to CS598 LLM Agent 2025 Workshop.* https://openreview.net/forum?id=DHe0UXipKU under review.
[10] Anthropic. 2024. Agentic Misalignment: How LLMs Could Be Insider Threats. https://www.anthropic.com/research/agentic-misalignment Accessed: 2025-09-08.
[11] Anthropic. 2025. *Detecting and Countering the Misuse of Agentic AI.* https://www.anthropic.com/news/detecting-countering-misuse-aug-2025 Accessed: 2025-09-08.
[12] API DNA. 2024. *API Rate Limiting and Throttling with Autonomous Agents.* https://dev.to/apidna/api-rate-limiting-and-throttling-with-autonomous-agents-2m7m Accessed: 2025-09-21.
[13] Oluwatosin Aramide. 2024. Autonomous network monitoring using LLMs and multi-agent systems. *World Journal of Advanced Engineering Technology and Sciences* 13 (2024), 974–985. doi:10.30574/wjaets.2024.13.2.0639
[14] Aspen Digital. 2024. Cyber Defenses and Agentic AI. https://www.aspendigital.org/blog/cyber-defenses-agentic-ai/ Accessed: 2025-09-08.
[15] Yam Atir. 2025. *The Rise of Agentic AI: Infrastructure, Autonomy, and America's Cyber Future.* Technical Report. Belfer Center for Science and International Affairs, Harvard Kennedy School. https://www.belfercenter.org/research-analysis/rise-agentic-ai-infrastructure-autonomy-and-americas-cyber-future
[16] Ahmed Atta. 2025. Autonomous Threat Intelligence with Agentic AI for Adaptive Security Operations in IoT Ecosystems. *ResearchGate Preprint* (2025). https://www.researchgate.net/publication/394263102_Autonomous_Threat_Intelligence_with_Agentic_AI_for_Adaptive_Security_Operations_in_IoT_Ecosystems
[17] Sanket Badhe. 2025. ScamAgents: How AI Agents Can Simulate Human-Level Scam Calls. https://arxiv.org/abs/2508.06457
[18] Abdul Barek, Md Bajlur Rashid, A Kamrul, Guillermo Iii, Hossain Shahriar, and Iqbal Ahamed. 2025. Analyzing the Behavior of LLM Under Concurrency and Token-Based DoS Attacks. doi:10.13140/RG.2.2.22386.21444
[19] Reza Vatankhah Barenji and Sina Khoshgoftar. 2025. Agentic AI for Autonomous Anomaly Management in Complex Systems. *arXiv preprint arXiv:2507.15676* (2025). https://arxiv.org/abs/2507.15676
[20] Nardine Basta, Conor Atkins, and Dali Kaafar. 2025. Bot Wars Evolved: Orchestrating Competing LLMs in a Counterstrike Against Phone Scams. https://arxiv.org/abs/2503.07036
[21] Armando Bellante et al. 2025. Evaluating the potential of quantum machine learning in cybersecurity: A case-study on PCA-based intrusion detection systems. *Computers & Security* 154 (2025), 104341. doi:10.1016/j.cose.2025.104341
[22] Ting Bi, Chenghang Ye, Zheyu Yang, Ziyi Zhou, Cui Tang, Jun Zhang, Zui Tao, Kailong Wang, Liting Zhou, Yang Yang, and Tianlong Yu. 2025. On the Feasibility of Using MultiModal LLMs to Execute AR Social Engineering Attacks. https://arxiv.org/abs/2504.13209
[23] Pete Bryan et al. 2025. *Taxonomy of Failure Mode in Agentic AI Systems.* Technical Report. Microsoft. https://cdn-dynmedia-1.microsoft.com/is/content/microsoftcorp/microsoft/final/en-us/microsoft-brand/documents/Taxonomy-of-Failure-Mode-in-Agentic-AI-Systems-Whitepaper.pdf
[24] Michael Burch. 2025. *Experts Reveal How Agentic AI Is Shaping Cybersecurity in 2025.* https://www.securityjourney.com/post/experts-reveal-how-agentic-ai-is-shaping-cybersecurity-in-2025 Contributed for CybersecurityTribe.com; includes insights from multiple industry experts.
[25] Juan Castro. 2024. Agentic AI and the Cybersecurity Compass - Optimizing Cyber Defense. https://cybersecuritycompass.org/agentic-ai-and-the-cybersecurity-compass-optimizing-cyber-defense-across-phases-eca0e4452e98
[26] Pradipta Kishore Chakrabarty. 2025. Adversarial Attacks on Agentic AI Systems: Mechanisms, Impacts, and Defense Strategies. *International Journal of Science and Research (IJSR)* 14 (2025), 1367 – 1369. doi:10.21275/SR25417074844
[27] Brian Challita and Pierre Parrend. 2025. RedTeamLLM: an Agentic AI framework for offensive security. https://arxiv.org/abs/2505.06913
[28] Franco Cirillo and Christian Esposito. 2025. Intrusion Detection System Based on Quantum Generative Adversarial Network. In *Proceedings of the 17th International Conference on Agents and Artificial Intelligence - Volume 1: QAIO.* INSTICC, SciTePress, 830–838. doi:10.5220/0013397800003890
[29] Cisco Outshift. 2025. *AI Agent Identity Framework from the AGNTCY.* https://outshift.cisco.com/blog/ai-agent-identity-framework-agntcy Accessed: 2025-09-21.
[30] Greg Clark. 2025. Quantum threats, Agentic AI, and the next frontier of data security. https://blogs.opentext.com/quantum-threats-agentic-ai-and-the-next-frontier-of-data-security/ OpenText blog, accessed 2025-12-25.
[31] Cloud Security Alliance. 2025. *Agentic AI Identity Management Approach.* https://cloudsecurityalliance.org/blog/2025/03/11/agentic-ai-identity-management-approach Accessed: 2025-09-21.

[32] Cloud Security Alliance. 2025. *Introducing DIRF: A Comprehensive Framework for Protecting Digital Identities in Agentic AI Systems.* https://cloudsecurityalliance.org/blog/2025/08/27/introducing-dirf-a-comprehensive-framework-for-protecting-digital-identities-in-agentic-ai-systems Accessed: 2025-09-11.
[33] CrowdStrike. 2023. Red Team vs. Blue Team: What's the Difference? https://www.crowdstrike.com/en-us/cybersecurity-101/advisory-services/red-team-vs-blue-team/
[34] CSAW. 2024. Agentic Automated Capture-the-Flag (CTF). https://www.csaw.io/agentic-automated-ctf Accessed: 2025-09-08.
[35] Jian Cui, Zichuan Li, Luyi Xing, and Xiaojing Liao. 2025. Safeguard-by-Development: A Privacy-Enhanced Development Paradigm for Multi-Agent Collaboration Systems. https://arxiv.org/abs/2505.04799
[36] Shrestha Datta, Shahriar Kabir Nahin, Anshuman Chhabra, and Prasant Mohapatra. 2025. Agentic AI Security: Threats, Defenses, Evaluation, and Open Challenges. arXiv:2510.23883 [cs.AI] https://arxiv.org/abs/2510.23883
[37] Zehang Deng, Yongjian Guo, Changzhou Han, Wanlun Ma, Junwu Xiong, Sheng Wen, and Yang Xiang. 2024. AI Agents Under Threat: A Survey of Key Security Challenges and Future Pathways. https://arxiv.org/abs/2406.02630
[38] Alexander DeRieux and Walid Saad. 2025. eQMARL: Entangled Quantum Multi-Agent Reinforcement Learning for Distributed Cooperation over Quantum Channels. arXiv:2405.17486 [quant-ph] https://arxiv.org/abs/2405.17486
[39] Dropzone AI. 2025. How AI Agents Will Transform the SOC of the Future. https://www.dropzone.ai/blog/how-ai-agents-will-transform-the-soc-of-the-future. Accessed: 2025-08-31.
[40] Abdelrahman Elewah and Khalid Elgazzar. 2025. Agentic Search Engine for Real-Time IoT Data (IoT-ASE). *arXiv preprint arXiv:2503.12255* (2025). https://arxiv.org/pdf/2503.12255v1
[41] Ivan Evtimov, Arman Zharmagambetov, Aaron Grattafiori, Chuan Guo, and Kamalika Chaudhuri. 2025. WASP: Benchmarking Web Agent Security Against Prompt Injection Attacks. https://arxiv.org/abs/2504.18575
[42] Exabeam. 2024. The Rise of AI Agents: A New Insider Threat You Can't Ignore. https://www.exabeam.com/blog/infosec-trends/the-rise-of-ai-agents-a-new-insider-threat-you-cant-ignore/ Accessed: 2025-09-08.
[43] Exabeam. 2025. *Agentic AI: How It Works and 7 Real-World Use Cases.* https://www.exabeam.com/explainers/ai-cyber-security/agentic-ai-how-it-works-and-7-real-world-use-cases/ Accessed: 2025-09-15.
[44] Falong Fan and Xi Li. 2025. PeerGuard: Defending Multi-Agent Systems Against Backdoor Attacks Through Mutual Reasoning. https://arxiv.org/abs/2505.11642
[45] Richard Fang, Dylan Bowman, and Daniel Kang. 2024. Voice-Enabled AI Agents can Perform Common Scams. https://arxiv.org/abs/2410.15650
[46] Shea Ferguson. 2025. A beginner's guide to sabotaging agentic AI. *TechMonitor* (2025). https://www.techmonitor.ai/technology/cybersecurity/agentic-ai-cybersecurity-implications Accessed: 2025-08-10.
[47] Fortinet, Inc. 2024. 2024 Global Cybersecurity Skills Gap Report. https://www.fortinet.com/content/dam/fortinet/assets/reports/2024-cybersecurity-skills-gap-report.pdf Accessed: 2025-08-23.
[48] Galileo AI. 2025. *Preventing LLM Unbounded Consumption.* https://galileo.ai/blog/prevent-llm-unbounded-consumption/ Accessed: 2025-09-21.
[49] Yuyou Gan and Others. 2024. Navigating the Risks: A Survey of Security, Privacy, and Ethics Threats in LLM-Based Agents. arXiv:2411.09523 [cs.AI] https://arxiv.org/abs/2411.09523
[50] Tarek Gasmi, Ramzi Guesmi, Ines Belhadj, and Jihene Bennaceur. 2025. Bridging AI and Software Security: A Comparative Vulnerability Assessment of LLM Agent Deployment Paradigms. https://arxiv.org/abs/2507.06323
[51] Suyash Gaurav, Jukka Heikkonen, and Jatin Chaudhary. 2025. Governance-as-a-Service: A Multi-Agent Framework for AI System Compliance and Policy Enforcement. https://arxiv.org/abs/2508.18765
[52] Diego Gosmar and Others. 2025. Prompt Injection Detection and Mitigation via AI Multi-Agent NLP Frameworks. https://arxiv.org/abs/2503.11517
[53] Abhishek Goswami. 2025. Agentic JWT: A Secure Delegation Protocol for Autonomous AI Agents. https://arxiv.org/abs/2509.13597
[54] Keltin Grimes, Julie Lawler, Robert Garrett, Emil Mathew, Marco Christiani, Sara Kingsley, and et al. 2025. *SOK: Bridging Research and Practice in LLM Agent Security.* Report. Carnegie Mellon University. doi:10.1184/R1/30610928.v1
[55] Yile Gu, Yifan Xiong, Jonathan Mace, Yuting Jiang, Yigong Hu, Baris Kasikci, and Peng Cheng. 2025. Argos: Agentic Time-Series Anomaly Detection with Autonomous Rule Generation via Large Language Models. https://arxiv.org/abs/2501.14170
[56] Qiming Guo, Jinwen Tang, and Xingran Huang. 2025. Attacking LLMs and AI Agents: Advertisement Embedding Attacks Against Large Language Models. https://arxiv.org/abs/2508.17674
[57] Halcyon. 2025. *Ransomware: The Sleeping Giant at Black Hat.* https://www.halcyon.ai/blog/ransomware-the-sleeping-giant-at-black-hat Accessed: 2025-09-08.
[58] Rich Harang and Martin Sablotny. 2025. Agentic Autonomy Levels and Security. https://developer.nvidia.com/blog/agentic-autonomy-levels-and-security/ Accessed: 2025-08-30.
[59] Feng He, Tianqing Zhu, Dayong Ye, Bo Liu, Wanlei Zhou, and Philip S. Yu. 2025. The Emerged Security and Privacy of LLM Agent: A Survey with Case Studies. *Comput. Surveys* 58, 6 (Dec. 2025), 1–36. doi:10.1145/3773080
[60] Xu He and Others. 2025. SentinelAgent: Graph-based Anomaly Detection in Multi-Agent Systems. https://arxiv.org/abs/2505.24201
[61] Yifeng He, Ethan Wang, Yuyang Rong, Zifei Cheng, and Hao Chen. 2024. Security of AI Agents. https://arxiv.org/abs/2406.08689
[62] Fred Heiding, Simon Lermen, Andrew Kao, Bruce Schneier, and Arun Vishwanath. 2024. Evaluating Large Language Models' Capability to Launch Fully Automated Spear Phishing Campaigns: Validated on Human Subjects. https://arxiv.org/abs/2412.00586

32 Sahaya Jestus Lazer, Kshitiz Aryal, Maanak Gupta, 以及 Elisa Bertino

[32] Cloud Security Alliance. 2025. *Introducing DIRF: A Comprehensive Framework for Protecting Digital Identities in Agentic AI Systems.* https://cloudsecurityalliance.org/blog/2025/08/27/introducing-dirf-a-comprehensive-framework-for-protecting-digital-identities-in-agentic-ai-systems Accessed: 2025-09-11.
[33] CrowdStrike. 2023. Red Team vs. Blue Team: What's the Difference? https://www.crowdstrike.com/en-us/cybersecurity-101/advisory-services/red-team-vs-blue-team/
[34] CSAW. 2024. Agentic Automated Capture-the-Flag (CTF). https://www.csaw.io/agentic-automated-ctf Accessed: 2025-09-08.
[35] Jian Cui, Zichuan Li, Luyi Xing, and Xiaojing Liao. 2025. Safeguard-by-Development: A Privacy-Enhanced Development Paradigm for Multi-Agent Collaboration Systems. https://arxiv.org/abs/2505.04799
[36] Shrestha Datta, Shahriar Kabir Nahin, Anshuman Chhabra, and Prasant Mohapatra. 2025. Agentic AI Security: Threats, Defenses, Evaluation, and Open Challenges. arXiv:2510.23883 [cs.AI] https://arxiv.org/abs/2510.23883
[37] Zehang Deng, Yongjian Guo, Changzhou Han, Wanlun Ma, Junwu Xiong, Sheng Wen, and Yang Xiang. 2024. AI Agents Under Threat: A Survey of Key Security Challenges and Future Pathways. https://arxiv.org/abs/2406.02630
[38] Alexander DeRieux and Walid Saad. 2025. eQMARL: Entangled Quantum Multi-Agent Reinforcement Learning for Distributed Cooperation over Quantum Channels. arXiv:2405.17486 [quant-ph] https://arxiv.org/abs/2405.17486
[39] Dropzone AI. 2025. How AI Agents Will Transform the SOC of the Future. https://www.dropzone.ai/blog/how-ai-agents-will-transform-the-soc-of-the-future. Accessed: 2025-08-31.
[40] Abdelrahman Elewah and Khalid Elgazzar. 2025. Agentic Search Engine for Real-Time IoT Data (IoT-ASE). *arXiv preprint arXiv:2503.12255* (2025). https://arxiv.org/pdf/2503.12255v1
[41] Ivan Evtimov, Arman Zharmagambetov, Aaron Grattafiori, Chuan Guo, and Kamalika Chaudhuri. 2025. WASP: Benchmarking Web Agent Security Against Prompt Injection Attacks. https://arxiv.org/abs/2504.18575
[42] Exabeam. 2024. The Rise of AI Agents: A New Insider Threat You Can't Ignore. https://www.exabeam.com/blog/infosec-trends/the-rise-of-ai-agents-a-new-insider-threat-you-cant-ignore/ Accessed: 2025-09-08.
[43] Exabeam. 2025. *Agentic AI: How It Works and 7 Real-World Use Cases.* https://www.exabeam.com/explainers/ai-cyber-security/agentic-ai-how-it-works-and-7-real-world-use-cases/ Accessed: 2025-09-15.
[44] Falong Fan and Xi Li. 2025. PeerGuard: Defending Multi-Agent Systems Against Backdoor Attacks Through Mutual Reasoning. https://arxiv.org/abs/2505.11642
[45] Richard Fang, Dylan Bowman, and Daniel Kang. 2024. Voice-Enabled AI Agents can Perform Common Scams. https://arxiv.org/abs/2410.15650
[46] Shea Ferguson. 2025. A beginner's guide to sabotaging agentic AI. *TechMonitor* (2025). https://www.techmonitor.ai/technology/cybersecurity/agentic-ai-cybersecurity-implications Accessed: 2025-08-10.
[47] Fortinet, Inc. 2024. 2024 Global Cybersecurity Skills Gap Report. https://www.fortinet.com/content/dam/fortinet/assets/reports/2024-cybersecurity-skills-gap-report.pdf Accessed: 2025-08-23.
[48] Galileo AI. 2025. *Preventing LLM Unbounded Consumption.* https://galileo.ai/blog/prevent-llm-unbounded-consumption/ Accessed: 2025-09-21.
[49] Yuyou Gan and Others. 2024. Navigating the Risks: A Survey of Security, Privacy, and Ethics Threats in LLM-Based Agents. arXiv:2411.09523 [cs.AI] https://arxiv.org/abs/2411.09523
[50] Tarek Gasmi, Ramzi Guesmi, Ines Belhadj, and Jihene Bennaceur. 2025. Bridging AI and Software Security: A Comparative Vulnerability Assessment of LLM Agent Deployment Paradigms. https://arxiv.org/abs/2507.06323
[51] Suyash Gaurav, Jukka Heikkonen, and Jatin Chaudhary. 2025. Governance-as-a-Service: A Multi-Agent Framework for AI System Compliance and Policy Enforcement. https://arxiv.org/abs/2508.18765
[52] Diego Gosmar and Others. 2025. Prompt Injection Detection and Mitigation via AI Multi-Agent NLP Frameworks. https://arxiv.org/abs/2503.11517
[53] Abhishek Goswami. 2025. Agentic JWT: A Secure Delegation Protocol for Autonomous AI Agents. https://arxiv.org/abs/2509.13597
[54] Keltin Grimes, Julie Lawler, Robert Garrett, Emil Mathew, Marco Christiani, Sara Kingsley, and et al. 2025. *SOK: Bridging Research and Practice in LLM Agent Security.* Report. Carnegie Mellon University. doi:10.1184/R1/30610928.v1
[55] Yile Gu, Yifan Xiong, Jonathan Mace, Yuting Jiang, Yigong Hu, Baris Kasikci, and Peng Cheng. 2025. Argos: Agentic Time-Series Anomaly Detection with Autonomous Rule Generation via Large Language Models. https://arxiv.org/abs/2501.14170
[56] Qiming Guo, Jinwen Tang, and Xingran Huang. 2025. Attacking LLMs and AI Agents: Advertisement Embedding Attacks Against Large Language Models. https://arxiv.org/abs/2508.17674
[57] Halcyon. 2025. *Ransomware: The Sleeping Giant at Black Hat.* https://www.halcyon.ai/blog/ransomware-the-sleeping-giant-at-black-hat Accessed: 2025-09-08.
[58] Rich Harang and Martin Sablotny. 2025. Agentic Autonomy Levels and Security. https://developer.nvidia.com/blog/agentic-autonomy-levels-and-security/ Accessed: 2025-08-30.
[59] Feng He, Tianqing Zhu, Dayong Ye, Bo Liu, Wanlei Zhou, and Philip S. Yu. 2025. The Emerged Security and Privacy of LLM Agent: A Survey with Case Studies. *Comput. Surveys* 58, 6 (Dec. 2025), 1–36. doi:10.1145/3773080
[60] Xu He and Others. 2025. SentinelAgent: Graph-based Anomaly Detection in Multi-Agent Systems. https://arxiv.org/abs/2505.24201
[61] Yifeng He, Ethan Wang, Yuyang Rong, Zifei Cheng, and Hao Chen. 2024. Security of AI Agents. https://arxiv.org/abs/2406.08689
[62] Fred Heiding, Simon Lermen, Andrew Kao, Bruce Schneier, and Arun Vishwanath. 2024. Evaluating Large Language Models' Capability to Launch Fully Automated Spear Phishing Campaigns: Validated on Human Subjects. https://arxiv.org/abs/2412.00586

Manuscript submitted to ACM

[63] Jack Hidary. 2025. Non-human identities: Agentic AI's new frontier of cybersecurity risk. https://www.weforum.org/stories/2025/10/non-human-identities-ai-cybersecurity/ World Economic Forum article, accessed 2025-12-25.
[64] Ritesh Honnalli and Junaid Farooq. 2025. LLM-Powered Agentic AI Approach to Securing EV Charging Systems Against Cyber Threats. In *2025 IEEE 26th International Symposium on a World of Wireless, Mobile and Multimedia Networks (WoWMoM)*. 266–274. doi:10.1109/WoWMoM65615.2025.00053
[65] Hoplon InfoSec. 2025. AI Penetration Testing Tools and Security Concerns. https://hoploninfosec.com/ai-pen-testing-tool-security-concerns Accessed: 2026-01-06.
[66] Ken Huang. 2025. Agentic AI Threat Modeling Framework: MAESTRO. Blog on the Cloud Security Alliance website. https://cloudsecurityalliance.org/blog/2025/02/06/agentic-ai-threat-modeling-framework-maestro# Written by Ken Huang, CEO & Chief AI Officer, DistributedApps.ai.
[67] Ken Huang, Vineeth Sai Narajala, Idan Habler, and Akram Sheriff. 2025. Agent Name Service (ANS): A Universal Directory for Secure AI Agent Discovery and Interoperability. https://arxiv.org/abs/2505.10609
[68] Ken Huang, Vineeth Sai Narajala, John Yeoh, Jason Ross, Ramesh Raskar, Youssef Harkati, Jerry Huang, Idan Habler, and Chris Hughes. 2025. A Novel Zero-Trust Identity Framework for Agentic AI: Decentralized Authentication and Fine-Grained Access Control. https://arxiv.org/abs/2505.19301
[69] IBM Corporation. 2025. Autonomous Threat Operations Machine (ATOM). https://www.ibm.com/services/autonomous-threat-operations Accessed: 2025-08-07.
[70] Ruochen Jiao and Others. 2025. Can We Trust Embodied Agents? Exploring Backdoor Attacks against Embodied LLM-Based Decision-Making Systems. In *The Thirteenth International Conference on Learning Representations*. https://openreview.net/forum?id=S1Bv3068Xt
[71] Sulbha Jindal. 2024. Agentic Misalignment. https://medium.com/@sulbha.jindal/agentic-misalignment-1238212c58e8 Accessed: 2025-09-08.
[72] Satyadhar Joshi. 2025. Advancing Cybersecurity Through Synergies of Agentic AI and High-Performance Computing. (2025). https://ssrn.com/abstract=5341131 SSRN Working Paper, Available at SSRN: https://ssrn.com/abstract=5341131.
[73] Neil Kale, Chen Bo Calvin Zhang, Kevin Zhu, Ankit Aich, Paula Rodriguez, Scale Red Team, Christina Q. Knight, and Zifan Wang. 2025. Reliable Weak-to-Strong Monitoring of LLM Agents. https://arxiv.org/abs/2508.19461
[74] Shivang Kalsi. 2025. SOC Investigation: How AI SOC Agents Solve Security Operations Center Challenges. Simbian.ai Blog. https://simbian.ai/blog/soc-investigation-ai-soc Online; accessed 2025-08-18.
[75] Sahil Kataria. 2025. The Birth of Agentic AI and Quantum-Resistant Cryptography: Security Beyond Tomorrow. https://www.fluxforce.ai/blog/agentic-ai-and-quantum-resistant-cryptography FluxForce AI blog article, accessed 2025-12-25.
[76] Raihan Khan, Sayak Sarkar, Sainik Kumar Mahata, and Edwin Jose. 2024. Security Threats in Agentic AI System. https://arxiv.org/abs/2410.14728
[77] Michael Khoury. 2025. AI, Quantum Computing and Other Emerging Risks. https://www.paloaltonetworks.com/blog/2025/10/ai-quantum-computing-emerging-risks/ Palo Alto Networks blog, accessed 2025-12-25.
[78] Hanna Kim and Others. 2025. When LLMs Go Online: The Emerging Threat of Web-Enabled LLMs. In *Proc. of the USENIX Security Symposium*.
[79] Charlie Klein. 2025. 7 Use Cases for AI Agents in Cybersecurity. https://www.jit.io/resources/devsecops/7-use-cases-for-ai-agents-in-cybersecurity Accessed: 2025-09-01.
[80] Anna Knack and Ant Burke. 2024. *Autonomous Cyber Defence: Authorised bounds for autonomous agents*. CETaS Briefing Paper. Centre for Emerging Technology and Security, The Alan Turing Institute. https://cetas.turing.ac.uk/publications/autonomous-cyber-defence-autonomous-agents
[81] Beata Kolecka, Igor Nai Fovino, Patricia Cabarcos, Gery Steri, Ignacio Sanchez, and Adam Lewis. 2025. Artificial intelligence, quantum and cybersecurity by 2040: Are we ready for the disruption?
[82] Dezhang Kong and Others. 2025. A Survey of LLM-Driven AI Agent Communication: Protocols, Security Risks, and Defense Countermeasures. arXiv:2506.19676 [cs.CR] https://arxiv.org/abs/2506.19676
[83] Tomek Korbak et al. 2025. Chain of Thought Monitorability: A New and Fragile Opportunity for AI Safety. https://arxiv.org/abs/2507.11473
[84] Nir Kshetri. 2025. Transforming cybersecurity with agentic AI to combat emerging cyber threats. *Telecommunications Policy* 49, 6 (2025), 102976. doi:10.1016/j.telpol.2025.102976
[85] Nir Kshetri and Jeffrey Voas. 2025. Agentic Artificial Intelligence for Cyber Threat Management. *Computer* 58, 5 (2025), 86–90. doi:10.1109/MC.2025.3544797
[86] Abhinav Kumar and Others. 2025. Throttling Web Agents Using Reasoning Gates. https://arxiv.org/abs/2509.01619
[87] Tharindu Kumarage and Others. 2025. Personalized Attacks of Social Engineering in Multi-turn Conversations: LLM Agents for Simulation and Detection. https://arxiv.org/abs/2503.15552
[88] Joe Kwon. 2025. *AI Agents: Governing Autonomy in the Digital Age*. https://www.centeraipolicy.org/work/ai-agents-governing-autonomy-in-the-digital-age Accessed: 2025-09-21.
[89] Kyndryl. 2025. Kyndryl Unveils Agentic AI Framework that Dynamically Evolves to Drive Enhanced Business Performance. Press release (PR Newswire). https://www.prnewswire.com/news-releases/kyndryl-unveils-agentic-ai-framework-that-dynamically-evolves-to-drive-enhanced-business-performance-302507958.html Accessed: 2025-09-11.
[90] Ravie Lakshmanan. 2025. Threat Actors Weaponize HexStrike-AI to Accelerate Vulnerability Exploitation. https://thehackernews.com/2025/09/threat-actors-weaponize-hexstrike-ai-to.html Accessed: 2026-01-06.
[91] Christoph R. Landolt, Christoph Würsch, Roland Meier, Alain Mermoud, and Julian Jang-Jaccard. 2025. Multi-Agent Reinforcement Learning in Cybersecurity: From Fundamentals to Applications. https://arxiv.org/abs/2505.19837
[92] Peiran Li, Xinkai Zou, Zhuohang Wu, Ruifeng Li, Shuo Xing, Hanwen Zheng, et al. 2025. SAFEFLOW: A Principled Protocol for Trustworthy and Transactional Autonomous Agent Systems. https://arxiv.org/abs/2506.07564

[63] Jack Hidary. 2025. Non-human identities: Agentic AI's new frontier of cybersecurity risk. https://www.weforum.org/stories/2025/10/non-human-identities-ai-cybersecurity/ World Economic Forum article, accessed 2025-12-25.
[64] Ritesh Honnalli and Junaid Farooq. 2025. LLM-Powered Agentic AI Approach to Securing EV Charging Systems Against Cyber Threats. In *2025 IEEE 26th International Symposium on a World of Wireless, Mobile and Multimedia Networks (WoWMoM)*. 266–274. doi:10.1109/WoWMoM65615.2025.00053
[65] Hoplon InfoSec. 2025. AI Penetration Testing Tools and Security Concerns. https://hoploninfosec.com/ai-pen-testing-tool-security-concerns Accessed: 2026-01-06.
[66] Ken Huang. 2025. Agentic AI Threat Modeling Framework: MAESTRO. Blog on the Cloud Security Alliance website. https://cloudsecurityalliance.org/blog/2025/02/06/agentic-ai-threat-modeling-framework-maestro# Written by Ken Huang, CEO & Chief AI Officer, DistributedApps.ai.
[67] Ken Huang, Vineeth Sai Narajala, Idan Habler, and Akram Sheriff. 2025. Agent Name Service (ANS): A Universal Directory for Secure AI Agent Discovery and Interoperability. https://arxiv.org/abs/2505.10609
[68] Ken Huang, Vineeth Sai Narajala, John Yeoh, Jason Ross, Ramesh Raskar, Youssef Harkati, Jerry Huang, Idan Habler, and Chris Hughes. 2025. A Novel Zero-Trust Identity Framework for Agentic AI: Decentralized Authentication and Fine-Grained Access Control. https://arxiv.org/abs/2505.19301
[69] IBM Corporation. 2025. Autonomous Threat Operations Machine (ATOM). https://www.ibm.com/services/autonomous-threat-operations Accessed: 2025-08-07.
[70] Ruochen Jiao and Others. 2025. Can We Trust Embodied Agents? Exploring Backdoor Attacks against Embodied LLM-Based Decision-Making Systems. In *The Thirteenth International Conference on Learning Representations*. https://openreview.net/forum?id=S1Bv3068Xt
[71] Sulbha Jindal. 2024. Agentic Misalignment. https://medium.com/@sulbha.jindal/agentic-misalignment-1238212c58e8 Accessed: 2025-09-08.
[72] Satyadhar Joshi. 2025. Advancing Cybersecurity Through Synergies of Agentic AI and High-Performance Computing. (2025). https://ssrn.com/abstract=5341131 SSRN Working Paper, Available at SSRN: https://ssrn.com/abstract=5341131.
[73] Neil Kale, Chen Bo Calvin Zhang, Kevin Zhu, Ankit Aich, Paula Rodriguez, Scale Red Team, Christina Q. Knight, and Zifan Wang. 2025. Reliable Weak-to-Strong Monitoring of LLM Agents. https://arxiv.org/abs/2508.19461
[74] Shivang Kalsi. 2025. SOC Investigation: How AI SOC Agents Solve Security Operations Center Challenges. Simbian.ai Blog. https://simbian.ai/blog/soc-investigation-ai-soc Online; accessed 2025-08-18.
[75] Sahil Kataria. 2025. The Birth of Agentic AI and Quantum-Resistant Cryptography: Security Beyond Tomorrow. https://www.fluxforce.ai/blog/agentic-ai-and-quantum-resistant-cryptography FluxForce AI blog article, accessed 2025-12-25.
[76] Raihan Khan, Sayak Sarkar, Sainik Kumar Mahata, and Edwin Jose. 2024. Security Threats in Agentic AI System. https://arxiv.org/abs/2410.14728
[77] Michael Khoury. 2025. AI, Quantum Computing and Other Emerging Risks. https://www.paloaltonetworks.com/blog/2025/10/ai-quantum-computing-emerging-risks/ Palo Alto Networks blog, accessed 2025-12-25.
[78] Hanna Kim and Others. 2025. When LLMs Go Online: The Emerging Threat of Web-Enabled LLMs. In *Proc. of the USENIX Security Symposium*.
[79] Charlie Klein. 2025. 7 Use Cases for AI Agents in Cybersecurity. https://www.jit.io/resources/devsecops/7-use-cases-for-ai-agents-in-cybersecurity Accessed: 2025-09-01.
[80] Anna Knack and Ant Burke. 2024. *Autonomous Cyber Defence: Authorised bounds for autonomous agents*. CETaS Briefing Paper. Centre for Emerging Technology and Security, The Alan Turing Institute. https://cetas.turing.ac.uk/publications/autonomous-cyber-defence-autonomous-agents
[81] Beata Kolecka, Igor Nai Fovino, Patricia Cabarcos, Gery Steri, Ignacio Sanchez, and Adam Lewis. 2025. Artificial intelligence, quantum and cybersecurity by 2040: Are we ready for the disruption?
[82] Dezhang Kong and Others. 2025. A Survey of LLM-Driven AI Agent Communication: Protocols, Security Risks, and Defense Countermeasures. arXiv:2506.19676 [cs.CR] https://arxiv.org/abs/2506.19676
[83] Tomek Korbak et al. 2025. Chain of Thought Monitorability: A New and Fragile Opportunity for AI Safety. https://arxiv.org/abs/2507.11473
[84] Nir Kshetri. 2025. Transforming cybersecurity with agentic AI to combat emerging cyber threats. *Telecommunications Policy* 49, 6 (2025), 102976. doi:10.1016/j.telpol.2025.102976
[85] Nir Kshetri and Jeffrey Voas. 2025. Agentic Artificial Intelligence for Cyber Threat Management. *Computer* 58, 5 (2025), 86–90. doi:10.1109/MC.2025.3544797
[86] Abhinav Kumar and Others. 2025. Throttling Web Agents Using Reasoning Gates. https://arxiv.org/abs/2509.01619
[87] Tharindu Kumarage and Others. 2025. Personalized Attacks of Social Engineering in Multi-turn Conversations: LLM Agents for Simulation and Detection. https://arxiv.org/abs/2503.15552
[88] Joe Kwon. 2025. *AI Agents: Governing Autonomy in the Digital Age*. https://www.centeraipolicy.org/work/ai-agents-governing-autonomy-in-the-digital-age Accessed: 2025-09-21.
[89] Kyndryl. 2025. Kyndryl Unveils Agentic AI Framework that Dynamically Evolves to Drive Enhanced Business Performance. Press release (PR Newswire). https://www.prnewswire.com/news-releases/kyndryl-unveils-agentic-ai-framework-that-dynamically-evolves-to-drive-enhanced-business-performance-302507958.html Accessed: 2025-09-11.
[90] Ravie Lakshmanan. 2025. Threat Actors Weaponize HexStrike-AI to Accelerate Vulnerability Exploitation. https://thehackernews.com/2025/09/threat-actors-weaponize-hexstrike-ai-to.html Accessed: 2026-01-06.
[91] Christoph R. Landolt, Christoph Würsch, Roland Meier, Alain Mermoud, and Julian Jang-Jaccard. 2025. Multi-Agent Reinforcement Learning in Cybersecurity: From Fundamentals to Applications. https://arxiv.org/abs/2505.19837
[92] Peiran Li, Xinkai Zou, Zhuohang Wu, Ruifeng Li, Shuo Xing, Hanwen Zheng, et al. 2025. SAFEFLOW: A Principled Protocol for Trustworthy and Transactional Autonomous Agent Systems. https://arxiv.org/abs/2506.07564

[93] Wenhao Li, Selvakumar Manickam, Yung wey Chong, and Shankar Karuppayah. 2025. PhishDebate: An LLM-Based Multi-Agent Framework for Phishing Website Detection. https://arxiv.org/abs/2506.15656
[94] Yanjie Li, Zhen Xiang, Nathaniel D. Bastian, Dawn Song, and Bo Li. 2025. IDS-Agent: An LLM Agent for Explainable Intrusion Detection in IoT Networks. https://openreview.net/forum?id=uuCcK4cmlH
[95] LiveView Technologies. 2025. *AI Security Automation with Agentic AI.* https://www.lvt.com/features/ai-security-automation Accessed: 2025-09-15.
[96] Johannes F. Loevenich and Others. 2024. Towards Robust and Secure Autonomous Cyber Defense Agents in Coalition Networks. In *IEEE Military Communications Conference.* doi:10.1109/MILCOM61039.2024.10773821
[97] Matteo Lupinacci, Francesco Blefari, Francesco Romeo, Francesco Aurelio Pironti, and Angelo Furfaro. 2025. *ARCeR: An Agentic RAG for the Automated Definition of Cyber Ranges.* Springer Nature Switzerland, 23–40. doi:10.1007/978-3-032-00630-1_2
[98] Matteo Lupinacci, Francesco Aurelio Pironti, Francesco Blefari, Francesco Romeo, Luigi Arena, and Angelo Furfaro. 2025. The Dark Side of LLMs: Agent-based Attacks for Complete Computer Takeover. https://arxiv.org/abs/2507.06850
[99] Xingjun Ma et al. 2025. Safety at Scale: A Comprehensive Survey of Large Model and Agent Safety. arXiv:2502.05206 [cs.CR]
[100] Jeremy McHugh, Kristina Šekrst, and Jon Cefalu. 2025. Prompt Injection 2.0: Hybrid AI Threats. https://arxiv.org/abs/2507.13169
[101] McKinsey & Company. 2025. *How agentic AI can change the way banks fight financial crime.* https://www.mckinsey.com/capabilities/risk-and-resilience/our-insights/how-agentic-ai-can-change-the-way-banks-fight-financial-crime Accessed September 14, 2025.
[102] Michelle Meineke. 2024. *The cybersecurity industry has an urgent talent shortage. Here's how to plug the gap.* World Economic Forum. https://www.weforum.org/stories/2024/04/cybersecurity-industry-talent-shortage-new-report/
[103] Metamirror Research Team. 2025. *Architecting a Unified Agent Policy for Delegated Authority in AI Ecosystems.* https://blog.metamirror.io/architecting-a-unified-agent-policy-for-delegated-authority-in-ai-ecosystems-befe268f4708 Accessed: 2025-09-21.
[104] Mezmo. 2025. *Agentic AI: What is Model Context Protocol, Agent2Agent and How Does This Impact Automation?* https://www.mezmo.com/learn-observability/agentic-ai-what-is-model-context-protocol-agent2agent-and-how-does-this-impact-automation Accessed: 2025-08-06.
[105] Mindgard. 2025. *AI Agent Security Challenges.* https://mindgard.ai/blog/ai-agent-security-challenges Accessed: 2025-09-21.
[106] Sean Mitchell. 2025. Quantum, agentic AI & Web 4.0 to transform cybersecurity. https://securitybrief.asia/story/quantum-agentic-ai-web-4-0-to-transform-cybersecurity SecurityBrief Asia article, accessed 2025-12-25.
[107] Sumeet Ramesh Motwani and Others. 2025. Secret Collusion among AI Agents: Multi-Agent Deception via Steganography. https://arxiv.org/abs/2402.07510
[108] Attila Nagy, Yue Wu, Ács Szilvia, Beatrix Fregan, and Zoltan Rajnai. 2025. Quantum Machine Learning-Based Intrusion Detection: A Comparative Study on Real Quantum Hardware. 000083–000088. doi:10.1109/SISY67000.2025.11205415
[109] Katsuaki Nakano, Reza Feyyazi, Shanchieh Jay Yang, and Michael Zuzak. 2025. Guided Reasoning in LLM-Driven Penetration Testing Using Structured Attack Trees. https://arxiv.org/abs/2509.07939
[110] Vineeth Sai Narajala, Ken Huang, and Idan Habler. 2025. Securing GenAI Multi-Agent Systems Against Tool Squatting: A Zero Trust Registry-Based Approach. https://arxiv.org/abs/2504.19951
[111] Vineeth Sai Narajala and Om Narayan. 2025. Securing Agentic AI: A Comprehensive Threat Model and Mitigation Framework for Generative AI Agents. https://arxiv.org/abs/2504.19956
[112] Nordic APIs. 2025. *How AI Agents Are Changing API Rate Limit Approaches.* https://nordicapis.com/how-ai-agents-are-changing-api-rate-limit-approaches/ Accessed: 2025-09-21.
[113] NVIDIA. 2025. *Securing Agentic AI: How Semantic Prompt Injections Bypass Guardrails.* https://developer.nvidia.com/blog/securing-agentic-ai-how-semantic-prompt-injections-bypass-ai-guardrails/ Accessed: 2025-09-21.
[114] Sean Oesch, Phillipe Austria, Amul Chaulagain, Brian Weber, Cory Watson, Matthew Dixson, and Amir Sadovnik. 2024. The Path To Autonomous Cyber Defense. https://arxiv.org/abs/2404.10788
[115] Sean Oesch, Amul Chaulagain, Brian Weber, Matthew Dixson, Amir Sadovnik, Benjamin Roberson, and Others. 2024. Towards a High Fidelity Training Environment for Autonomous Cyber Defense Agents. In *Proc. of the ACM 17th Cyber Security Experimentation and Test Workshop.*
[116] Sean Oesch, Jack Hutchins, Phillipe Austria, and Amul Chaulagain. 2025. Agentic AI and the Cyber Arms Race. https://arxiv.org/abs/2503.04760
[117] Okta. 2025. *What is Agentic AI? Securing Autonomous Agents.* https://www.okta.com/identity-101/what-is-agentic-ai/ Accessed: 2025-09-21.
[118] OWASP Agentic Security Initiative. 2025. *Agentic AI – Threats and Mitigations.* Technical Report, Version 1.0. OWASP. https://www.aigl.blog/content/files/2025/04/Agentic-AI---Threats-and-Mitigations.pdf
[119] OWASP Foundation. 2024. FinBot Agentic AI Capture-the-Flag (CTF) Application. https://genai.owasp.org/resource/finbot-agentic-ai-capture-the-flag-ctf-application/ Accessed: 2025-09-08.
[120] Ciprian Paduraru, Catalina Patilea, and Alin Stefanescu. 2025. CyberGuardian 2: Integrating LLMs and Agentic AI Assistants for Securing Distributed Networks. 660–667. doi:10.5220/0013406000003928
[121] Palo Alto Networks. 2025. AI Agents Are Here. So Are the Threats. https://unit42.paloaltonetworks.com/agentic-ai-threats/. Accessed: 2025-08-30.
[122] Palo Alto Networks. 2025. Unit 42 Develops Agentic AI Attack Framework. https://www.paloaltonetworks.com/blog/2025/05/unit-42-develops-agentic-ai-attack-framework/. Accessed: 2025-08-30.
[123] Pierre Peigne-Lefebvre and Others. 2025. Multi-Agent Security Tax: Trading Off Security and Collaboration Capabilities in Multi-Agent Systems. https://arxiv.org/abs/2502.19145

[93] Wenhao Li, Selvakumar Manickam, Yung wey Chong, and Shankar Karuppayah. 2025. PhishDebate: An LLM-Based Multi-Agent Framework for Phishing Website Detection. https://arxiv.org/abs/2506.15656
[94] Yanjie Li, Zhen Xiang, Nathaniel D. Bastian, Dawn Song, and Bo Li. 2025. IDS-Agent: An LLM Agent for Explainable Intrusion Detection in IoT Networks. https://openreview.net/forum?id=uuCcK4cmlH
[95] LiveView Technologies. 2025. *AI Security Automation with Agentic AI.* https://www.lvt.com/features/ai-security-automation Accessed: 2025-09-15.
[96] Johannes F. Loevenich and Others. 2024. Towards Robust and Secure Autonomous Cyber Defense Agents in Coalition Networks. In *IEEE Military Communications Conference.* doi:10.1109/MILCOM61039.2024.10773821
[97] Matteo Lupinacci, Francesco Blefari, Francesco Romeo, Francesco Aurelio Pironti, and Angelo Furfaro. 2025. *ARCeR: An Agentic RAG for the Automated Definition of Cyber Ranges.* Springer Nature Switzerland, 23–40. doi:10.1007/978-3-032-00630-1_2
[98] Matteo Lupinacci, Francesco Aurelio Pironti, Francesco Blefari, Francesco Romeo, Luigi Arena, and Angelo Furfaro. 2025. The Dark Side of LLMs: Agent-based Attacks for Complete Computer Takeover. https://arxiv.org/abs/2507.06850
[99] Xingjun Ma et al. 2025. Safety at Scale: A Comprehensive Survey of Large Model and Agent Safety. arXiv:2502.05206 [cs.CR]
[100] Jeremy McHugh, Kristina Šekrst, and Jon Cefalu. 2025. Prompt Injection 2.0: Hybrid AI Threats. https://arxiv.org/abs/2507.13169
[101] McKinsey & Company. 2025. *How agentic AI can change the way banks fight financial crime.* https://www.mckinsey.com/capabilities/risk-and-resilience/our-insights/how-agentic-ai-can-change-the-way-banks-fight-financial-crime Accessed September 14, 2025.
[102] Michelle Meineke. 2024. *The cybersecurity industry has an urgent talent shortage. Here's how to plug the gap.* World Economic Forum. https://www.weforum.org/stories/2024/04/cybersecurity-industry-talent-shortage-new-report/
[103] Metamirror Research Team. 2025. *Architecting a Unified Agent Policy for Delegated Authority in AI Ecosystems.* https://blog.metamirror.io/architecting-a-unified-agent-policy-for-delegated-authority-in-ai-ecosystems-befe268f4708 Accessed: 2025-09-21.
[104] Mezmo. 2025. *Agentic AI: What is Model Context Protocol, Agent2Agent and How Does This Impact Automation?* https://www.mezmo.com/learn-observability/agentic-ai-what-is-model-context-protocol-agent2agent-and-how-does-this-impact-automation Accessed: 2025-08-06.
[105] Mindgard. 2025. *AI Agent Security Challenges.* https://mindgard.ai/blog/ai-agent-security-challenges Accessed: 2025-09-21.
[106] Sean Mitchell. 2025. Quantum, agentic AI & Web 4.0 to transform cybersecurity. https://securitybrief.asia/story/quantum-agentic-ai-web-4-0-to-transform-cybersecurity SecurityBrief Asia article, accessed 2025-12-25.
[107] Sumeet Ramesh Motwani and Others. 2025. Secret Collusion among AI Agents: Multi-Agent Deception via Steganography. https://arxiv.org/abs/2402.07510
[108] Attila Nagy, Yue Wu, Ács Szilvia, Beatrix Fregan, and Zoltan Rajnai. 2025. Quantum Machine Learning-Based Intrusion Detection: A Comparative Study on Real Quantum Hardware. 000083–000088. doi:10.1109/SISY67000.2025.11205415
[109] Katsuaki Nakano, Reza Feyyazi, Shanchieh Jay Yang, and Michael Zuzak. 2025. Guided Reasoning in LLM-Driven Penetration Testing Using Structured Attack Trees. https://arxiv.org/abs/2509.07939
[110] Vineeth Sai Narajala, Ken Huang, and Idan Habler. 2025. Securing GenAI Multi-Agent Systems Against Tool Squatting: A Zero Trust Registry-Based Approach. https://arxiv.org/abs/2504.19951
[111] Vineeth Sai Narajala and Om Narayan. 2025. Securing Agentic AI: A Comprehensive Threat Model and Mitigation Framework for Generative AI Agents. https://arxiv.org/abs/2504.19956
[112] Nordic APIs. 2025. *How AI Agents Are Changing API Rate Limit Approaches.* https://nordicapis.com/how-ai-agents-are-changing-api-rate-limit-approaches/ Accessed: 2025-09-21.
[113] NVIDIA. 2025. *Securing Agentic AI: How Semantic Prompt Injections Bypass Guardrails.* https://developer.nvidia.com/blog/securing-agentic-ai-how-semantic-prompt-injections-bypass-ai-guardrails/ Accessed: 2025-09-21.
[114] Sean Oesch, Phillipe Austria, Amul Chaulagain, Brian Weber, Cory Watson, Matthew Dixson, and Amir Sadovnik. 2024. The Path To Autonomous Cyber Defense. https://arxiv.org/abs/2404.10788
[115] Sean Oesch, Amul Chaulagain, Brian Weber, Matthew Dixson, Amir Sadovnik, Benjamin Roberson, and Others. 2024. Towards a High Fidelity Training Environment for Autonomous Cyber Defense Agents. In *Proc. of the ACM 17th Cyber Security Experimentation and Test Workshop.*
[116] Sean Oesch, Jack Hutchins, Phillipe Austria, and Amul Chaulagain. 2025. Agentic AI and the Cyber Arms Race. https://arxiv.org/abs/2503.04760
[117] Okta. 2025. *What is Agentic AI? Securing Autonomous Agents.* https://www.okta.com/identity-101/what-is-agentic-ai/ Accessed: 2025-09-21.
[118] OWASP Agentic Security Initiative. 2025. *Agentic AI – Threats and Mitigations.* Technical Report, Version 1.0. OWASP. https://www.aigl.blog/content/files/2025/04/Agentic-AI---Threats-and-Mitigations.pdf
[119] OWASP Foundation. 2024. FinBot Agentic AI Capture-the-Flag (CTF) Application. https://genai.owasp.org/resource/finbot-agentic-ai-capture-the-flag-ctf-application/ Accessed: 2025-09-08.
[120] Ciprian Paduraru, Catalina Patilea, and Alin Stefanescu. 2025. CyberGuardian 2: Integrating LLMs and Agentic AI Assistants for Securing Distributed Networks. 660–667. doi:10.5220/0013406000003928
[121] Palo Alto Networks. 2025. AI Agents Are Here. So Are the Threats. https://unit42.paloaltonetworks.com/agentic-ai-threats/. Accessed: 2025-08-30.
[122] Palo Alto Networks. 2025. Unit 42 Develops Agentic AI Attack Framework. https://www.paloaltonetworks.com/blog/2025/05/unit-42-develops-agentic-ai-attack-framework/. Accessed: 2025-08-30.
[123] Pierre Peigne-Lefebvre and Others. 2025. Multi-Agent Security Tax: Trading Off Security and Collaboration Capabilities in Multi-Agent Systems. https://arxiv.org/abs/2502.19145

[124] Sai Santhosh Polagani. 2025. Agentic AI for Cybersecurity and Risk Management (Autonomous AI for Fraud Detection, Compliance, And Threat Mitigations). *IRE Journals* 8, 10 (2025). https://www.irejournals.com/formatedpaper/1707702.pdf Accessed: 2025-09-21.
[125] Erik Pounds. 2024. What Is Agentic AI? https://blogs.nvidia.com/blog/what-is-agentic-ai/
[126] Davis Prosper. 2025. Integrating Reinforcement Learning and Agentic AI for Adaptive IoT Security Frameworks. https://www.researchgate.net/publication/394880726_Integrating_Reinforcement_Learning_and_Agentic_AI_for_Adaptive_IoT_Security_Frameworks Preprint.
[127] Rajesh Ranjan, Shailja Gupta, and Surya Narayan Singh. 2025. LOKA Protocol: A Decentralized Framework for Trustworthy and Ethical AI Agent Ecosystems. https://arxiv.org/abs/2504.10915
[128] Ramesh Raskar et al. 2025. Beyond DNS: Unlocking the Internet of AI Agents via the NANDA Index and Verified AgentFacts. https://arxiv.org/abs/2507.14263
[129] Shaina Raza and Others. 2025. Responsible Agentic Reasoning and AI Agents: A Critical Survey. (2025). doi:10.36227/techrxiv.175735299.97215847/v3
[130] Shaina Raza and Others. 2025. TRiSM for Agentic AI: A Review of Trust, Risk, and Security Management in LLM-based Agentic Multi-Agent Systems. https://arxiv.org/abs/2506.04133
[131] Red Canary. 2025. Agentic AI in Cybersecurity: Autonomous Detection, Containment, and Remediation. https://redcanary.com/cybersecurity-101/security-operations/agentic-ai/ Accessed: 2025-09-08.
[132] Red Canary. 2025. *Security Operations and Agentic AI.* https://redcanary.com/cybersecurity-101/security-operations/agentic-ai/ Accessed: 2025-09-08.
[133] ReliaQuest. 2025. AI SOC Agents: AI Agents in Security Operations. https://reliaquest.com/cyber-knowledge/ai-soc-agents-ai-agents-in-security-operations/
[134] Siva Sai, Ishika Goyal, Shubham Sharma, Sri Harshita Manuri, Vinay Chamola, and Rajkumar Buyya. 2025. Quantum Machine Learning for Cybersecurity: A Taxonomy and Future Directions. arXiv:2512.15286 [cs.LG] https://arxiv.org/abs/2512.15286
[135] SANS Institute. 2024. From Assistant to Adversary: When Agentic AI Becomes an Insider Threat. https://www.sans.org/presentations/from-assistant-to-adversary-when-agentic-ai-becomes-an-insider-threat Accessed: 2025-09-08.
[136] Johannes Schneider. 2025. Generative to Agentic AI: Survey, Conceptualization, and Challenges. https://arxiv.org/abs/2504.18875
[137] Christian Schroeder de Witt. 2025. Open Challenges in Multi-Agent Security: Towards Secure Systems of Interacting AI Agents. https://www.alphaxiv.org/abs/2505.02077v1 Preprint.
[138] Rob Schwartz. 2025. *AI agents expected to transform security operations centers by 2027, Gartner says.* https://www.cybersecuritydive.com/news/artificial-intelligence-ai-agents-security-operations-center-gartner/750370/ Accessed: 2025-08-31.
[139] Asif Shahriar, Md Nafiu Rahman, Sadif Ahmed, Farig Sadeque, and Md Rizwan Parvez. 2025. A Survey on Agentic Security: Applications, Threats and Defenses. arXiv:2510.06445 [cs.CL] https://arxiv.org/abs/2510.06445
[140] Minghao Shao et al. 2025. CRAKEN: Cybersecurity LLM Agent with Knowledge-Based Execution. https://arxiv.org/abs/2505.17107
[141] Arfan Sharif. 2022. What Is Continuous Monitoring? https://www.crowdstrike.com/en-us/cybersecurity-101/next-gen-siem/continuous-monitoring/
[142] Yonadav Shavit, Sandhini Agarwal, Miles Brundage, Steven Adler, Cullen O'Keefe, Rosie Campbell, Teddy Lee, Pamela Mishkin, Tyna Eloundou, Alan Hickey, Katarina Slama, Lama Ahmad, Paul McMillan, Andrea Vallone, Alexandre Passos, and David G. Robinson. 2023. Practices for Governing Agentic AI Systems. https://openai.com/index/practices-for-governing-agentic-ai-systems/
[143] Yonadav Shavit, Sandhini Agarwal, Miles Brundage, Cullen O'Keefe, Rosie Campbell, et al. 2023. Practices for Governing Agentic AI Systems. https://openai.com/index/practices-for-governing-agentic-ai-systems/ White Paper.
[144] David Shi and Kevin Joo. 2025. Horus: A Protocol for Trustless Verification Under Uncertainty. https://arxiv.org/abs/2507.00631
[145] Simbian. 2025. AI Agents in Cybersecurity: An Opportunity to Solve Security with AI. https://simbian.ai/resources/white-papers/ai-agents-in-cybersecurity White Paper, accessed 2025-08-31.
[146] SolutionsReview Editorial Team. 2025. *The Top AI Agents for Cybersecurity Teams.* https://solutionsreview.com/endpoint-security/the-top-ai-agents-for-cybersecurity-teams/ Accessed: 2025-09-15.
[147] Tobin South, Samuele Marro, Thomas Hardjono, Robert Mahari, Cedric Deslandes Whitney, Dazza Greenwood, Alan Chan, and Alex Pentland. 2025. Authenticated Delegation and Authorized AI Agents. https://arxiv.org/abs/2501.09674
[148] Spirl. 2025. *Securing AI Agents in the Real World: A Case Study on Workload Identity.* https://www.spirl.com/blog/securing-ai-agents-in-the-real-world-a-case-study Accessed: 2025-09-21.
[149] Johannes Start and John Lunney. 2025. Adaptive Computational Budgeting for AI Agents in Collaborative Environments. Technical Disclosure Commons. https://www.tdcommons.org/dpubs_series/8602
[150] Strata Identity. 2025. *Why AI Agents Deserve First-Class Identity Management.* https://www.strata.io/blog/agentic-identity/why-ai-agents-deserve-first-class-identity-management-7b/ Accessed: 2025-09-21.
[151] Sri Keerthi Suggu. 2025. Agentic AI Workflows in Cybersecurity: Opportunities, Challenges, and Governance via the MCP Model. *Journal of Information Systems and Emerging Management (JISEM)* 10, 52s (2025). doi:10.52783/jisem.v10i52s.10767
[152] Eldar Sultanow and Others. 2025. Quantum Agents. (6 2025). arXiv:2506.01536 [quant-ph]
[153] Swimlane. 2025. Agentic AI & Cybersecurity: A Powerful Partnership in 2025. https://swimlane.com/blog/agentic-ai/ Accessed: 2025-08-12.
[154] Georgios Syros, Anshuman Suri, Jacob Ginesin, Cristina Nita-Rotaru, and Alina Oprea. 2025. SAGA: A Security Architecture for Governing AI Agentic Systems. https://arxiv.org/abs/2504.21034

[124] Sai Santhosh Polagani. 2025. Agentic AI for Cybersecurity and Risk Management (Autonomous AI for Fraud Detection, Compliance, And Threat Mitigations). *IRE Journals* 8, 10 (2025). https://www.irejournals.com/formatedpaper/1707702.pdf Accessed: 2025-09-21.
[125] Erik Pounds. 2024. What Is Agentic AI? https://blogs.nvidia.com/blog/what-is-agentic-ai/
[126] Davis Prosper. 2025. Integrating Reinforcement Learning and Agentic AI for Adaptive IoT Security Frameworks. https://www.researchgate.net/publication/394880726_Integrating_Reinforcement_Learning_and_Agentic_AI_for_Adaptive_IoT_Security_Frameworks Preprint.
[127] Rajesh Ranjan, Shailja Gupta, and Surya Narayan Singh. 2025. LOKA Protocol: A Decentralized Framework for Trustworthy and Ethical AI Agent Ecosystems. https://arxiv.org/abs/2504.10915
[128] Ramesh Raskar et al. 2025. Beyond DNS: Unlocking the Internet of AI Agents via the NANDA Index and Verified AgentFacts. https://arxiv.org/abs/2507.14263
[129] Shaina Raza and Others. 2025. Responsible Agentic Reasoning and AI Agents: A Critical Survey. (2025). doi:10.36227/techrxiv.175735299.97215847/v3
[130] Shaina Raza and Others. 2025. TRiSM for Agentic AI: A Review of Trust, Risk, and Security Management in LLM-based Agentic Multi-Agent Systems. https://arxiv.org/abs/2506.04133
[131] Red Canary. 2025. Agentic AI in Cybersecurity: Autonomous Detection, Containment, and Remediation. https://redcanary.com/cybersecurity-101/security-operations/agentic-ai/ Accessed: 2025-09-08.
[132] Red Canary. 2025. *Security Operations and Agentic AI.* https://redcanary.com/cybersecurity-101/security-operations/agentic-ai/ Accessed: 2025-09-08.
[133] ReliaQuest. 2025. AI SOC Agents: AI Agents in Security Operations. https://reliaquest.com/cyber-knowledge/ai-soc-agents-ai-agents-in-security-operations/
[134] Siva Sai, Ishika Goyal, Shubham Sharma, Sri Harshita Manuri, Vinay Chamola, and Rajkumar Buyya. 2025. Quantum Machine Learning for Cybersecurity: A Taxonomy and Future Directions. arXiv:2512.15286 [cs.LG] https://arxiv.org/abs/2512.15286
[135] SANS Institute. 2024. From Assistant to Adversary: When Agentic AI Becomes an Insider Threat. https://www.sans.org/presentations/from-assistant-to-adversary-when-agentic-ai-becomes-an-insider-threat Accessed: 2025-09-08.
[136] Johannes Schneider. 2025. Generative to Agentic AI: Survey, Conceptualization, and Challenges. https://arxiv.org/abs/2504.18875
[137] Christian Schroeder de Witt. 2025. Open Challenges in Multi-Agent Security: Towards Secure Systems of Interacting AI Agents. https://www.alphaxiv.org/abs/2505.02077v1 Preprint.
[138] Rob Schwartz. 2025. *AI agents expected to transform security operations centers by 2027, Gartner says.* https://www.cybersecuritydive.com/news/artificial-intelligence-ai-agents-security-operations-center-gartner/750370/ Accessed: 2025-08-31.
[139] Asif Shahriar, Md Nafiu Rahman, Sadif Ahmed, Farig Sadeque, and Md Rizwan Parvez. 2025. A Survey on Agentic Security: Applications, Threats and Defenses. arXiv:2510.06445 [cs.CL] https://arxiv.org/abs/2510.06445
[140] Minghao Shao et al. 2025. CRAKEN: Cybersecurity LLM Agent with Knowledge-Based Execution. https://arxiv.org/abs/2505.17107
[141] Arfan Sharif. 2022. What Is Continuous Monitoring? https://www.crowdstrike.com/en-us/cybersecurity-101/next-gen-siem/continuous-monitoring/
[142] Yonadav Shavit, Sandhini Agarwal, Miles Brundage, Steven Adler, Cullen O'Keefe, Rosie Campbell, Teddy Lee, Pamela Mishkin, Tyna Eloundou, Alan Hickey, Katarina Slama, Lama Ahmad, Paul McMillan, Andrea Vallone, Alexandre Passos, and David G. Robinson. 2023. Practices for Governing Agentic AI Systems. https://openai.com/index/practices-for-governing-agentic-ai-systems/
[143] Yonadav Shavit, Sandhini Agarwal, Miles Brundage, Cullen O'Keefe, Rosie Campbell, et al. 2023. Practices for Governing Agentic AI Systems. https://openai.com/index/practices-for-governing-agentic-ai-systems/ White Paper.
[144] David Shi and Kevin Joo. 2025. Horus: A Protocol for Trustless Verification Under Uncertainty. https://arxiv.org/abs/2507.00631
[145] Simbian. 2025. AI Agents in Cybersecurity: An Opportunity to Solve Security with AI. https://simbian.ai/resources/white-papers/ai-agents-in-cybersecurity White Paper, accessed 2025-08-31.
[146] SolutionsReview Editorial Team. 2025. *The Top AI Agents for Cybersecurity Teams.* https://solutionsreview.com/endpoint-security/the-top-ai-agents-for-cybersecurity-teams/ Accessed: 2025-09-15.
[147] Tobin South, Samuele Marro, Thomas Hardjono, Robert Mahari, Cedric Deslandes Whitney, Dazza Greenwood, Alan Chan, and Alex Pentland. 2025. Authenticated Delegation and Authorized AI Agents. https://arxiv.org/abs/2501.09674
[148] Spirl. 2025. *Securing AI Agents in the Real World: A Case Study on Workload Identity.* https://www.spirl.com/blog/securing-ai-agents-in-the-real-world-a-case-study Accessed: 2025-09-21.
[149] Johannes Start and John Lunney. 2025. Adaptive Computational Budgeting for AI Agents in Collaborative Environments. Technical Disclosure Commons. https://www.tdcommons.org/dpubs_series/8602
[150] Strata Identity. 2025. *Why AI Agents Deserve First-Class Identity Management.* https://www.strata.io/blog/agentic-identity/why-ai-agents-deserve-first-class-identity-management-7b/ Accessed: 2025-09-21.
[151] Sri Keerthi Suggu. 2025. Agentic AI Workflows in Cybersecurity: Opportunities, Challenges, and Governance via the MCP Model. *Journal of Information Systems and Emerging Management (JISEM)* 10, 52s (2025). doi:10.52783/jisem.v10i52s.10767
[152] Eldar Sultanow and Others. 2025. Quantum Agents. (6 2025). arXiv:2506.01536 [quant-ph]
[153] Swimlane. 2025. Agentic AI & Cybersecurity: A Powerful Partnership in 2025. https://swimlane.com/blog/agentic-ai/ Accessed: 2025-08-12.
[154] Georgios Syros, Anshuman Suri, Jacob Ginesin, Cristina Nita-Rotaru, and Alina Oprea. 2025. SAGA: A Security Architecture for Governing AI Agentic Systems. https://arxiv.org/abs/2504.21034

[155] Krti Tallam. 2025. Transforming Cyber Defense: Harnessing Agentic and Frontier AI for Proactive, Ethical Threat Intelligence. doi:10.48550/arXiv.2503.00164
[156] Trend Micro Research. 2025. Using Agentic AI & Digital Twin for Cyber Resilience. https://www.trendmicro.com/en_us/research/25/e/ai-digital-twin-cyber-resilience.html Accessed: 2025-08-15.
[157] Trustwise. 2024. Capture-the-Flag Security in Legal Technology. https://trustwise.ai/capture-the-flag-security-in-legal-technology/ Accessed: 2025-09-08.
[158] Prashant Vajpayee and Gahangir Hossain. 2025. Cyber Defense through Agentic AI Enabled Automation: An Approach to Reduce Cyber Risk. Association for Computing Machinery, New York, NY, USA. doi:10.1145/3716489.3728439
[159] Varonis. 2024. Detecting Agentic AI Threats. https://www.varonis.com/blog/detecting-agentic-ai-threats Accessed: 2025-09-08.
[160] VentureBeat. 2025. Black Hat 2025: How Agentic AI is Finally Delivering Real Value. https://venturebeat.com/security/black-hat-2025-how-agentic-ai-is-finally-delivering-real-value Accessed: 2025-09-08.
[161] Visa Acceptance Solutions. 2025. *Payment Trends Update: How AI and Agentic AI Impact Fraud.* https://www.visaacceptance.com/en-us/blog/article/2025/agentic-ai-fraud-impact.html Accessed September 14, 2025.
[162] Ngoc Tuong Vy Nguyen, Felix D Childress, and Yunting Yin. 2025. Debate-Driven Multi-Agent LLMs for Phishing Email Detection. In *2025 13th International Symposium on Digital Forensics and Security (ISDFS)*. IEEE. doi:10.1109/isdfs65363.2025.11012014
[163] Kun Wang et al. 2025. A Comprehensive Survey in LLM(-Agent) Full Stack Safety: Data, Training and Deployment. https://arxiv.org/abs/2504.15585
[164] Zhun Wang, Vincent Siu, Zhe Ye, Tianneng Shi, Yuzhou Nie, Xuandong Zhao, Chenguang Wang, Wenbo Guo, and Dawn Song. 2025. AgentVigil: Generic Black-Box Red-teaming for Indirect Prompt Injection against LLM Agents. https://arxiv.org/abs/2505.05849
[165] Haiman Wong and Tiffany Saade. 2025. *The Rise of AI Agents: Anticipating Cybersecurity Opportunities, Risks, and the Next Frontier.* R Street Policy Study No. 325. R Street Institute. https://www.rstreet.org/wp-content/uploads/2025/05/FINAL-r-street-policy-study-no-325.pdf
[166] WunderGraph. 2025. *Harm Limiting for API Access.* https://wundergraph.com/blog/harm_limiting_for_api_access Accessed: 2025-09-21.
[167] Minrui Xu and Others. 2025. Forewarned is Forearmed: A Survey on Large Language Model-based Agents in Autonomous Cyberattacks. arXiv:2505.12786 [cs.NI]
[168] Yinuo Xue, Eric Spero, Yun Sing Koh, and Giovanni Russello. 2025. MultiPhishGuard: An LLM-based Multi-Agent System for Phishing Email Detection. https://arxiv.org/abs/2505.23803
[169] Yi Yang, Yitong Ma, Hao Feng, Yiming Cheng, and Zhu Han. 2025. Minimizing Hallucinations and Communication Costs: Adversarial Debate and Voting Mechanisms in LLM-Based Multi-Agents. *Applied Sciences* 15, 7 (2025). doi:10.3390/app15073676
[170] Shunyu Yao and Others. 2023. ReAct: Synergizing Reasoning and Acting in Language Models. https://arxiv.org/abs/2210.03629
[171] Miao Yu and Others. 2025. A Survey on Trustworthy LLM Agents: Threats and Countermeasures. arXiv:2503.09648 https://arxiv.org/abs/2503.09648
[172] Wenhan Yu and Jun Zhao. 2023. Quantum Multi-Agent Reinforcement Learning as an Emerging AI Technology: A Survey and Future Directions. In *2023 International Conference on Computer and Applications (ICCA)*. 1–7. doi:10.1109/ICCA59364.2023.10401605
[173] Pallavi Zambare and Others. 2025. NetMoniAI: An Agentic AI Framework for Network Security & Monitoring. https://arxiv.org/abs/2508.10052
[174] Pallavi Zambare, Venkata Nikhil Thanikella, and Ying Liu. 2025. Securing Agentic AI: Threat Modeling and Risk Analysis for Network Monitoring Agentic AI System. https://arxiv.org/abs/2508.10043
[175] Lingfeng Zeng et al. 2025. FinGAIA: A Chinese Benchmark for AI Agents in Real-World Financial Domain. https://arxiv.org/abs/2507.17186
[176] Andy K. Zhang et al. 2025. BountyBench: Dollar Impact of AI Agent Attackers and Defenders on Real-World Cybersecurity Systems. https://arxiv.org/abs/2505.15216
[177] Hanrong Zhang and Others. 2025. Agent Security Bench (ASB): Formalizing and Benchmarking Attacks and Defenses in LLM-based Agents. https://arxiv.org/abs/2410.02644
[178] Jiaqi Zhang, Chen Gao, Liyuan Zhang, Yong Li, and Hongzhi Yin. 2025. SmartAgent: Chain-of-User-Thought for Embodied Personalized Agent in Cyber World. https://arxiv.org/abs/2412.07472
[179] Jiawei Zhang, Shuang Yang, and Bo Li. 2025. UDora: A Unified Red Teaming Framework against LLM Agents by Dynamically Hijacking Their Own Reasoning. https://arxiv.org/abs/2503.01908
[180] Qingzhao Zhang, Ziyang Xiong, and Z. Morley Mao. 2025. LLM Safeguard is a Double-Edged Sword: Exploiting False Positives for Denial-of-Service Attacks. https://arxiv.org/abs/2410.02916
[181] Wei Zhang and Others. 2025. Penetration Testing for System Security: Methods and Practical Approaches. https://arxiv.org/abs/2505.19174
[182] Yuyang Zhang and Others. 2025. Towards Action Hijacking of Large Language Model-based Agent. https://arxiv.org/abs/2412.10807
[183] Yuanhe Zhang, Zhenhong Zhou, Wei Zhang, Xinyue Wang, Xiaojun Jia, Yang Liu, and Sen Su. 2025. Crabs: Consuming Resource via Auto-generation for LLM-DoS Attack under Black-box Settings. https://arxiv.org/abs/2412.13879
[184] Jialong Zhou, Lichao Wang, and Xiao Yang. 2025. GUARDIAN: Safeguarding LLM Multi-Agent Collaborations with Temporal Graph Modeling. https://arxiv.org/abs/2505.19234
[185] Quanyan Zhu. 2025. Game Theory Meets LLM and Agentic AI: Reimagining Cybersecurity for the Age of Intelligent Threats. https://arxiv.org/abs/2507.10621
[186] Andy Zou and Others. 2024. Improving Alignment and Robustness with Circuit Breakers. https://arxiv.org/abs/2406.04313
[187] Zhenhua Zou and Others. 2025. BlockA2A: Towards Secure and Verifiable Agent-to-Agent Interoperability. https://arxiv.org/abs/2508.01332

36 Sahaya Jestus Lazer, Kshitiz Aryal, Maanak Gupta, 以及 Elisa Bertino

[155] Krti Tallam. 2025. Transforming Cyber Defense: Harnessing Agentic and Frontier AI for Proactive, Ethical Threat Intelligence. doi:10.48550/arXiv.2503.00164
[156] Trend Micro Research. 2025. Using Agentic AI & Digital Twin for Cyber Resilience. https://www.trendmicro.com/en_us/research/25/e/ai-digital-twin-cyber-resilience.html Accessed: 2025-08-15.
[157] Trustwise. 2024. Capture-the-Flag Security in Legal Technology. https://trustwise.ai/capture-the-flag-security-in-legal-technology/ Accessed: 2025-09-08.
[158] Prashant Vajpayee and Gahangir Hossain. 2025. Cyber Defense through Agentic AI Enabled Automation: An Approach to Reduce Cyber Risk. Association for Computing Machinery, New York, NY, USA. doi:10.1145/3716489.3728439
[159] Varonis. 2024. Detecting Agentic AI Threats. https://www.varonis.com/blog/detecting-agentic-ai-threats Accessed: 2025-09-08.
[160] VentureBeat. 2025. Black Hat 2025: How Agentic AI is Finally Delivering Real Value. https://venturebeat.com/security/black-hat-2025-how-agentic-ai-is-finally-delivering-real-value Accessed: 2025-09-08.
[161] Visa Acceptance Solutions. 2025. *Payment Trends Update: How AI and Agentic AI Impact Fraud.* https://www.visaacceptance.com/en-us/blog/article/2025/agentic-ai-fraud-impact.html Accessed September 14, 2025.
[162] Ngoc Tuong Vy Nguyen, Felix D Childress, and Yunting Yin. 2025. Debate-Driven Multi-Agent LLMs for Phishing Email Detection. In *2025 13th International Symposium on Digital Forensics and Security (ISDFS)*. IEEE. doi:10.1109/isdfs65363.2025.11012014
[163] Kun Wang et al. 2025. A Comprehensive Survey in LLM(-Agent) Full Stack Safety: Data, Training and Deployment. https://arxiv.org/abs/2504.15585
[164] Zhun Wang, Vincent Siu, Zhe Ye, Tianneng Shi, Yuzhou Nie, Xuandong Zhao, Chenguang Wang, Wenbo Guo, and Dawn Song. 2025. AgentVigil: Generic Black-Box Red-teaming for Indirect Prompt Injection against LLM Agents. https://arxiv.org/abs/2505.05849
[165] Haiman Wong and Tiffany Saade. 2025. *The Rise of AI Agents: Anticipating Cybersecurity Opportunities, Risks, and the Next Frontier.* R Street Policy Study No. 325. R Street Institute. https://www.rstreet.org/wp-content/uploads/2025/05/FINAL-r-street-policy-study-no-325.pdf
[166] WunderGraph. 2025. *Harm Limiting for API Access.* https://wundergraph.com/blog/harm_limiting_for_api_access Accessed: 2025-09-21.
[167] Minrui Xu and Others. 2025. Forewarned is Forearmed: A Survey on Large Language Model-based Agents in Autonomous Cyberattacks. arXiv:2505.12786 [cs.NI]
[168] Yinuo Xue, Eric Spero, Yun Sing Koh, and Giovanni Russello. 2025. MultiPhishGuard: An LLM-based Multi-Agent System for Phishing Email Detection. https://arxiv.org/abs/2505.23803
[169] Yi Yang, Yitong Ma, Hao Feng, Yiming Cheng, and Zhu Han. 2025. Minimizing Hallucinations and Communication Costs: Adversarial Debate and Voting Mechanisms in LLM-Based Multi-Agents. *Applied Sciences* 15, 7 (2025). doi:10.3390/app15073676
[170] Shunyu Yao and Others. 2023. ReAct: Synergizing Reasoning and Acting in Language Models. https://arxiv.org/abs/2210.03629
[171] Miao Yu and Others. 2025. A Survey on Trustworthy LLM Agents: Threats and Countermeasures. arXiv:2503.09648 https://arxiv.org/abs/2503.09648
[172] Wenhan Yu and Jun Zhao. 2023. Quantum Multi-Agent Reinforcement Learning as an Emerging AI Technology: A Survey and Future Directions. In *2023 International Conference on Computer and Applications (ICCA)*. 1–7. doi:10.1109/ICCA59364.2023.10401605
[173] Pallavi Zambare and Others. 2025. NetMoniAI: An Agentic AI Framework for Network Security & Monitoring. https://arxiv.org/abs/2508.10052
[174] Pallavi Zambare, Venkata Nikhil Thanikella, and Ying Liu. 2025. Securing Agentic AI: Threat Modeling and Risk Analysis for Network Monitoring Agentic AI System. https://arxiv.org/abs/2508.10043
[175] Lingfeng Zeng et al. 2025. FinGAIA: A Chinese Benchmark for AI Agents in Real-World Financial Domain. https://arxiv.org/abs/2507.17186
[176] Andy K. Zhang et al. 2025. BountyBench: Dollar Impact of AI Agent Attackers and Defenders on Real-World Cybersecurity Systems. https://arxiv.org/abs/2505.15216
[177] Hanrong Zhang and Others. 2025. Agent Security Bench (ASB): Formalizing and Benchmarking Attacks and Defenses in LLM-based Agents. https://arxiv.org/abs/2410.02644
[178] Jiaqi Zhang, Chen Gao, Liyuan Zhang, Yong Li, and Hongzhi Yin. 2025. SmartAgent: Chain-of-User-Thought for Embodied Personalized Agent in Cyber World. https://arxiv.org/abs/2412.07472
[179] Jiawei Zhang, Shuang Yang, and Bo Li. 2025. UDora: A Unified Red Teaming Framework against LLM Agents by Dynamically Hijacking Their Own Reasoning. https://arxiv.org/abs/2503.01908
[180] Qingzhao Zhang, Ziyang Xiong, and Z. Morley Mao. 2025. LLM Safeguard is a Double-Edged Sword: Exploiting False Positives for Denial-of-Service Attacks. https://arxiv.org/abs/2410.02916
[181] Wei Zhang and Others. 2025. Penetration Testing for System Security: Methods and Practical Approaches. https://arxiv.org/abs/2505.19174
[182] Yuyang Zhang and Others. 2025. Towards Action Hijacking of Large Language Model-based Agent. https://arxiv.org/abs/2412.10807
[183] Yuanhe Zhang, Zhenhong Zhou, Wei Zhang, Xinyue Wang, Xiaojun Jia, Yang Liu, and Sen Su. 2025. Crabs: Consuming Resource via Auto-generation for LLM-DoS Attack under Black-box Settings. https://arxiv.org/abs/2412.13879
[184] Jialong Zhou, Lichao Wang, and Xiao Yang. 2025. GUARDIAN: Safeguarding LLM Multi-Agent Collaborations with Temporal Graph Modeling. https://arxiv.org/abs/2505.19234
[185] Quanyan Zhu. 2025. Game Theory Meets LLM and Agentic AI: Reimagining Cybersecurity for the Age of Intelligent Threats. https://arxiv.org/abs/2507.10621
[186] Andy Zou and Others. 2024. Improving Alignment and Robustness with Circuit Breakers. https://arxiv.org/abs/2406.04313
[187] Zhenhua Zou and Others. 2025. BlockA2A: Towards Secure and Verifiable Agent-to-Agent Interoperability. https://arxiv.org/abs/2508.01332

提交至 ACM 的手稿